

# Operational Risk

Edition 26, June 2025



This workbook relates to syllabus  
version 22.0 and will cover the exam on  
20 September 2025 to 19 September 2027

Welcome to the Chartered Institute for Securities & Investment's Operational Risk study material.

This workbook has been written to prepare you for the Chartered Institute for Securities & Investment's Operational Risk examination.

**Published by:**

Chartered Institute for Securities & Investment

© Chartered Institute for Securities & Investment 2025

20 Fenchurch Street, London EC3M 3BY, United Kingdom

Tel: +44 20 7645 0600

Email: [customersupport@cisi.org](mailto:customersupport@cisi.org)

Fax: +44 20 7645 0601

[www.cisi.org/qualifications](http://www.cisi.org/qualifications)

**Author:**

Stewart Lancaster, Chartered FCSI

**Reviewers:**

Richard Ward

Jigna Malde, Chartered FCSI

This is an educational workbook only and the Chartered Institute for Securities & Investment accepts no responsibility for persons undertaking trading or investments in whatever form.

While every effort has been made to ensure its accuracy, no responsibility for loss occasioned to any person acting or refraining from action as a result of any material in this publication can be accepted by the publisher or authors.

All rights reserved. No part of this publication may be reproduced, stored in a retrieval system, or transmitted, in any form or by any means, electronic, mechanical, photocopying, recording or otherwise without the prior permission of the copyright owner.

Warning: any unauthorised act in relation to all or any part of the material in this publication may result in both a civil claim for damages and criminal prosecution.

Candidates should be aware that the laws mentioned in this workbook may not always apply to Scotland.

A learning map, which contains the full syllabus, appears at the end of this workbook. The syllabus can also be viewed on [cisi.org](http://cisi.org) and is also available by contacting the Customer Support Centre on +44 20 7645 0777. Please note that the examination is based upon the syllabus.

The questions contained in this workbook are designed as an aid to revision of different areas of the syllabus and to help you consolidate your learning chapter by chapter.

Workbook version: 26.1 (June 2025)

## Important – Keep Informed on Changes to this Workbook and Examination Dates

Changes in industry practice, economic conditions, legislation/regulations, technology and various other factors mean that practitioners must ensure that their knowledge is up to date.

At the time of publication, the content of this workbook is approved as suitable for examinations taken during the period specified. However, changes affecting the industry may either prompt or postpone the publication of an updated version.

It should be noted that the current version of a workbook will always supersede the content of those issued previously.

Keep informed on the publication of new workbooks and any changes to examination dates by regularly checking the CISI's website: [cisi.org/candidateupdate](https://cisi.org/candidateupdate)

## Learning and Professional Development with the CISI

The Chartered Institute for Securities & Investment is the leading professional body for those who work in, or aspire to work in, the investment sector, and we are passionately committed to enhancing knowledge, skills and integrity – the three pillars of professionalism at the heart of our Chartered body.

CISI examinations are used extensively by firms to meet the requirements of government regulators. Besides the regulators in the UK, where the CISI head office is based, CISI examinations are recognised by a wide range of governments and their regulators, from Singapore to Dubai and the US. Around 50,000 examinations are taken each year, and it is compulsory for candidates to use CISI workbooks to prepare for CISI examinations so that they have the best chance of success. Our workbooks are normally revised every year by experts who themselves work in the industry and also by our Accredited Training Partners, who offer training and elearning to help prepare candidates for the examinations. Information for candidates is also posted on a special area of our website: [cisi.org/candidateupdate](https://cisi.org/candidateupdate).

This workbook not only provides a thorough preparation for the examination it refers to, it is also a valuable desktop reference for practitioners, and studying from it counts towards your Continuing Professional Development (CPD). Mock examination papers, for most of our titles, will be made available on our website, as an additional revision tool.

CISI examination candidates are automatically registered, without additional charge, as student members for one year (should they not be members of the CISI already), and this enables you to use a vast range of online resources, including CISI TV, free of any additional charge. The CISI has more than 40,000 members, and nearly half of them have already completed relevant qualifications and transferred to a core membership grade. You will find more information about the next steps for this at the end of this workbook.



|                                                             |     |
|-------------------------------------------------------------|-----|
| Risk Basics . . . . .                                       | 1   |
| Other Major Risks . . . . .                                 | 15  |
| The Nature of Operational Risk . . . . .                    | 45  |
| The Causes and Impacts of Operational Risk Events . . . . . | 93  |
| Operational Risks Arising in the Trade Cycle . . . . .      | 109 |
| The Support and Control Functions . . . . .                 | 129 |
| Operational Risk in the Regulatory Environment . . . . .    | 145 |
| Glossary . . . . .                                          | 169 |
| Multiple Choice Questions . . . . .                         | 181 |
| Syllabus Learning Map. . . . .                              | 197 |



It is estimated that this manual will require approximately 80 hours of study time.

**What next?**

See the back of this book for details of CISI membership.

**Need more support to pass your exam?**

See our section on Accredited Training Partners.

**Want to leave feedback?**

Please email your comments to [learningresources@cisi.org](mailto:learningresources@cisi.org)







# Before you open Chapter 1

We love a book! ...but don't forget you have been sent a link to an ebook, which gives you a range of tools to help you study for this qualification

Depending on the individual subject being studied and your device, your ebook may include features such as:



Watch video clips related to your syllabus



Read aloud function\*



Adjustable text size allows you to read comfortably on any device\*



Pop-up definitions



Highlight, bookmark and make annotations digitally\*



Images, tables and animated graphs



Links to relevant websites



End of chapter questions and interactive multiple choice questions

\* These features are device dependent. Please consult your manufacturers guidelines for compatibility



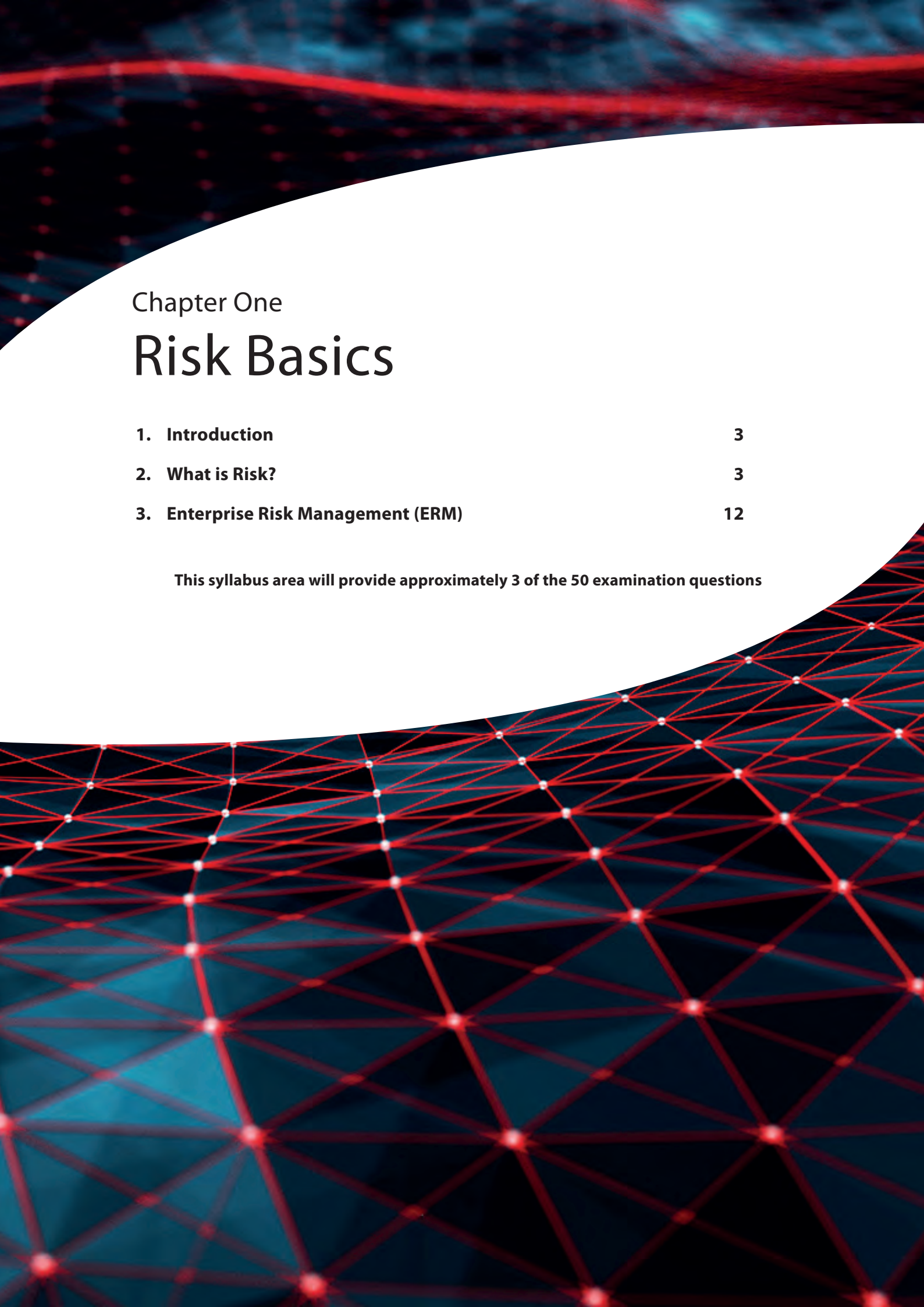
Find out more at [cisi.org/ebooks](http://cisi.org/ebooks)

The use of online videos and voice functions allowed me to study at home and on the go, which helped me make more use of my time. I would recommend this as a study aid as it accommodates a variety of learning styles.

Billy Snowdon, Team Leader, Brewin Dolphin







## Chapter One

# Risk Basics

|                                     |    |
|-------------------------------------|----|
| 1. Introduction                     | 3  |
| 2. What is Risk?                    | 3  |
| 3. Enterprise Risk Management (ERM) | 12 |

**This syllabus area will provide approximately 3 of the 50 examination questions**





## 1. Introduction

This workbook describes what **risk** is and what it means to the financial services sector. It describes the four common categories of risk – credit, market, liquidity and operational – providing a brief contextual overview of the first three and focusing particularly on the latter. **Operational risk** and some of the more important aspects of its management are described in detail in chapters 3, 4 and 5.

This opening chapter introduces the basics of risk and explains why risk in general is a subject of concern in all industries and in all walks of life. It then focuses on where the category of operational risk fits into the overall picture. Finally, it describes some of the high-profile events that have served to highlight the critical need to understand and manage operational risk effectively.

## 2. What is Risk?

### 2.1 What is Risk?

The consequences of ‘something going wrong’ can be critical; therefore, the need to understand why something might go wrong and then to try to prevent the possibility of its occurrence is a fundamental requirement for any industry. The aerospace, civil engineering and chemical processing industries are prime examples as the consequences can be extremely high. For instance, for an airline operator, an aircraft crash in service will have some profound consequences.

The five major consequences are:

1. loss of passenger/aircrew lives
2. financial loss arising from destruction of the aircraft
3. financial loss arising from subsequent litigation
4. loss of passenger confidence and reduction in future airline travel leading to a fall in revenues, and
5. damage to reputation.

For these reasons, all airline operators expend a great deal of time, effort and money on ensuring adequate safety standards by means of rigorous airframe and engine maintenance, adequate aircrew training, the establishment of safety procedures, and general compliance with all relevant industry standards. The same approach has been adopted by many other industries and activities. Think of the importance in the modern world of health and safety regulations, inspection and enforcement.

There are direct parallels with the approach to operational risk in the financial services sector; here, the consequences generally occur in the form of financial loss or reputational damage and to prevent this, firms put risk control procedures in place.

Financial services regulators, just like airline regulators, set minimum standards and then police them to ensure that firms are doing enough to protect their clients' interests.

That said, in financial services, risk can mean different things to different people – there is no single definition. To some, risk is the chance (ie, the likelihood or probability) of permanent capital loss (in nominal terms and/or when adjusted for inflation); while to others, it is the volatility in market price (ie, temporary capital loss). Generally, though, risk refers to the potential for an investor to lose money.

Historically, financial institutions have concentrated on market, credit and liquidity risk as a means of understanding their exposure to loss. However, following a number of high-profile losses due to operational failures, the industry has increasingly focused on the measurement and management of operational risk.

Thus, it is generally accepted that credit, market, liquidity and operational risk are the four main categories of risk in the financial services sector. We will now look at each of these risks in turn.

## 2.2 General Risk Definition

### Learning Objective

1.1.1 Know the following major risk categories: credit risk; market risk; operational risk; liquidity risk

The Concise Oxford English Dictionary defines risk as:

*'The chance or possibility of damages, loss, injury or other adverse consequences'.*

The essential points to note when applying this definition to **risk management** are:

- **Chance** – this is the 'likelihood' or 'probability' of an event happening in the future. The event has not yet happened; it exists as one of a number of possible outcomes that may occur in the future. This is important because it suggests that people can take action today that may reduce the chance of an event occurring in the future.
- **Adverse consequences** – the potential outcome is regarded as negative. It is a potential occurrence that people are trying to avoid. This is also called the **downside** of risk.

As noted above the four main categories of risk in the financial services sector are as follows:

- **Credit risk** – relates to lending or agreeing to trade with another counterparty. This is the fundamental risk in finance, as banks' traditional business is to lend money in return for interest revenue. Lending institutions accept the credit risk of a borrower not paying back the loan in exchange for revenue. The higher the **risk profile** of the borrower, the higher the interest rate banks can charge. Credit risk also exists between trade counterparties, with the risk being that a counterparty does not pay or deliver the asset they have agreed to deliver on time.
- **Market risk** – is manifested by exposure to the uncertain market value of a portfolio. For example, a trader may hold a portfolio of securities, assets or commodities. They know what the market value of these instruments is today, but are uncertain as to what the market value will be a week from today. Therefore, the trader faces market risk. Market risk represents the potential risk of loss of earnings or capital arising from a reduction in the value of financial instruments. In simple terms, an investor is exposed to market risk as soon as a financial product is purchased. This is intrinsic in all markets and across all products.
- **Liquidity risk** – is the risk that a bank or other financial institution may not be able to meet its short-term financial obligations (including its ability to settle transactions) due to insufficient cash, thereby rendering the firm insolvent. This is sometimes referred to as 'firm liquidity risk' or 'funding liquidity risk' to differentiate it from '**asset liquidity risk**' which is the risk of loss caused by an inability to sell an asset at or near the current market value when required due to lack of liquidity in the market. Liquidity risk has historically been linked to systemic failures including the financial crisis of 2009 whereby banks were unable to refinance their debts leading to government intervention to bail out these institutions, bank failures and a broader financial crisis.
- **Operational risk** – is formally defined by the Basel Committee on Banking Supervision (BCBS) as '*the risk of loss resulting from inadequate or failed internal processes, people and systems or from external events*'. In practical terms, operational risk addresses the risk of things going wrong with the day-to-day operating activities of the firm, which then results in financial or other loss. There is a strong correlation between operational risk and the other risk categories, and when something goes wrong there is often an operational risk impact in addition to any credit, market or liquidity risk impacts experienced by the firm. While credit, market and liquidity risk may all be a function of the broader economic environment (eg, systemic risks), operational risks are specific to the firm in question.

## 2.3 Risk Management

### Learning Objective

#### 1.1.2 Understand simple examples of risk in the financial services sector

The financial services sector has become increasingly aware of the importance of managing risk. For financial services institutions, as stated in section 2.2, this may involve credit risk, market risk, liquidity risk or operational risk. For financial services regulators, it has come to mean adopting risk-based supervision. For banks in particular, the measurement and control of capital risk has become a key issue.

Traditionally, credit risk from lending was the primary risk for banks. As financial institutions entered new markets and traded new products, other risks such as market risk began to occupy the attention of management.



In the last few decades, financial institutions have developed sophisticated tools and methodologies to manage market risk, driven by the huge rewards involved in its **upside**. The methods have been modified to allow the modelling of credit risk.

The importance of operational risk has been acknowledged, and it now takes its place as one of the fundamental categories of risk that require effective management.

Operational risk management is concerned principally with identifying, assessing, measuring and managing inherent weaknesses in the operational workings of a financial institution.

The following activities and associated processes are common across financial institutions and are prone to operational risk events:

- Trading and dealing
- Marketing and selling
- Product development
- Data entry and data maintenance
- Legal
- Credit
- Payments and treasury
- Accounting
- Technology, IT and project functions
- Human resources
- Compliance.

They can affect one or many areas of the firm and can cross departmental boundaries. The main sources from which deficiencies can originate in the financial services sector, along with simple examples of how this risk could be realised, can be found within the table below:

| Area                       | Risk example                                                                                                                                                                                                                                                                                                                                                                                                                   |
|----------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Information systems</b> | Incorrect or missing information being held within, or passed between, key systems; this could result in inaccurate regulatory returns, inappropriate transactions being effected within the firm, incorrect client positions and compensation claims; eg, a MiFID investment firm incorrectly reporting transactions to the Financial Conduct Authority (FCA) due to information not being passed accurately between systems. |
| <b>Internal controls</b>   | Inappropriately designed controls or control failures can result in errors, omissions and risk events; eg, a firm has seen an increase in internal fraud as it has not introduced appropriately designed internal controls including segregation of duties, ie, individuals who initiate payments are not able to approve or execute the payment.                                                                              |
| <b>Human error</b>         | This could result in controls not operating as expected, missed deadlines, fines, compensation claims and rework; eg, a member of staff keying a manual payment of £1,000,000 instead of £100,000 could result in a significant loss to the firm.                                                                                                                                                                              |

| Area                                | Risk example                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                            |
|-------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Systems failure</b>              | This can prevent the firm operating, meeting its obligations to its clients, the market or the regulator, resulting in penalties, fines and reputation damage; eg, the failure of internal software that links directly to external banking systems could prevent the settlement of market transactions and prevent clients from receiving their money or effecting payments on a timely basis.                                                                                                                                                                                                         |
| <b>Lack of (or poor) governance</b> | This could lead to poor decision making, inadequate policies or procedures and a lack of independent challenge; eg, a known control weakness has not been acted on leading to recurring control failures and regulatory breaches increasing the risk of regulatory fines or scrutiny and reputational damage. Appropriate and timely governance intervention would have identified that the firm is acting outside of its risk appetite and charged those responsible for the operation of these controls to address the root cause of the issue or to escalate the issue to the firm's governing body. |
| <b>External events</b>              | A cyber attack could result in the firm's systems being compromised, preventing access to key systems; eg, clients are unable to access the secure online platform for an online trading firm, preventing clients from closing out positions, and resulting in unacceptable client losses.                                                                                                                                                                                                                                                                                                              |

In general terms, risk management tries to ensure that the likelihood of risks being realised and their potential impact are reduced to acceptable levels. The four important aspects of this description are:

- **Implementation** – risk management is concerned with taking action to reduce risk levels. It requires a proactive, or preventative approach. There is little benefit in the foreknowledge that a loss-making event may occur if no action is taken to prevent it, or to mitigate its consequences.
- **A structured process** – this means using the result of a planned, ongoing decision process and related action programme. This involves identifying, assessing, controlling, monitoring, reporting and mitigating risks where possible. Once implemented, there will be a need for feedback and review of the process to aid and inform future decision-making.
- **Reducing the likelihood** – the likelihood of a risk being realised within a business can be reduced but cannot be eliminated completely (unless the activity to which the risk is related is not undertaken at all). This is linked to the idea of probability. If the future were certain, there would be no probabilities, only certain outcomes. The best that can be done is to try to make the future a little more certain and reduce the chance of negative outcomes.
- **Acceptable levels** – given that risk cannot be eliminated entirely, effective risk management is concerned with reducing the chances of misfortune to an acceptable level. What is acceptable will depend upon factors such as risk appetite, regulatory boundaries, and the level of risk that each institution feels comfortable with. Identifying acceptable levels of risk involves understanding and balancing the downside of risk with the potential benefits of the upside. Finding agreement at a firm-wide or industry-wide level and obtaining regulatory consent on the level of acceptability of risk is a major area of contention when designing risk management strategies.



## 2.4 Major Operational Risk Incidents

### Learning Objective

- 1.1.3 Understand the operational risk issues linked with recent major risk-related events in the financial services sector, such as: Invesco (2014); PPI; LIBOR; HSBC (2016); Central Bank of Bangladesh (2016); Wells Fargo (2016); TSB (2018); GAM (2018); Raphael's Bank (2018)

As stated historically, financial institutions have concentrated on market and credit risk as a means of managing their exposure to loss. However, following a number of high-profile losses due to operational failures, the industry has increasingly been focusing on managing and measuring the risks inherent in their internal processes. This section summarises well-known operational failures which have highlighted the need for better understanding and control of operational risk.

- **Invesco** – this US-based investment management company was fined £18.6 million in April 2014 by the UK regulator, the **Financial Conduct Authority (FCA)**, for exposing investors to higher levels of risk than they had been led to expect. This higher level of exposure occurred during the period between May 2008 and November 2012. Customers lost in the region of £5 million and Invesco was required to pay compensation to clients that were affected by this major oversight. It was found that Invesco did not comply with investment limits and did not clearly inform investors, or explain the associated risks, of its use of derivatives in its simplified prospectus required for each fund. Invesco incorrectly described the impact of using derivatives in the key investor information documents that they produced in 2012. By using derivatives, Invesco was introducing leverage into its funds, although the firm was not allowed to use derivatives in this way. Invesco had to quickly improve its systems and controls as identified by the FCA. The regulator also found that the firm had not always recorded trades on time, which meant funds could have been wrongly priced. The firm also failed to monitor whether trades were fairly allocated between funds, creating an actual risk that some funds may have been disadvantaged.
- **PPI** – Payment Protection Insurance (PPI) was designed to meet the repayments on loans and credit cards should the borrower die, become ill or disabled, lose their job or anything else that meant that the borrower was unable to service the repayment of the debt. PPI was often sold at the same time the credit facility was offered to the borrower. Surveys in 2008 showed that approximately 40% of PPI policyholders in the UK did not know that they had been sold a PPI policy. It was discovered that PPI had been mis-sold on a huge scale in the UK and, over a ten-year period, many complaints were made by borrowers to the companies providing the PPI policies. The sale of PPI policies usually meant that the firm providing them earned a large commission on each individual policy sold. Often the commission earned by selling the PPI policy was greater than the interest earned by the lender by granting the credit facility to the borrower in the first place. Customers were often told that the borrowing was protected, but rarely in practice were they advised of the cost and nature of the protection that they had been sold. Often borrowers that were in financial hardship were unlikely to question the policy supporting the credit granted to them as they required the loan and assumed that if they did not also agree to accept the protection, their chance of gaining the credit facility would be diminished.

The FCA has fined a number of high-profile companies for mis-selling PPI. Borrowers who believe that they were mis-sold PPI are still encouraged to complain to the original lender and seek compensation.

- **LIBOR** – The London Interbank Offered Rate (LIBOR) is an average interest rate that is calculated daily through submissions by major banks in London. As early as 2008, there were rumours circulating in the financial services sector that some banks were attempting to manipulate this rate for their own benefit. The LIBOR scandal itself arose when it was found that some banks were falsely over- or understating their interest rates in order to profit on certain trades or to give the false impression that they were more creditworthy than they actually were. LIBOR was also the benchmark rate for many types of derivatives, such as swaps and structured products. Banks could, therefore, influence the setting of prices for products they had sold to clients.

The banks are required to submit their bids for the interest rates that they are paying, or would expect to pay for interbank lending. One way of assessing the health of the financial system is to look at the LIBOR rate. For example, if the banks involved in submitting their interest rates feel more confident about the financial system, they would submit a lower interest rate and vice versa. In 2012, it was revealed by Barclays Bank that there was significant fraud and collusion by member banks, and that it had been fined at that stage £290 million by the UK's then regulator, the FSA, for rigging LIBOR between 2005 and 2009. Several other banks were also indicted and had action taken against them, including a prison sentence for a trader at both Citigroup and UBS, Tom Hayes. In addition, new benchmark interest rates other than LIBOR have been introduced to curb future manipulation.

- **HSBC** – was targeted in January 2016 in a distributed denial-of-service (DDoS) attack. HSBC confirmed that the attack was successfully defended and that its systems had not been breached; however, the cyber attack resulted in HSBC's online banking facilities being unavailable – with customers not being able to access their online accounts or make payments.

A cyber attack such as a DDoS is designed to overwhelm websites and other online services with huge volumes of website traffic. Hackers stealthily infect thousands of computers around the world with malware that allows these machines to be used as part of a coordinated attack on the target website.

The attack was timed to coincide with one of the bank's busier periods, including the first pay date after the Christmas period for many, as well as coinciding with the self-assessment tax payment deadline at the end of January. While there was no **direct loss** as a result of the attack, indirect losses included reputational damage, as customers were frozen out of their systems, as well as the cost of enhancing system resilience to prevent a recurrence of this issue.

- **Bank of Bangladesh** – the central bank of Bangladesh was subject to a sophisticated cyber attack in an attempt to steal over \$950 million. In February 2016, hackers gained access to the bank's internal systems and payment credentials, allowing them to initiate a series of transactions via **Society for the Worldwide Interbank Financial Telecommunication (SWIFT)** to a number of fictitious entities in Sri Lanka and the Philippines.

The bank's systems had been compromised a month earlier, which allowed the criminals to not only initiate a number of fraudulent payments but to also turn off internal printers that were used to print all money transfer instructions which were then manually reviewed. Suspicion was raised by the Federal Bank of New York due in part to a spelling mistake in the recipient's name; however, weaknesses in the bank's internal controls meant that once the suspicion was raised the bank was unable to determine if the trades were in fact fraudulent. Once the internal printer functionality was eventually restored the bank became aware of dozens of transactions that had been initiated over the weekend. While the suspicious activity was identified by the Federal Bank of New York, delays in responding by the Bank of Bangladesh meant that the cyber-criminals managed to withdraw over \$80 million.

- Wells Fargo** – was fined \$185 million in September 2016 as a result of employees of Wells Fargo fraudulently opening millions of fee-bearing bank accounts and credit cards on behalf of clients without their consent in order to meet sales targets and to boost income for the bank. The fraud was discovered when clients started noticing unexpected fees being deducted from their accounts and, in some cases, money was moved from the client's legitimate accounts to fund these fraudulent accounts. As part of the widespread deception which took place over a five-year period, employees used a process known as 'pinning' whereby the client's security pin number was reset to 0000, allowing members of staff to access and control the account; employees would also replace the clients' contact details with their own contact details to circumvent fraud notifications to the clients. Over the period 2011–16, Wells Fargo fired over 5,000 employees for opening accounts without client consent, and, in February 2019, it agreed to settle an associated class action for \$320 million.
- Merrill Lynch** – was fined £34 million in October 2017 as a result of repeated EMIR transaction reporting failures after having received two prior final notices from the FCA. Merrill Lynch had been subject to the transaction reporting requirements for exchange-traded derivatives (ETDs) under EMIR since February 2014 and had experienced difficulties in implementing appropriate systems and controls.

ETD trades consist of two legs: the market leg and the client leg. These were not recorded within their systems, meaning these trades had to be synthetically generated by their systems to allow them to be reported onwards to the regulator. Unfortunately, a static data table that contained incorrect information was used to identify if the trade was reportable, resulting in over 68 million trades not being reported to the regulator.

Merrill Lynch was criticised for delaying the implementation of the reporting requirements until three months before the regulatory deadline, and relying on a large number of external contractors to support its reporting initiative, the majority of whom were let go once the regulatory deadline had arrived despite not having fully implemented the required processes. Specifically, the FCA stated that the systems testing conducted by Merrill Lynch *'was not adequate to address the risk that the reports [...] were complete and accurate'*.

While the issues were identified internally, the lack of appropriate controls over the three-year period in review, coupled with the repeated nature of the offence, resulted in the regulator increasing the fine by 60%.
- TSB** – as part of their separation from the Lloyds Banking Group in September 2018, TSB migrated their five million customers on to its proprietary digital platform. Delays in the migration led to 1.9 million customers losing access to their online banking and mobile banking applications.

During the outage, TSB was the target of an unprecedented fraud with over 10,000 incidents being reported; this was further exacerbated by what the bank has acknowledged as 'poor communication' with its customers following the incident. The bank later admitted this had diminished its clients' trust. The FCA subsequently started an investigation into the bank due to concerns that TSB had been downplaying the issues and had not responding quickly enough to early concerns. TSB committed to ensuring that all clients would not be out of pocket due to the migration issues or subsequent fraud.
- GAM** – in July 2018, the Swiss asset manager suspended the manager of its Absolute Return Bond Fund following a whistleblower tip regarding *'a number of potential misconduct issues'*. Following an independent investigation conducted by an external law firm, the whistleblower escalated and expanded on their concerns to the FCA.

The whistleblower claimed that there was a failure to observe internal risk management and record-keeping policies and conflicts of interest policies over a prolonged period. The investigation concluded that, while there was no material client detriment, there had been breaches of its dealing and inducement policies.

Subsequently, GAM experienced large outflows of funds as clients sought to move away from the fund range in question. This led to its liquidation and a management restructure of the firm in a bid to enhance the organisational controls, thus reducing the autonomy its investment staff had previously enjoyed.

- **Raphael's Bank** – was one of the UK's oldest independent retail banks; it operated prepaid card and charge card services across Europe and the UK for which it relied on an outsourced provider. The bank had been fined previously by the PRA in 2015 for its failure in relation to oversight of outsourced functions. In May 2018, the FCA and the PRA jointly fined Raphael's Bank £1.89 million for '*flaws in its overall management and oversight of **outsourcing** risk from board level down*' between 2014 and 2016.

The regulator noted that Raphael's bank did not have the processes in place to identify and assess the risks related to business continuity and disaster recovery arrangements. These risks crystallised when an incident occurred at its third-party supplier preventing any transactions from being authorised, which affected over 3,000 customers who were unable to use their prepaid cards during an eight-hour period on Christmas eve in 2015. The bank was eventually wound down in 2019 after it failed to attract a buyer.

- **WhatsApp** – In September 2022 the US regulator the Securities Exchange Commission (SEC) fined multiple banks \$2 billion for what they described as '*pervasive off-channel communications*' which allowed employees of the organisations involved to avoid regulatory scrutiny by communicating via WhatsApp. These record-keeping failings were identified across multiple levels from junior employees through to senior executives.

A number of global financial institutions including Barclays, Bank of America, Citigroup, Credit Suisse, Deutsche Bank, Goldman Sachs, Morgan Stanley and UBS were ordered to pay fines in the region of \$200 million each. It is believed that the use of instant messaging apps became more commonplace during the COVID-19 pandemic whereby employees and employers had to adapt quickly to a remote working environment as countries introduced lockdowns. However, the decentralised nature of these applications, coupled with the ability to permanently delete messages, means they are not easily accessible or able to be monitored by organisations, and thus breach record-keeping requirements designed to detect and prevent financial manipulation of markets and fraudulent activities.

### 3. Enterprise Risk Management (ERM)

#### Learning Objective

##### 1.2.1 Understand Enterprise Risk Management (ERM): objectives; challenges

---

**Enterprise risk management (ERM)** is a concept that provides a firm with the ability to understand, address and manage its interrelated risks in the most effective way. It is also commonly referred to as integrated risk management, or firm-wide risk management, because it is a structured, consistent and continuous process across the whole organisation (which could extend around the globe) for identifying, assessing, and deciding on responses to, and reporting on opportunities and threats that affect the achievement of its objectives.

One of ERM's main aims is to protect shareholder value by integrating the management of all the disparate risks of a portfolio of businesses. This allows a firm to appreciate its overall risk profile and to identify and explain **financial risk** in a transparent, structured and comprehensive way.

In order to protect shareholder value, ERM has four practical objectives that make financial risk management more effective. These are:

- holistic risk identification and assessment aligned with the overall risk management process
- improved decision making based on an understanding of total risk exposure ensuring that risk considerations are built into or considered when setting the business strategy
- stronger risk governance, ensuring clear accountability to manage the consequences of risk proactively across the firm in an integrated manner, and
- enhanced internal controls environment ensuring the firm has a common understanding of risk and risk language and that robust mitigations are in place for known risks.

These objectives are common to any risk-management process. The difference with ERM is that it integrates the management of all risks. This means generating a common framework and using a common approach and systems for the management of:

- market risk
- credit risk
- liquidity risk
- operational risk
- reputational risk
- legal and compliance risk
- **strategic risk**
- ESG risk, and
- **business risk.**

While we have covered market, credit, liquidity and operational risk earlier in this chapter, ERM considers a wider range of risks that could impact the long-term success of an organisation including:

- **Reputational risk** – the risk that the external perception of an organisation is damaged which can lead to loss of customer trust, loss of business reduced share price.
- **Legal and compliance risks** – both legal and compliance risks relate to the risk of legal claims, regulatory sanctions (eg, fines, loss of regulatory permissions), financial loss or legal proceedings as a result of failing to comply with applicable laws or regulations.
- **Strategic risk** – that the company does not reach its goals due to the impact of strategic decisions; this could be a failure to implement the business strategy or simply that the strategy was poorly designed, or unable to withstand, or adapt to, a changing business environment such as regulatory changes or economic changes.
- **ESG risk** – the risk of harm from environmental, social or governance factors; it is closely related to reputational risk but extends beyond reputational harm to include the financial or operational impacts as a result of poor (or poorly perceived) ESG practices.
- **Business risk** – the risk that internal or external factors can negatively impact the organisations profitability and ultimately in extremis cause the firm to fail. These can include market fluctuations, economic changes or increase competition, as well as reputation or operational risk events resulting in a loss of revenue.

Much of the effort involved in ERM, at present, is in understanding the interrelationship between the different risk types that a business faces and improving the way the various risk specialists work with each other in forming the overall risk picture. As a result, ERM is the next major strategic step forward for financial institutions to help them manage their risk.

There are a number of areas and challenges to be considered when implementing an effective ERM policy. These include the following:

- Has the firm adopted a common process for risk management and is there a common understanding of risk and risk management within the firm?
- How are risk management tools being applied to decision-making within the firm and are they being used effectively and consistently?
- Do all the firm's business and operational plans consider risks and incorporate measures to mitigate those risks and/or to maximise opportunities?
- Is there a sufficient understanding of how each risk area impacts others within the risk teams to allow them to provide adequate challenge to business decisions?
- Is the risk management function adequately resourced and granted proper authority, and does it report to a high level within the organisation?

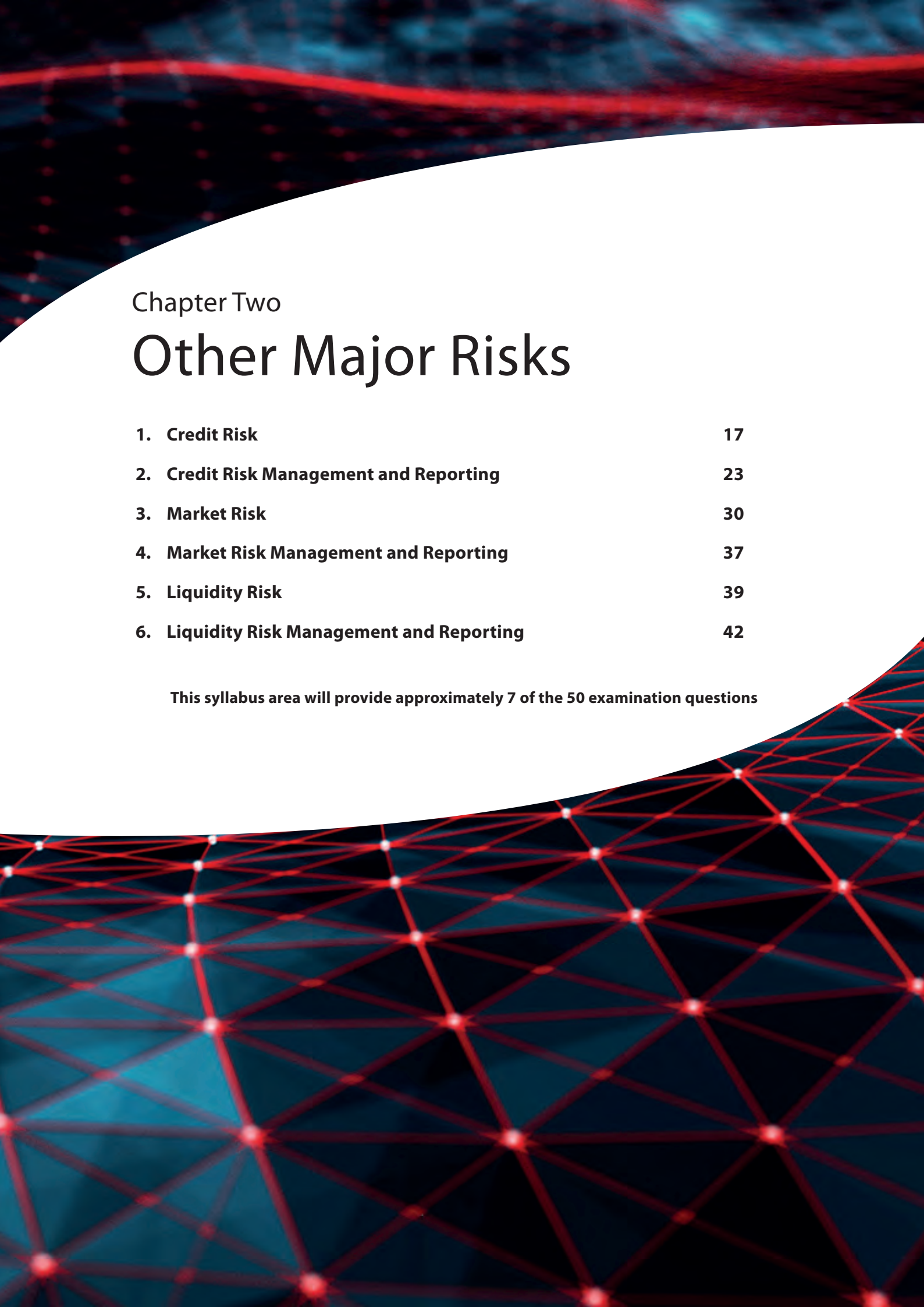
In order to help firms understand the risks that they may be exposed to, it is common to use a **risk register** as a risk-management tool. This acts as a central record or database for all the individual known risks that the firm has identified and then details, for each risk, the source and nature of the risk, the treatment options available and the existing countermeasures that the firm may use to mitigate the risks. The risk register will usually contain an assessment of the impact to the firm should the risk arise in practice, along with the likelihood of the risk occurring. The risk register may appear in different media, eg, a written register or a spreadsheet.



## End of Chapter Questions

Think of an answer for each question and refer to the appropriate section for confirmation.

1. **What is the difference between credit risk and market risk?**  
*Answer Reference: Section 2.2*
2. **Name two of the high-profile losses that have occurred in recent years in the financial services sector.**  
*Answer Reference: Section 2.4*
3. **What caused the London Interbank Offered Rate (LIBOR) scandal in the UK?**  
*Answer Reference: Section 2.4*
4. **Why was Raphael's Bank fined by the Financial Conduct Authority (FCA) in 2018?**  
*Answer Reference: Section 2.4*
5. **What types of risk does ERM aim to address?**  
*Answer Reference: Section 3*
6. **What is strategic risk?**  
*Answer Reference: Section 3*
7. **What are the four objectives of enterprise risk management (ERM)?**  
*Answer Reference: Section 3*



## Chapter Two

# Other Major Risks

|                                                   |           |
|---------------------------------------------------|-----------|
| <b>1. Credit Risk</b>                             | <b>17</b> |
| <b>2. Credit Risk Management and Reporting</b>    | <b>23</b> |
| <b>3. Market Risk</b>                             | <b>30</b> |
| <b>4. Market Risk Management and Reporting</b>    | <b>37</b> |
| <b>5. Liquidity Risk</b>                          | <b>39</b> |
| <b>6. Liquidity Risk Management and Reporting</b> | <b>42</b> |

**This syllabus area will provide approximately 7 of the 50 examination questions**





# 1. Credit Risk

## 1.1 The Nature of Credit Risk

### Learning Objectives

- 2.1.1 Know the basic terms used in the subject of credit risk: counterparty risk; issuer risk
- 2.1.2 Be able to apply the concept of credit risk to simple, practical situations

Traditionally, the primary risk for financial institutions has been credit risk or the potential for loss that results from lending. Institutions accept credit risk in order to earn revenue. They will also lend to firms with higher risks matched at higher interest rates to compensate for the increased chance of loss.

Over the last few decades, companies have expanded rapidly both nationally and globally, markets have developed, new and complex products have been created and the client base of firms has increased. This has led to greater opportunities for revenue growth as well as new and increased credit risks that need to be identified, assessed and controlled. As a result, new ways are continually being developed to offset these risks. Products such as interest rate and currency derivatives have been created for the purpose of market risk management by enabling hedging strategies to be adopted, but a side effect of these products is the creation of yet more credit risk inherent in using such products themselves.

Understanding credit risk has become a complex subject, and its mitigation to acceptable levels is a major concern for all financial institutions as credit losses can have a significant impact on the firm's profitability. This chapter introduces the basic methods of measurement and some common mitigation techniques.

Before considering how counterparty risk or credit risk can be managed, we need to define what constitutes these types of risk.

### 1.1.1 Definition of Credit Risk

Credit risk, also sometimes known as default risk, is defined as the risk of loss caused by the failure of a counterparty to meet its obligations or to repay monies due.

Credit risk affects any firm to which money is owed by way of loan debt or obligation to pay, such as fees. The firm that has the financial obligation is called an **obligor**. Credit risk exists in any contract where one party has an obligation to another and is present in the trading of all financial instruments.

A counterparty is one of the parties to a transaction – either the buyer or the seller, the lender or the borrower.

### 1.1.2 Types of Credit Risk

Credit risk is associated with either **on-balance sheet transactions** or **off-balance sheet transactions**.

On-balance sheet transactions include instruments such as loans and the buying and selling of securities.

Loans carry 'direct risk', which is the simple risk of loan default when money is lent to a customer. Securities carry **issuer risk**, which is the risk of default by the issuer on redemption or on interest servicing when an institution or investor holds debt securities (eg, bonds) issued by the issuing institution.

Bonds are a long-term form of debt and, thus, there is a risk that the issuer will default on its obligations to pay **coupons** and repay the principal with regard to the bond. When considering issuer risk, an investor must assess the likelihood of a default taking place, the severity of such a default and when a default might occur. Bonds are issued by governments and corporations to raise finance, and government bonds (eg, gilts – the UK government securities) are deemed less risky than corporate bonds. However, government issuers can also present credit risk – for example, the Russian Government defaulted on payment of interest and bond redemptions in September 1998.

Buying and selling securities carries counterparty risk which is the risk that the counterparty fails to meet their contractual obligations, for example, a broker fails to deliver the stock as part of an equities transaction and subsequently becomes insolvent. This risk is reduced with DVP (delivery versus payment) transactions which involved the simultaneous exchange of securities and cash.

Off-balance sheet transactions involve financial instruments such as **securitisation** products, forwards, and over-the-counter (OTC) derivatives. These may also include the transfer of liabilities to nominally independent entities, such as special purpose vehicles (SPVs). As these agreements are usually bilateral agreements, these derivative transactions also carry counterparty risk. One of the main advantages of using off-balance sheet products is that they are treated differently from a capital adequacy perspective and allow a firm to reduce its balance sheet liabilities.

Both on- and off-balance-sheet transactions can carry pre-settlement risk and settlement risk.

- **Pre-settlement risk** is the risk that an institution defaults prior to the **settlement** of the transaction when the traded instrument has a positive economic value to the other party.
- **Settlement risk** occurs when there is a non-simultaneous exchange of value (eg, cash for securities) and one of the parties defaults during the exchange.

### Examples of Credit Risk

- A firm makes a loan to a corporate client. It is possible that the client will fail to make timely principal or interest payments, hence, the firm faces **direct credit risk**.
- Bond investors, who lose their investment if the bond issuer fails, face issuer credit risk.
- Firm A and Firm B trade an interest rate swap. If interest rates move in Firm A's favour, Firm B will owe a net obligation. As Firm B could fail to perform on such an obligation, Firm A faces pre-settlement credit risk.
- An investment company has a forward contract to exchange euros for US dollars with a foreign firm. On the contract's maturity date, the investment company makes its euro payment however, because of time differences, there is a delay in the foreign firm making its corresponding dollar payment. Given that it is possible that the firm will fail to make its payment, the corporation faces settlement credit risk.
- An investor seeking returns in foreign sovereign debt faces government issuer risk if the government defaults on the interest or redemption payments.

## 1.2 Measuring Credit Risk

### Learning Objective

- 2.2.1 Know the basic techniques for measuring credit risk: credit exposure management; credit risk premium; credit ratings; modern measurement techniques

Measuring credit risk involves the use of tools or models to estimate the credit exposure of the lender. These range from basic crude techniques, such as simply taking the credit exposure as being equal to the notional values of all transactions and managing this exposure, to more modern approaches that measure more precisely the risks inherent in a portfolio.

This section explains the following basic techniques:

- Credit exposure management.
- Credit risk premium.
- Credit ratings.
- Modern measurement techniques.



## 1.2.1 Credit Exposure Management

**Credit exposure** is the amount that can potentially be lost if a debtor defaults on their obligations. It is used by management quantitatively to assess the severity of credit risk.

Credit exposure consists of current exposure and potential future exposure:

- **Current exposure** is the current obligation outstanding.
- **Potential future exposure** is a calculation of the likely maximum loss in the future. The potential future exposure calculation is usually performed using statistical techniques and forms part of **value at risk (VaR)** calculations (this is explained in more detail in section 3.3).

## 1.2.2 Credit Risk Premium

The **credit risk premium** is the difference between the interest rate a firm pays when it borrows and the interest rate on a default-free security, such as an investment grade government bond. In other words, the additional compensation (the risk premium) is the extra compensation the market or financial institution requires for lending to a firm that presents a risk of defaulting.

As a firm's credit risk increases, lenders demand a higher credit risk premium through an increase in the amount of interest paid. This increase is necessary to offset the increased probability that the loan will not be repaid in accordance with its terms.

There is a strong relationship between credit risk premium and credit rating (see section 1.2.3). The higher a firm's rating, the more creditworthy the firm, the lower the premium. This means that the cost of borrowing will be lower for a higher-rated firm as a reflection of its lower **probability of default**. As a result, a downgrade in a company's credit rating can significantly increase its borrowing costs.

## 1.2.3 Credit Ratings

A broad measure of a firm's credit risk is its external **credit rating**, which is an assessment of its creditworthiness and financial health. It is used by investors in public issues of debt as a guide for managing their credit exposure.

An independent rating agency will assign a credit rating based on analysis of the company's financial status and published statements. This is usually done with a short- and long-term outlook.

Worldwide, there are many different credit rating agencies, although ratings are predominantly provided by three main agencies: Moody's Standard & Poor's (S&P) and **Fitch Ratings** (or simply Fitch for short). The services provided by these agencies enable investors to rely upon impartial and regularly updated research, which takes into account all the various factors that are necessary in respect of credit risk assessment.

Different agencies use different terminologies to assign their ratings. For example, Moody's uses ratings for long-term credit that range from Aaa, representing the highest-quality investments, to a variety of C ratings for firms more likely to default. This is clear from the table below.

The main agencies supplying ratings are Moody's, Standard & Poor's, and Fitch Ratings.

| Moody's   |            | Standard & Poor's |            | Fitch     |            |                                  |                                              |
|-----------|------------|-------------------|------------|-----------|------------|----------------------------------|----------------------------------------------|
| Long term | Short term | Long term         | Short term | Long term | Short term | Description                      |                                              |
| Aaa       | P-1        | AAA               | A-1+       | AAA       | F1+        | Prime                            |                                              |
| Aa1       |            | AA+               |            | AA+       |            | High grade                       |                                              |
| Aa2       |            | AA                |            | AA        |            |                                  |                                              |
| Aa3       |            | AA-               |            | AA-       |            |                                  |                                              |
| A1        |            | A+                | A-1        | A+        | F1         | Upper medium grade               |                                              |
| A2        |            | A                 |            | A         |            |                                  |                                              |
| A3        | P-2        | A-                | A-2        | A-        | F2         | Lower medium grade               |                                              |
| Baa1      |            | BBB+              |            | BBB+      |            |                                  |                                              |
| Baa2      | P-3        | BBB               | A-3        | BBB       | F3         |                                  |                                              |
| Baa3      |            | BBB-              |            | BBB-      |            |                                  |                                              |
| Ba1       | Not prime  | BB+               | B          | BB+       | B          | Non-investment grade speculative |                                              |
| Ba2       |            | BB                |            | BB        |            |                                  |                                              |
| Ba3       |            | BB-               |            | BB-       |            |                                  |                                              |
| B1        |            | B+                |            | B+        |            | Highly speculative               |                                              |
| B2        |            | B                 |            | B         |            |                                  |                                              |
| B3        |            | B-                |            | B-        |            |                                  |                                              |
| Caa1      |            | Not prime         | CCC+       | C         | CCC        | C                                | Substantial risks                            |
| Caa2      |            |                   | CCC-       |           |            |                                  | In default with little prospect for recovery |
| Caa3      |            |                   |            |           |            |                                  |                                              |
| Ca        |            |                   | CC         | /         |            |                                  | D                                            |
| /         |            | D                 |            |           |            |                                  |                                              |
| /         |            |                   |            |           |            |                                  |                                              |
| /         |            |                   |            |           |            |                                  |                                              |

Any instrument up to and including Baa or BBB is deemed to be investment grade; the remainder below this level are referred to as non-investment grade. Investment grade bonds are those that have been judged likely enough to meet their payment obligations. Commonly used abbreviations in the industry are 'IG' for bonds with an investment grade rating, and 'junk' or 'high yield' for non-investment grade.

The credit rating agencies have sometimes been subject to criticisms which could somewhat undermine market confidence in them, including:

- On occasions they have not downgraded companies promptly enough. For example, Enron's rating was still at investment grade four days before the company went bankrupt in 2002, despite the fact that the credit rating agencies had been aware of the company's problems for months.
- Some of the rating agencies have been criticised for having too familiar a relationship with companies' management, possibly opening themselves to undue influence or the vulnerability of being misled. During the financial crisis, several of the ratings agencies assigned high credit ratings on securitised products which, after further due diligence, should not have been the case. This potential conflict of interest is implicit in the relationships when the companies being rated are the ones paying fees to the rating agencies in order to obtain the credit rating.
- Some credit rating agencies have made errors of judgement in rating some structured products, particularly in assigning AAA ratings to structured debt which in a large number of cases was subsequently downgraded or defaulted. As part of the Sarbanes-Oxley Act of 2002, the US Securities and Exchange Commission (SEC) was required to produce a report detailing how credit ratings are used in US regulation and the policy issues this use raises.

See chapter 7 for more details regarding the Sarbanes-Oxley Act of 2002.

## 1.2.4 Modern Measurement Techniques

Modern tools concentrate on measuring the credit risk of a portfolio through the use of mathematical modelling techniques. These use statistical computer programs that attempt to simulate the complexity of the real world in order to measure the probability of default (PD) and calculate the **loss given default (LGD)** from a range of complex potential scenarios. From these calculations, a VaR estimate can be made, which is an estimate of the maximum loss that can occur in a given period of time.

These tools are commercially available to help companies gain an overall view of credit risk across their entire organisation and product spectrum and have become powerful aids in measuring the credit exposure of portfolios. However, although they represent significant advances in aiding credit risk management at the portfolio level, their accuracy generally depends on good quality historical data. If the quality of this data is poor, then confidence in the model's output is degraded. The quality of data is affected by issues such as:

- The simple lack of availability of data, for instance, for emerging markets.
- Significant economic or political changes in a country, making historical data irrelevant or misleading, for example, a change in political ideology or the discovery of large reserves of natural resources.
- Major market events making historical data irrelevant or misleading, for example, the introduction of the euro in 1999, and the coronavirus (COVID-19) pandemic.

Although the science of measuring credit risk using modern measurement techniques and tools is continually developing, there are some common assumptions used by both firms and regulators that can introduce inaccuracies into the risk models and produce inaccurate credit risk calculations.

Some of the main issues are:

- Using simplified calculations of potential future exposure. Generally, the potential future exposure of a portfolio is greater than the current exposure. Institutions may apply charges to account for potential exposure based on broad categories that oversimplify the different levels of risk. These charges are stated as percentages of notional amounts, but notionals are not always true measures of the underlying credit risks.
- Assuming that some exposures have equal credit risk when the reality is that they do not. For instance, owing to the simple rules applied in the Basel Committee on Banking Supervision's (BCBS') original guidelines on capital adequacy, the risks associated with South Korean and German banks were treated as equivalent. The capital adequacy proposal from the BCBS relates a firm's capital more closely to its true risk.
- A lack of recognition of the time period of credit risk. Default risk increases as the time of exposure increases. This is sometimes not accounted for.
- A lack of recognition of portfolio diversification. Overall, credit risk is significantly reduced by diversification, but measurement calculations may not take this into account.

Note that the BCBS is a committee of the Bank for International Settlements (BIS), which was established at the end of 1974 and now has some 60 member central banks. Countries are represented by their central bank and also by the authority with formal responsibility for the prudential supervision of banking business where this is not the central bank. The committee formulates broad supervisory standards and guidelines and recommends statements of best practice in the expectation that individual authorities will take steps to implement them through detailed arrangements – statutory or otherwise – which are best suited to their own national systems.

## 2. Credit Risk Management and Reporting

### 2.1 The Credit Risk Management Function

#### Learning Objective

##### 2.3.1 Understand the role of the credit risk management function

The key objective of the credit risk management function is to maximise an institution's risk-adjusted rate of return by maintaining credit risk exposure within acceptable limits. This is an essential part of the overall long-term success of the organisation. Institutions should identify, measure, monitor and control credit risk to ensure that they hold adequate levels of capital to cover these risks should they occur.

The board of directors has ultimate responsibility for approving and, at least annually, reviewing the credit risk strategy and major credit risk policies of the institution. It is then the responsibility of senior management to implement this credit risk strategy.

This means implementing a sound risk management policy to manage credit risk in a firm-wide context, which includes:

- performing adequate credit analysis by counterparty, country and sector (this includes the performance of regulatory **Know Your Customer (KYC)** checks as well as assessing creditworthiness)
- ensuring decisions on granting credit are made independently of the trading areas
- integrating the credit risk policy with the firm's general business strategy.

Although the information provided by external rating agencies (see section 1.2.3) can be useful, it is of limited value in relation to the needs of a sophisticated credit risk management function. This is because it is often too historic, not detailed enough to meet the firm's requirements fully and not as sensitive to changes as a firm's own analysis. As well as performing this detailed credit analysis, the responsibilities of the credit risk management function will include:

- setting the firm's credit policy and ensuring it is adhered to
- making credit decisions on methods of trading to reduce credit risk (eg, the use of netting)
- setting, monitoring and reviewing **credit limits**
- measuring and monitoring daily credit exposure, which will also involve providing information for the assessment of capital adequacy
- assessing potential credit risk events
- reporting and escalating risk issues to senior management, to make them aware and able to react to such issues, in order to minimise potential loss to the firm.

## 2.2 Credit Risk Mitigation

### Learning Objective

- 2.3.2 Understand the following examples of credit risk mitigation: asset securitisation; central counterparties; clearing houses; collateral and margin; credit derivatives; credit limits; diversification; loan sales; netting; underwriting standards

Mitigating credit risk involves the use of a range of techniques that aim to maintain a firm's credit exposure within acceptable parameters. These techniques operate at both individual level and portfolio level.

### 2.2.1 Individual Level

Techniques at the individual level aim to mitigate the credit risk of specific borrowers. These might involve simple decision-making based upon information derived from **risk measurement** (for instance, a decision to charge a higher credit risk premium to a firm with a low credit rating).

The common credit risk mitigation techniques employed by financial institutions are:

- centralised clearing
- underwriting standards
- credit limits
- **collateral** and margin, and
- netting.

### Centralised Clearing

The use of a centralised clearing system such as using a **central counterparty (CCP)** is a means practised on several exchanges and other structures globally to reduce credit risk. The clearing house acts as an intermediary between buyer and seller facilitating the completion of transactions between the two; if one clearing member defaults, the clearing house will guarantee the performance of the contract to the other.

CCPs however, become the counterparty to the trade through a process called novation and assume the counterparty risk, ie, they become the buyer to each seller, and the seller to each buyer, thus limiting the exposure of the transacting parties by protecting them from the potential impact of the default of others.

### Underwriting Standards

**Underwriting standards** are the standards that financial institutions apply to borrowers in order to evaluate their creditworthiness and, therefore, mitigate the risk of default.

Evaluation requires specific knowledge of the borrower's business and includes:

- a review of the borrower's cash flow and financial statements
- the consideration of earnings, profit margin and outstanding debt
- analysis of industry variables such as competitive pressures, product cycles and future growth potential, and
- controlling the terms of the loan, eg, limiting loan size, establishing a repayment schedule and requiring additional collateral for higher-risk loans.

### Credit Limits

Credit limits are maximum limits for all aspects of credit exposure, including lending, set by financial institutions to prevent too much exposure by a particular firm (counterparty).

All financial institutions will set limits of some description for all borrowers as a means of reducing credit risk.

### Collateral and Margin

Collateral is an asset held by a lender on behalf of an obligor, under certain agreed conditions, as security for a loan or other transaction, such as foreign exchange forwards, securities lending and derivatives. It generally takes the form of cash or securities and is used by the lender as insurance against default.



In the event that the obligor defaults, the lender may seize the collateral. Collateralisation is, therefore, used as a means of reducing credit exposure to a counterparty.

A collateral arrangement can be unilateral, bilateral or netted:

- A **unilateral arrangement** means that one party gives collateral to the other.
- A **bilateral arrangement** allows for two-sided obligations, such as a swap or foreign exchange forward. In this situation, both parties may post collateral for the value of their total obligation to the other.
- A netted arrangement means that the net obligation may be collateralised so that, at any point in time, the party who is the net obligor posts collateral for just the value of the net obligation.

In a typical arrangement, collateral is provided upfront by the buyer to the seller (known as **initial margin**), the collateral is periodically 'marked-to-market' (ie, its present value is calculated using current market prices/rates) and the amount adjusted to reflect changes in value. The obligor has to supply additional collateral when the market value has risen, or remove collateral when it has fallen.

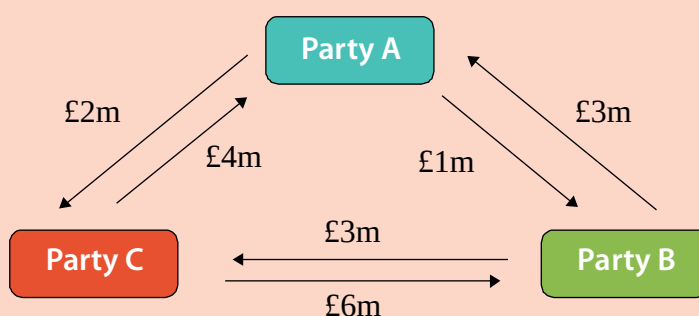
**Margin** can be described as the difference between the cost of the trade and the current marked-to-market price of the trade. An example of this is the use of **variation margin** in exchange-traded derivatives markets, when collateral (or margin) calls (demands) are made by the exchange, clearing house or clearing broker on a daily basis to reflect changes in the market value of the trades.

Collateral is mentioned again in chapter 5 of this workbook.

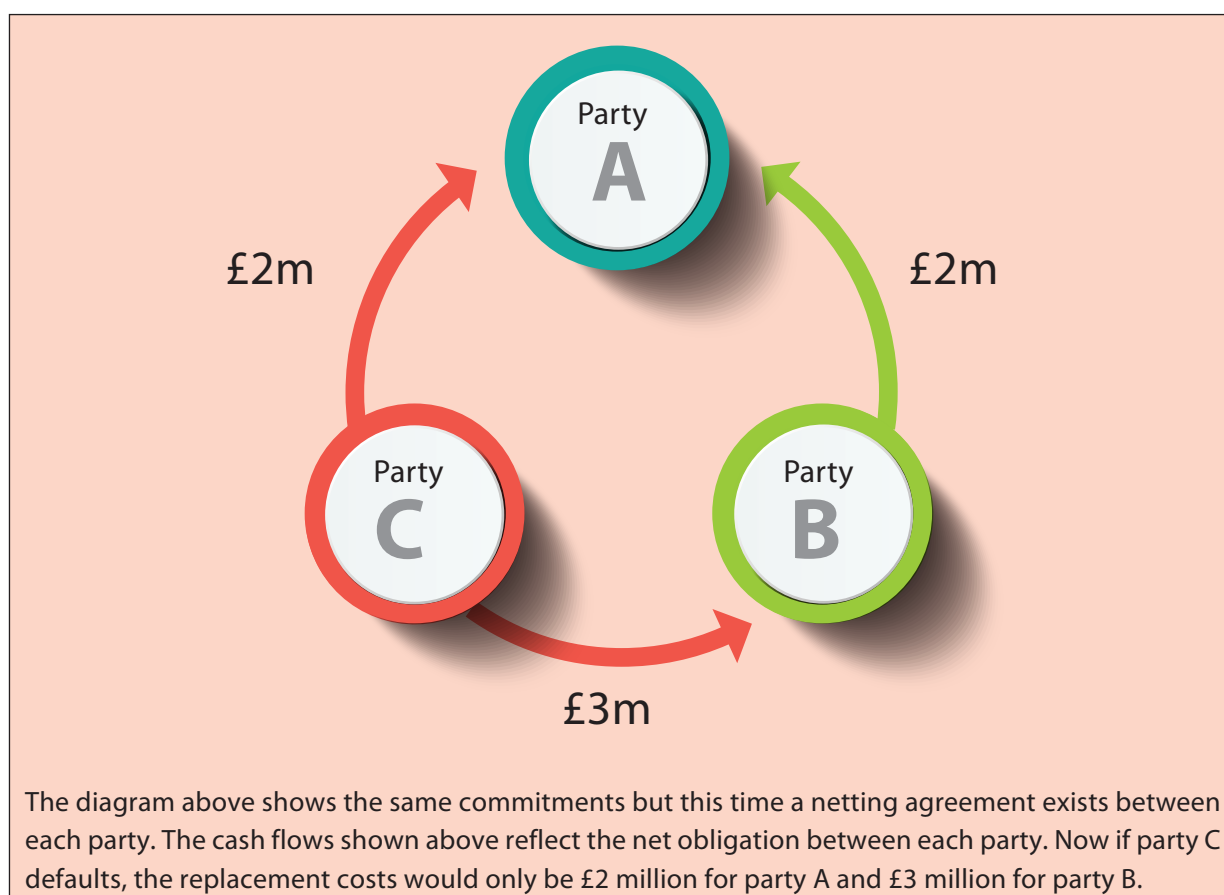
### Cash/Payment Netting

**Cash netting** (also known as payment netting) is the practice whereby two parties that exchange multiple cash flows during a given day agree bilaterally to net those cash flows to one payment per currency, thereby reducing settlement risk. It also reduces transaction costs and communication expenses. Figure 2.1 shows an example of cash netting.

**Figure 2.1 – An Example of Cash Netting**



The diagram above shows the end-of-day commitments between parties A, B and C. No netting agreement is in place. If, for instance, party C defaulted on wits commitments, the replacement costs would be £4 million for party A and £6 million for party B.



### 2.2.2 Portfolio Level

A **portfolio** is a collection of investments owned by the same individual or organisation. An efficient or optimal portfolio either:

- provides the greatest expected return for a given level of risk, or
- provides the lowest risk for a given expected return.

Portfolio management is concerned with optimising the market and credit risk inherent in the portfolio components in order to maximise returns.

Some of the most common techniques for mitigating credit risk within a portfolio are:

- diversification
- asset securitisation
- loan sales, and
- the use of credit derivatives.

## Diversification

**Diversification** is a means of offsetting risk in a portfolio by spreading investment across borrowers in different, negatively correlated, industry sectors (ie, industry sectors that have an inverse or opposite relationship to each other, so that when the investment return reduces, the other will increase).

The aim of diversification is that the earnings of some loans in a portfolio will offset the losses of others, making it less likely that the institution will lose money overall. By this principle of combining individual loans into a portfolio, it is possible to reduce overall credit risk. By doing this, institutions avoid unacceptable concentrations of credit risk. Diversification can also be done geographically; for example, an EU-based bank will most likely seek to lend in several countries.

### Example

An investor is seeking to invest in a British sun cream retail outlet. However, they are concerned about the seasonal nature of the business and the unpredictability of the weather.

In order to reduce the dependence on one company, they decide to diversify their portfolio and achieve this by investing in a shop specialising in umbrellas. The sun cream shop does well on sunny days, while the umbrella shop does well on rainy days.

Although the earnings of each individual business can be volatile, the combined earnings will be less so because of the inverse relationship, or **negative correlation**, between their earnings.

## Asset Securitisation

**Asset securitisation** is the practice of pooling bonds or loans with credit risk and selling them as a package to outside investors. This is attractive for the seller because it removes their credit exposure. It is also attractive for investors because the diversification they can achieve across many loans reduces their overall credit risk.

## Loan Sales

**Loan sales** is the practice of a firm making a loan to a company and then selling the loan to other institutions or investors. This strategy is attractive to firms because they earn a fee from the original loan but the new investor assumes the credit risk. This can be very important if large amounts are involved for such purposes as financing takeovers.

## Credit Derivatives

A **credit derivative** is a type of specialised OTC product that allows credit risk to be managed by the transfer of credit exposure between parties.

Institutions can use credit derivatives to increase or decrease their credit exposure to a particular counterparty, for a particular period of time. They are attractive because they allow financial institutions to:

- mitigate their credit risk more effectively and improve their portfolio diversification by reducing undesirable credit risk concentrations
- customise their credit exposure to another party without having a direct relationship with them, and
- transfer credit risk without adversely affecting the customer relationship.

Since their introduction in the 1990s, these instruments have been an important innovation in the mitigation of credit risk. However, they can also expose the user to other types of financial risks and regulatory costs.

Like other OTC products, they are privately negotiated financial contracts. These contracts expose the user to operational risk, counterparty risk, liquidity risk and **legal risk**. Controlling these risks is an essential factor in the operation and development of this market.

Popular examples of credit derivatives include:

- credit default swaps (CDS)
- total return swaps
- credit spread swap options (options on CDS), and
- credit-linked notes.

The way in which just one of these, a CDS, works is explained below.

### Credit Default Swaps (CDS)

A **credit default swap (CDS)** is a bilateral financial contract in which one counterparty (the protection buyer) pays a periodic or one-off fee (typically expressed in basis points on the notional amount) in return for a contingent payment by the other counterparty (the protection seller) following a **credit event** of a reference entity. A credit event is commonly defined as:

*'bankruptcy, insolvency, receivership, material adverse restructuring of debt or failure to meet payment obligations when due'.*

#### Example

Bank A holds an asset in the form of a loan made to a corporate client. Bank A is concerned that the corporate client might default on its obligations to service and/or repay the debt, so Bank A enters into a CDS with another bank, Bank B.

In return for a regular payment based on a percentage of the face value of the loans, Bank B agrees to pay out in the event of the corporate client defaulting.

Bank A is using the CDS to hedge. By buying a CDS, Bank A can manage its credit exposure and maintain its relationship with the client. Any payout from Bank B will be triggered by pre-specified credit events and will typically be based on the fall in the value of the loan as a result of the event, for example, the actual default or a credit rating downgrade by an external **credit rating agency**.

## 3. Market Risk

### 3.1 Introduction

#### Learning Objectives

- 2.4.1 Know the basic features of market risk: price level risk; volatility risk; liquidity risk; basis risk
- 2.4.2 Be able to apply the basic features of market risk to simple, practical situations

One of the major aims of many financial institutions is to make a profit by investing in the global financial markets. This business, by its nature, is based on **price uncertainty** – the uncertainty of knowing whether market prices will move in a favourable or adverse direction. Price uncertainty is the mechanism that allows profit or losses to be made, and the risk of loss associated is known as market risk. This risk reflects the uncertainty of an asset's future price.

The factors affecting market risk are complex. For instance, when investing in a company's shares, there are direct (specific) and indirect (systemic) market risk factors to consider:

- **Direct market risk factors** are those that directly reflect the performance of a company, such as the health of its balance sheet, its vision, the energy and strength of its management team and its policy.
- **Indirect market risk factors** are those that indirectly affect the performance of a company, such as interest rate levels, economic events, and political and environmental effects.

The financial services sector takes advantage of the existence of market risk to make profit. The aim of managing this is not to eradicate, but to understand and quantify the risk. If this is done accurately, an informed decision can be made on how acceptable the risk is compared to the firm's strategic risk appetite and whether this investment is worthwhile. The crucial aspect, as with all forms of risk management, is the confidence in the accuracy of the estimate of the size of risk. As there are vast profits to be made in getting this right, financial institutions have invested heavily in research, tools and expertise to try to predict the future performance of their investments.

The need to understand this market risk is also important in the pricing of some financial products, such as futures and options. For these reasons, the methods and tools employed for measuring market risk have become very advanced, involving cutting-edge mathematical theory and computer-processing technology. This section provides a basic understanding of these methods and tools and explains how they fit into an overall risk management strategy.

#### 3.1.1 Definition

Market risk can be defined as the risk of loss of earnings or capital arising from changes in the value of financial instruments. In simple terms, an investor is exposed to market risk as soon as they purchase a financial product; the risk is materialised if the value of the product goes down.

Market risk is intrinsic in all markets and all products, such as:

- money market products
- equities
- bonds
- commodities and energy products
- interest rate and exchange rate products
- futures and options, and
- other derivatives.

Due to the inherent differences between these markets and products, different types of market risk will relate to each product.

### 3.1.2 Types of Market Risk

Market risk can be subdivided into the following types:

- **Price level risk** – this is due to the potential for adverse changes in the price of a financial instrument and includes:
  - **Foreign exchange (FX) rate, exchange rate or currency risk** – this exists due to adverse movements in exchange rates. It affects any portfolio with cash flows denominated in a currency other than the base currency of the business.
  - **Interest rate risk** – this exists due to adverse movements in interest rates and will affect fixed-income securities and any forward-looking derivative.
  - **Credit risk** – increase in market-wide credit risk typically occurs during market shocks and corresponding periods of ‘flight to quality’. The debt of all private issuers can fall by varying degrees when investors flock to the safety of government bonds (which are perceived as ‘risk free’) or extremely safe short-term instruments (often given the general term of ‘cash’).
  - **Equity price risk** – this exists due to adverse movements in share prices affecting a portfolio.
  - **Commodity price risk** – this is the risk of an adverse price movement in the value of a commodity.
- **Volatility risk** – this is the risk of price movements that are more uncertain than usual affecting the pricing of products. All priced instruments suffer from this form of **volatility**. This particularly affects options pricing, because if the market is volatile then the pricing of an option is more difficult and options will become more expensive.
- **Liquidity risk** – this is the risk of loss through not being able to trade in a market or obtain a price on a desired product when required. This can occur in a market owing to either a lack of supply or demand or a shortage of market makers. Note that liquidity risk can also refer to the funding liquidity of a specific firm, meaning the risk that it may not be able to meet its obligations when they are due. Loss in this case can be incurred due to the cost of borrowing or facing contractual penalties and may ultimately result in insolvency. For this second type of liquidity risk, see section 5.
- **Basis risk** – this occurs when one kind of risk exposure is offset with another exposure in an instrument that behaves in a similar, but not identical, manner (ie, hedged). It reflects the uncertainty of the difference in the impact of the market factors on the prices of the two instruments. An example of basis risk is the risk when the price of a futures contract varies from the price of the underlying cash instrument as the expiry date approaches.



## 3.2 Measuring Market Risk: Distribution Analysis

### Learning Objective

- 2.5.1 Understand the measures of central tendency and dispersion: mean; median; mode; standard deviation; distribution analysis

Measurement of market risk involves advanced statistical and probability theory and analysis techniques. However, most conventional methods rely on basic principles, such as distribution analysis.

**Distribution analysis** is a statistical means of using historical data to predict future events and relies on an understanding of **probability distributions**. These are mathematical functions that describe the probability of possible outcomes. They are depicted as graphs with the 'probability of occurrence' on the vertical axis and the 'possible outcome' on the horizontal axis. Many types of distribution are used for analysis but for the purposes of this workbook, only an understanding of the most common form is needed, which is called a 'normal distribution' or **bell curve**, as shown in Figure 2.2.

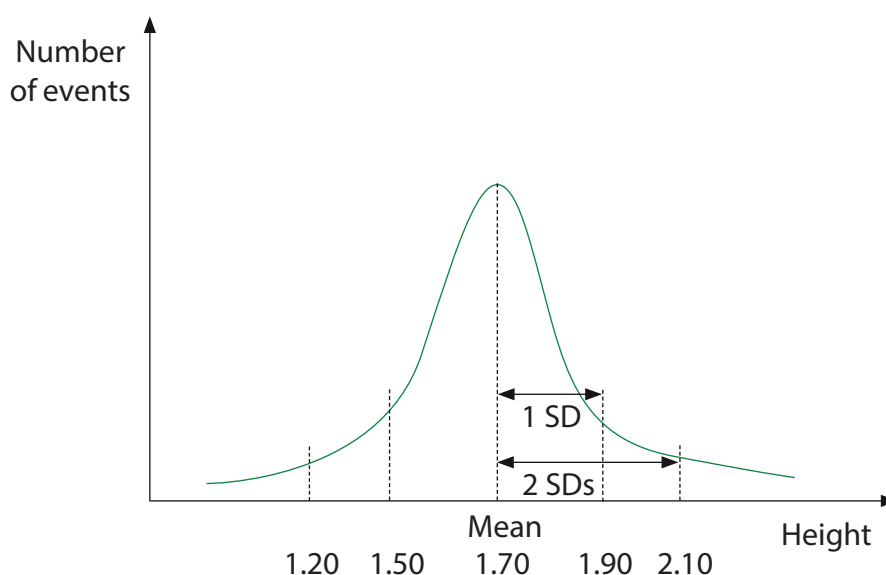
A **normal distribution curve** has the following attributes:

- It is continuous. This means that each point on the curve has a real value.
- It is symmetrical about its mean (a measure of central value).

It is defined by its mean and its standard deviation (a measure of dispersion):

The mean is a measure of the average value of a set of data, calculated by dividing the sum of all the values (eg, heights of people) by the total population (eg, total number of people). Other measures of central value are the median and the mode. The median is the value such that exactly half of a population is of a greater quantity. If the population has an odd number of entries, the median is the middle entry after sorting in increasing order. If the list has an even number of entries, the median is equal to the sum of the two middle numbers after sorting, divided by two. The mode is the value that has the greatest frequency of occurrence. For example, from the following list of numbers: 1, 1, 2, 3, 3, 3, 4, 5, 5, 6 the mean is 3.3, the median is 3 and the mode is 3.

Figure 2.2 – Example of a Normal Distribution Curve



The curve shows how people's height varies in a particular population. The mean, or average, height is shown to be 1.7 metres, so most people in the population will fall in a band around this value. A few people are very tall and a few very short. Using this curve, we can make a prediction of how tall the next person to be measured will be, or what percentage of people are above or below a certain height. Many other natural events, such as people's intelligence (IQ), or a country's temperature, can be described by this type of distribution.

The **standard deviation (SD)** is a means of measuring variability, uncertainty or volatility. It measures the dispersion from the average or mean value. If, for instance, an equity is highly volatile, it will have a high SD. In finance, investment returns from primary instruments (but not derivatives), based on market factors, are often assumed to be normally distributed. By making this assumption, it is possible to create a model that will predict the future performance of the instrument to a given probability. This probability is also known as the **confidence level**. For example, if the mean historical price of an instrument were £1, we would be 50% confident that tomorrow's price would be more than £1. By using a knowledge of SD, we could also calculate what the price would be that would ensure we had a 95% confidence level that tomorrow's price would be higher. This means if we bought an equity, say, at that price, we would be 95% certain that we would not lose money. This sort of calculation is useful as a basis for establishing the risk appetite of the firm and limiting loss.

## 3.3 Measuring Market Risk: Value at Risk (VaR)

### Learning Objective

- 2.6.1 Understand the meaning of VaR and its constituents
  - 2.6.2 Understand the meaning of back testing
  - 2.6.3 Understand the meaning of stress testing
  - 2.6.4 Know the limitations of using VaR for market risk management
- 

### 3.3.1 Definition of Value at Risk (VaR)

The most significant development in the measurement of market risk has been the invention of the value at risk (VaR) measure. This is a statistical measure that uses distribution analysis and **sensitivity analysis** to determine how much value of a portfolio may be lost given certain market conditions.

VaR can be formally defined as the maximum loss that can occur with a specified confidence over a specified period. For example, if a portfolio's one-week VaR is stated as £1 million in 99 weeks out of 100, then the portfolio is predicted to lose less than £1 million over 99 weeks out of 100. This estimate would be based upon the portfolio's current composition and recent market conditions, so it would not account for potential future changes.

VaR is a category of risk metrics that describes, in terms of probability, the market risk of a trading portfolio. VaR is widely used by banks, securities firms, commodity and energy traders and other trading organisations.

Such firms might track their portfolios' market risk by using historical volatility as a risk metric. They might do so by calculating the historical volatility of their portfolios' market value over a rolling look-back period of a given number of trading days. The problem with doing this is that it would provide a retrospective indication of risk. The historical volatility would illustrate how risky the portfolio had been over the previous period; it would say nothing about how much market risk the portfolio was presenting today.

For institutions to manage risk, they must know about risks while they are being taken. If a trader fails to hedge a portfolio correctly, their supervisor and firm need to find out before a loss is incurred. VaR gives institutions the ability to do this. Unlike retrospective risk metrics, such as historical volatility, VaR is prospective. It quantifies market risk while it is being taken. VaR attempts to measure market risk in an integrated manner, theoretically taking into account all sources of market risk in a portfolio. It can, however, be difficult to calculate in practice.

For institutions to manage risk, they must know about risks while they are being taken. If a trader fails to hedge a portfolio correctly, their supervisor and firm need to find out before a loss is incurred. VaR gives institutions the ability to do this. Unlike retrospective risk metrics, such as historical volatility, VaR is prospective. It quantifies market risk while it is being taken. VaR attempts to measure market risk in an integrated manner, theoretically taking into account all sources of market risk in a portfolio. It can, however, be difficult to calculate in practice.

### 3.3.2 Methods of Calculating VaR

VaR can be calculated in the following ways:

- **Historical simulation** – this is the simplest method and uses actual historic returns in the risk factors to estimate risk exposure in the future. Its advantage is that it is the least controversial, because it is based on actual data.
- **Correlation simulation** – this is also known as the **variance/covariance simulation**. It calculates the volatility of each risk factor from historical data and estimates their effect on the portfolio to give an overall estimate of risk that accounts for all risk factors.

### 3.3.3 Benefits and Limitations of VaR

VaR is recognised as one of the most effective concepts in risk management. However, it must be closely integrated with the day-to-day market risk management process. Its advantages and limitations are as follows:

| Benefits                                                                                                                                                                                                                                                                                                                                                    | Limitations                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                          |
|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <ul style="list-style-type: none"> <li>• VaR provides a statistical probability of potential loss.</li> <li>• It can assess the correlation between different assets.</li> <li>• It translates all risks in a portfolio into a common standard (that of potential loss), thus allowing the quantification of firm-wide, cross-product exposures.</li> </ul> | <ul style="list-style-type: none"> <li>• VaR does not account for liquidity risk.</li> <li>• It is dependent on accurate historical data. For this reason, it is most useful for financial instruments that have easily available records of market values such as derivative instruments, bonds, and currency instruments. For areas such as loans and deposits, it is less useful due to the long-term maturities involved.</li> <li>• If market conditions or the risk environment change dramatically (eg, during a crisis period), VaR may provide poor predictions.</li> </ul> |

### 3.3.4 Expected Shortfall

Expected shortfall is another measure of risk that is used in finance, particularly in relation to financial risk measurement, which can be used to replace or supplement VaR. This can be used to measure the level of market risk or credit risk associated with a portfolio of investments. Expected shortfall is also known as the conditional value at risk (CVaR), average VaR, mean excess loss and the expected tail loss.

Models need to be refined to take into account market events (eg, negative or rising interest rates). Many of the models that were set up during the pre-crisis levels were designed in an environment of high and positive interest rates. When global interest rates fell, many institutions began charging negative interest on cash balances in currencies such as the euro, Norwegian krone, Swedish krona and the Swiss franc, and as a result, the yield curves for these currencies, which are used as an input into various models provided incorrect trade valuations because the models were not programmed to accept negative interest rates.

The powerful mathematical models described have been developed as a means of predicting, or anticipating, future events. This is not a perfect process and the models can break down if the assumptions they are based upon are violated or if the data used by the model is incorrect. The risk of this happening is called model risk. An important aspect in the application of these models is to understand the assumptions and test their accuracy as far as possible. This is achieved by performing back testing and stress testing.

## Back Testing

**Back testing** is the practice of comparing the actual daily trading exposure to the predicted VaR figure. It is a test of reliability of the VaR methodology and ensures that the approach is of sufficient quality. It is usually performed on a daily basis by the financial reporting function and, if unsatisfactory differences between reality and estimation are found, the VaR model must be revised.

## Stress Testing

**Stress testing** means testing the model against 'extreme' market event scenarios. It can be thought of as emphasising particular risks that may, or may not, have been captured by the VaR calculation. Stress tests are not designed to generate worst-case results.

Stress testing is normally performed by the financial reporting function, and the results can also be fed back into the VaR model to improve it. There is no standard way of stress testing, but the BIS does carry out surveys of common practice in the marketplace. There is a wide range of stress test practices at banks and securities firms.

The use of stress tests continues to broaden from the exploration of exceptional but plausible events – the traditional focus of stress testing – to cover a much wider range of applications. These include the exploration of the risk profile of a firm, the allocation of economic capital, the verification of existing limits, and the evaluation of **business risks**. The expanded usage of stress testing derives from its wider acceptance within firms. Aside from its inherent flexibility, it benefits from explicitly linking potential impacts to specific events.

Nonetheless, stress tests continue to focus primarily on traded market portfolios. These portfolios are well suited to stress testing as they can be marked-to-market on a regular basis. Stress tests on loan books are conducted less frequently and, quite often, by separate business units of the firm. Stress testing often involves creating a wide range in the particular risks considered and evaluating how the portfolios would have performed in those extreme scenarios.

Stress testing and back testing work as a complement, rather than a supplement, to major risk management tools such as VaR. It is, therefore, becoming an integral part of the risk management framework of banks and securities firms.

## 4. Market Risk Management and Reporting

There are a number of techniques for managing market risk that operate both on the portfolio (micro) and organisational (macro) levels. To be successful, an integrated approach to market risk must be followed and an overall risk framework and structure set up. This section describes some of the more common mitigation techniques and introduces some good practice requirements for an effective framework.

### 4.1 Market Risk Mitigation

#### Learning Objective

- 2.7.1 Understand the following techniques for mitigating market risk: hedging; market risk limits; diversification

The following mitigation techniques will be explained:

- Hedging.
- Diversification.
- Risk limits.

#### 4.1.1 Hedging

**Hedging** is a means of reducing risk and it is usually used to reduce the impact of adverse price movements by taking an offsetting position in a related product. It is a means of insuring against market risk in the same way that a car is insured against damage and loss.

There are different types of hedging which are used to address specific risks, including interest rate risks and currency risks. The main financial instruments used in hedging are derivatives, in particular, futures, options and swaps.

For instance, an investor may buy an equity and is at risk of losing money if the market declines. This could be hedged by buying a 'put option'. This option gives the buyer the right to sell the stock at a set price (the strike price) within a particular time in the future, providing the investor with a degree of protection against adverse market movements.

The decision to hedge is a trade-off between the risk of adverse movement and the cost of the hedge – in the example above, this would be the purchase price of the option. It is, however, difficult to achieve perfect offsetting of the risk because the use of hedging introduces, or exacerbates, other risks such as basis risk, credit risk and operational risk.

### 4.1.2 Diversification

Diversifying a portfolio is a technique for mitigating market risk that uses the same principles as for credit risk mitigation described in section 2.2.

### 4.1.3 Risk Limits

Market risk limits are used as a tool for managing market risk in the same way that credit limits are applied to protect firms from credit risk (see section 2.2.1).

The existence of market risk limits does not, however, assume the existence of credit limits. These will be established separately, and vice versa.

When an organisation takes a risk, it will often specify the maximum loss that it is prepared to make on a portfolio or transaction. This is called the **market risk limit** or **stop-loss limit**, and may be expressed in terms of VaR.

The effectiveness of risk limits to manage market risk is dependent upon the accuracy of the risk measurement used to set the limits.

The potential problems of using oversimplified risk measurements are:

- risk limits usually have to be inflated in order to accommodate the errors and uncertainty in the measurement. This adversely affects the potential profit of the firm, and
- traders or other investment professionals may exploit the inaccuracy of risk measurement and take risks that they know the measurement does not account for.

Providing that high-quality risk data is used, risk limits can be very effective. While investment professionals sometimes see them as restrictive, they can also be viewed as empowering because they set the risk appetite of the firm and represent explicit authority to take specified levels of risk.

## 4.2 The Market Risk Management Framework

### Learning Objective

#### 2.7.2 Understand the role of the market risk management framework

---

As already explained, market risk relates to the loss of earnings or capital arising from changes in the value of financial instruments.

In the same way that institutions employ a credit risk management function to manage credit risk, it is also essential that they develop and implement an independent market risk management framework to manage market risk and then to ensure that there is adequate reporting. This also includes implementing a firm-wide policy with clear roles and responsibilities.



A good practice framework for market risk will include:

- a clearly defined market risk management policy
- proactive management involvement in market risk issues
- defined escalation procedures to deal with rising levels of trading loss, which include market risk limits
- VaR as a common measure of market risk exposure and for it to be adequately reported
- an independent daily monitoring and reporting function of risk utilisation through the daily production of profit and loss (P&L) accounts and review of front-office closing prices ('independent' means a separately accountable function reporting directly to senior management)
- independent validation of market pricing and adequacy of VaR models
- analysing a range of different scenarios for large or extreme market movements in order to see what effect they have; the results can be fed back into the VaR model, and
- considering implementing position limits to reduce market risk.

## 5. Liquidity Risk

### 5.1 The Nature of Liquidity Risk

#### Learning Objectives

- 2.8.1 Know the basic terms used in the subject of liquidity risk: asset and liability management; maturity ladders; actual and contractual cash receipts; asset liquidity risk; funding liquidity risk; fund liquidity risk; liquidity coverage ratio; net stable funding ratio
- 2.8.2 Be able to apply the concept of liquidity risk to simple, practical situations

Liquidity risk is an area of risk management that concerns itself predominantly with two main variables – cash and time. Funding liquidity risk is the risk that an institution will not be able to meet its liabilities as they become due, ie, there is a shortfall of available cash to meet the liquidity within a given time.

On the subject of liquidity risk, some of the basic terms used are as follows:

- **Asset and liability management** aims to reduce liquidity risk by trying to match the timings of cash flows against the liabilities of the firm, ensuring that the amount of cash to be received is greater than the liabilities due.
- **Maturity ladders** are one way of helping to improve liquidity for an organisation. This method involves investing in a range of securities that have varying maturity dates. This ensures regular cash flows in terms of both income and capital maturing.
- **Actual and contractual cash receipts** can affect the timing of cash flows and need to be taken into consideration when matching projected cash flows against future liabilities. Some cash receipts from investments will be contractual (ie, a predetermined, fixed amount of income will be received on a set date) while others may be actual (ie, will be linked to the performance level of a suitable index). Firms will need to balance the types of cash being received in order to meet future liabilities as they fall due.

- Asset liquidity risk is the risk of loss caused by an inability to sell an asset that cannot be sold at or near the current market value when required due to lack of liquidity in the market. Asset liquidity risk is essentially a subset of market risk.
- **Funding liquidity risk** is demonstrated when liabilities cannot be met when they fall due, or can only be met at an uneconomic price. They can be firm-specific or systemic.
- **Fund liquidity risk** is the risk that there may not be sufficient cash available within a fund to pay out redeemed units in time to meet demand. This risk can be exacerbated in funds that do not deal on a daily basis as the fund may need to pay compensation to clients if the market has experienced adverse movement between fund pricing points. When the manager of a fund is not able to satisfy redemption requests, they may be forced to temporarily freeze outflows, known as 'gating'. This may help preserve the remaining value of assets in the fund but has serious reputational consequences for the manager.

### Example

In September 2007, Northern Rock suffered from the crystallisation of liquidity risk due to the sub-prime crisis. The bank was over-exposed to the sub-prime mortgage sector and suffered from short-term liquidity issues despite being solvent at the time.

The UK Government gave huge amounts of financial assistance to provide sufficient levels of liquidity to Northern Rock. The bank in this case was unable to meet its various liabilities with the assets that it had available.

In response, the regulator now places greater supervisory focus on liquidity risk especially with regard to high-impact retail firms.

Basel III introduced two standardised liquidity measures, the **liquidity coverage ratio (LCR)** and the **net stable funding ratio**, as a way to help banks and other interested parties assess liquidity risks on a common basis across banking institutions.

The LCR relates to highly liquid assets held by financial institutions to meet short-term obligations. The ratio is a generic stress test that aims to anticipate market-wide shocks. The LCR is designed to ensure financial institutions have the necessary assets on hand to ride out short-term liquidity disruptions. The net stable funding ratio is defined as the amount of available stable funding relative to the amount of required stable funding.

## 5.2 Measuring Asset Liquidity Risk

### 5.2.1 Key Measures of Asset Liquidity Risk

#### Learning Objective

- 2.9.1 Know the key measures of asset liquidity risk: bid-offer spread; market depth; immediacy; resilience

#### Bid-Offer Spread

The bid-offer (or bid-ask) **spread** is used by market participants as an asset liquidity measure. The 'bid price' is the price at which the institution will buy an asset and the 'offer price' is the price at which the institution will sell an asset.

To compare different products, the ratio of the spread to the product's mid-price can be used. The smaller the ratio, the more liquid the asset. This spread comprises operational, administrative and processing costs, as well as the compensation required for the possibility of trading with a more informed trader.

#### Market Depth

This relates to the liquidity of the market and is the amount of an asset that can be bought and sold at various bid-ask spreads. An institution needs to consider the effect of executing a large order on the market and to adjust the bid-ask spread accordingly. The institution will need to calculate the liquidity cost as the difference between the execution price and the initial execution price.

#### Immediacy

Immediacy is used as a measure of market liquidity by evaluating the time needed to trade a certain quantity of an asset successfully at a prescribed cost. This measure would be expected to be higher in illiquid assets.

#### Resilience

Resilience is a measure of the time taken for asset prices to return to previous levels after a large transaction. Resilience essentially evaluates an asset's ability to recover after a surge in supply or demand. The levels of resilience would be expected to be higher for a liquid asset than for an illiquid asset, allowing it to be used as a proxy of market liquidity.

The resilience of an asset requires the use of historic market data and can only be determined over a period of time.

## 6. Liquidity Risk Management and Reporting

Financial firms can meet their liquidity needs through several sources, ranging from existing assets to debt obligations and equity. The most readily available is operating cash flows arising from interest and principal payments from existing assets, service fees, and the receipt of funds from various transactions. For example, active management of the timing and maturity of firms' asset and liability cash flows can enhance liquidity.

In addition, firms may sell assets that are near-term cash equivalents, such as government securities. This is typically done on a contingency basis to meet unexpected cash needs, and such liquidity reserves must be actively managed, since the assets must be unencumbered (that is, not pledged as collateral for any other transaction) and easy to liquidate under potentially adverse market conditions.

### 6.1 The Liquidity Risk Management and Reporting Function

#### Learning Objective

2.10.1 Understand the role of the liquidity risk management function from the perspective of the firm

---

Managing liquidity is a fundamental component in the safe and sound management of all financial institutions. The liquidity risk management function will carry out and monitor all aspects of the liquidity profile of the institution to ensure that an appropriate level of liquidity is maintained, assets and liabilities are being prudently managed and that expected cash inflows have an appropriate relationship to cash outflows.

Banks and larger financial institutions are evaluated on their levels of liquidity which are reported as part of their statutory duty to meet cash obligations without having to sell large amounts of assets and potentially incur losses. These liquidity measures are used as risk indicators for those investing in, or contracting with, these institutions.

## End of Chapter Questions

Think of an answer to each question and refer to the appropriate section for confirmation.

1. **What is the definition of credit risk?**

*Answer Reference: Section 1.1.1*

2. **What is the difference between pre-settlement and settlement risk?**

*Answer Reference: Section 1.1.2*

3. **What is the definition of potential future exposure?**

*Answer Reference: Section 1.2.1*

4. **What is the difference between credit exposure and credit risk premium?**

*Answer Reference: Sections 1.2.1 and 1.2.2*

5. **What does LGD stand for?**

*Answer Reference: Section 1.2.4*

6. **List four techniques used for mitigating individual credit risk.**

*Answer Reference: Section 2.2.1*

7. **The following end-of-day commitments exist between four counterparties:**

A owes B £2m

B owes C £7m

C owes D £3m

D owes A £1m

B owes D £2m

A owes D £4m

D owes C £2m

C owes B £4m

B owes A £5m

D owes B £2m

What is the credit risk exposure for B:

Without netting?

With netting?

*Answer Reference: Section 2.2.1*

8. **What are the three types of collateral arrangement?**

*Answer Reference: Section 2.2.1*

9. **What are four of the most common techniques for managing credit risk within a portfolio?**

*Answer Reference: Section 2.2.2*

10. **What three reasons make credit derivatives attractive as a means of managing credit risk?**

*Answer Reference: Section 2.2.2*

11. **What is the definition of market risk?**

*Answer Reference: Section 3.1.1*

**12. What are the four main types of market risk?**

*Answer Reference: Section 3.1.2*

**13. What are the attributes of a normal distribution (bell) curve?**

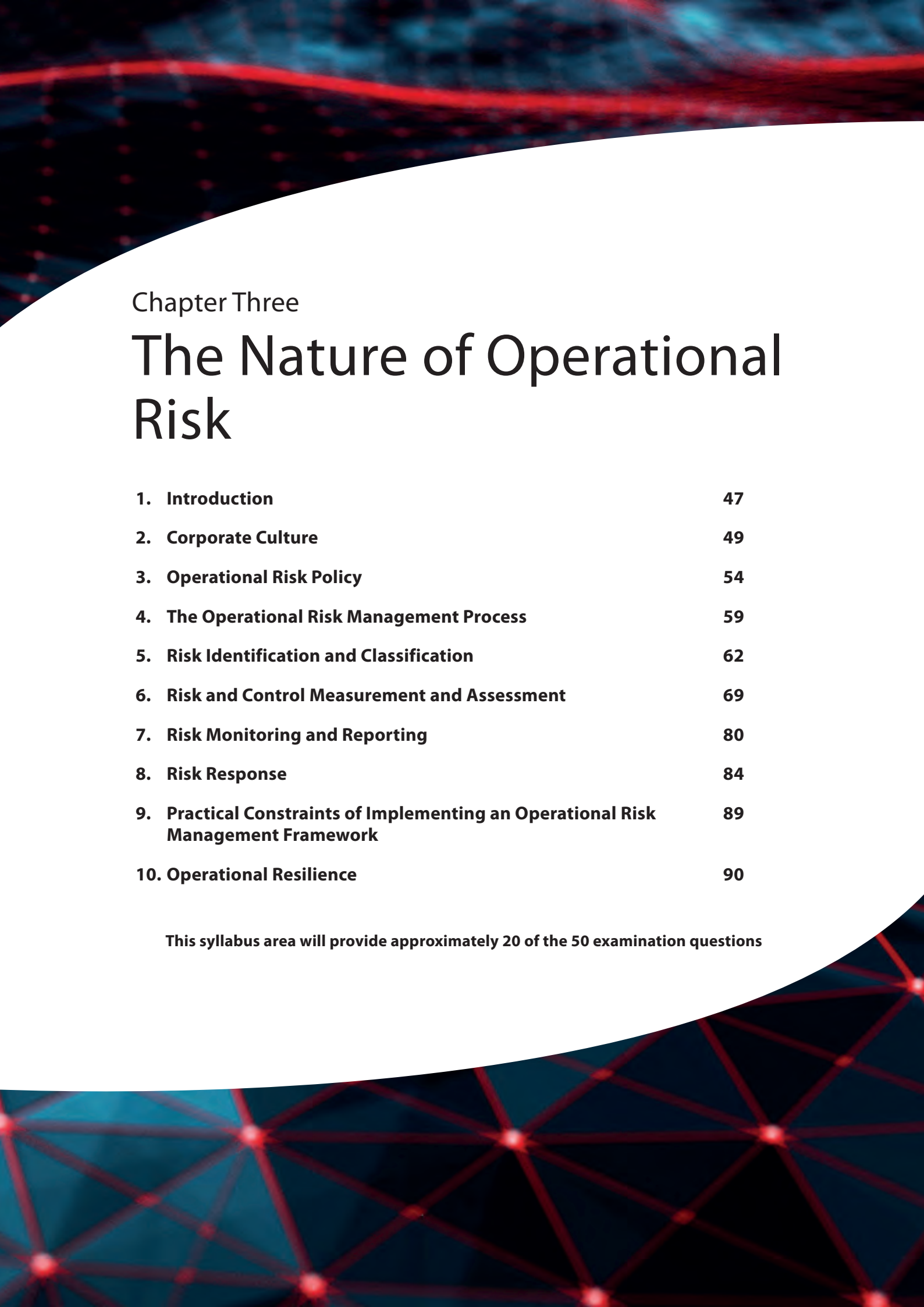
*Answer Reference: Section 3.2*

**14. What is the definition of value at risk (VaR)?**

*Answer Reference: Section 3.3.1*

**15. Name four ways in which asset liquidity risk can be measured.**

*Answer Reference: Section 5.2.1*



## Chapter Three

# The Nature of Operational Risk

|                                                                                          |           |
|------------------------------------------------------------------------------------------|-----------|
| <b>1. Introduction</b>                                                                   | <b>47</b> |
| <b>2. Corporate Culture</b>                                                              | <b>49</b> |
| <b>3. Operational Risk Policy</b>                                                        | <b>54</b> |
| <b>4. The Operational Risk Management Process</b>                                        | <b>59</b> |
| <b>5. Risk Identification and Classification</b>                                         | <b>62</b> |
| <b>6. Risk and Control Measurement and Assessment</b>                                    | <b>69</b> |
| <b>7. Risk Monitoring and Reporting</b>                                                  | <b>80</b> |
| <b>8. Risk Response</b>                                                                  | <b>84</b> |
| <b>9. Practical Constraints of Implementing an Operational Risk Management Framework</b> | <b>89</b> |
| <b>10. Operational Resilience</b>                                                        | <b>90</b> |

**This syllabus area will provide approximately 20 of the 50 examination questions**





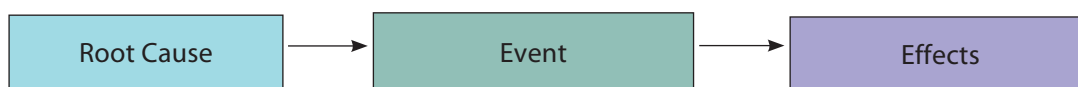


## 1. Introduction

Over the last decade or so, the full impact of the effects of operational risk failures has begun to be appreciated in the financial services sector which, in turn, has heightened awareness of the importance of appropriate operational risk management. This is mainly due to the increase in major loss events that have seriously affected corporate profitability and reputation (see chapter 1, section 2.4). As a result, the effective management of these risks has become a major priority for senior management, regulators and customers. This change in thinking in the industry has led to the need for a rigorous and structured approach to understanding, identifying, assessing, measuring, mitigating and monitoring operational risk.

This chapter first looks at how the concept of operational risk has been developed and driven by international regulators. It then introduces cultural and leadership issues to highlight the importance of developing a favourable environment for risk management. Next, it provides a generic, practical framework for managing operational risk. Additionally, this chapter introduces the 'chain of events', which describes the root causes of risk that are realised through the crystallisation of risk events that ultimately result in financial loss to the firm. This chain of events is shown in Figure 3.1.

**Figure 3.1 – The Chain of Events of Operational Risk**



## 1.1 The Nature of Operational Risk

### Learning Objective

#### 3.1.1 Know the basic Bank for International Settlements' definition of operational risk

The Bank for International Settlements (BIS) defines operational risk as:

*'The risk of loss resulting from inadequate or failed internal processes, people and systems or from external events'.*

In practical terms, it is the risk of loss that a business faces in the course of conducting its daily activities, procedures and systems.

The BIS is referred to further in chapter 2, section 1.2.4 and chapter 7, section 3.

## 1.2 Operational Risk is Present Across the Organisation

### Learning Objective

#### 3.1.2 Understand that operational risk is present across the organisation in all departments and activities

As can be seen from the definition of operational risk in section 1.1, the departments and activities of the firm that could potentially be affected by operational risk are spread across the firm as a whole. It is, therefore, important that there is a firm-wide approach to tackling the operational risks that have been identified or those that may occur in the future. Section 3.8 of this chapter explores the need for consistency of the firm-wide approach in more detail. Chapter 5 of this workbook looks at the front office, support functions and control functions of a firm in more detail in the context of helping the firm manage its operational risks. Staff across the firm (including the board of directors, senior management and all other staff) should be aware of the various operational risks (and other types of risk) that will affect their roles.

## 2. Corporate Culture

### 2.1 What is Corporate Culture?

Culture is to a firm what personality is to an individual. An organisation's culture is its identity. It is the collective norms and values of its employees.

Culture can be loosely defined as 'the way we do things around here'. While it reflects the collective beliefs and traditions of the workforce, it is strongly influenced by a firm's leadership. This is because people naturally take their lead from their superiors. For instance, if senior managers are seen to have an appetite for taking risks, then they will most likely attract individuals who like to take risks so that the culture will also be one of risk-taking.

### 2.2 Relevance to Operational Risk

In the context of operational risk, culture means that the firm's employees possess a common understanding and awareness of what risk is, where it occurs and how it can be managed. A certain amount of risk in different forms may be tolerated by the firm as part of its day-to-day operational activities. The employees will also understand the nature or extent of risk which the firm will and will not tolerate. This awareness must form part of the firm's beliefs and values.

Developing and maintaining the right culture and attitude towards risk is a hugely influential factor in the risk management process and in the effectiveness of risk management policies and actions. Without an appropriate culture, a firm can never be fully confident that it is managing its risk properly.

If risk consciousness is not part of the culture, then the culture needs to be changed. This can be difficult because it reflects the people that make it up. People tend not to be entirely rational in their thought processes and actions, as the less tangible effects of emotion, habits, principles, ethos and ego all play a part in their decision-making. As a result, there can be a resistance to change. Operational risk due to cultural issues has a large intangible element to it. The cause-and-effect relationship is often not obvious, which makes managing it more of a perceptual issue than a logical one.

Some of the main issues that impact the risk culture are:

- quality and integrity of staff
- extent of change the organisation is going through
- effectiveness of the control environment
- levels of resourcing
- reward practices, and
- tone from the top (ie, senior management).

## 2.3 Leadership

### Learning Objective

#### 3.2.1 Understand the importance of effective leadership and the role of senior management in sustaining a robust risk and control culture

---

One of the key roles of senior management is to position a firm's culture so that it best supports the business objectives. This can also be seen as adapting the strategy and objectives of the organisation to best fit the prevailing culture. Either view requires senior managers to be effective leaders and to understand how leadership can affect a firm's operational risk and prevailing culture.

Leadership is viewed as one of the most significant drivers of culture. How organisational leaders behave and interact with employees is critical in the fostering of a favourable risk culture. Effective leaders will deliberately alter their style depending on the situation, this requires both a sensitivity to the requirements of the business (and its culture) and an understanding of their own leadership abilities.

If the risk environment is relatively stable and predictable, and there is a well-established, risk-aware culture, then one style of leadership is appropriate. However, if there is a high pace of change, and an immature risk environment, another style may be appropriate. Leaders, therefore, need to be aware of their organisation's position and what strategies they must adopt to create the most effective environment.

### 2.3.1 The Role of the Board of Directors and Senior Management

Financial regulators state that the board of directors will be accountable for the effectiveness of the risk management processes. Their responsibilities regarding operational risk management will be to:

- be aware of major operational risks
- approve and review the operational risk framework
- ensure the operational risk framework is audited by independent, trained and competent staff, and
- ensure a segregation of duties between internal audit and operational risk management.

Senior management responsibility will include:

- implementing the operational risk framework
- developing effective policies, processes and procedures
- ensuring consistency across the organisation, and
- ensuring all staff understand their responsibilities.

## 2.4 Creating a Robust Risk and Control Culture

### Learning Objectives

- 3.2.2 Know the main factors determining a firm's risk and control culture: strategy/objectives; clear roles and responsibilities; risk appetite; selection, training and development; values and behaviours; communication; incentivisation and remuneration
- 3.2.3 Know the organisational areas where positive behaviours are necessary to ensure a continuing robust risk and control culture
- 3.2.4 Understand the contribution of the risk officers in maintaining a robust risk and control culture
- 3.2.5 Understand the UK regulators' expectations of risk control and culture

Good risk processes and planning are worth nothing without the commitment and energy of a motivated, effective workforce. Equally, weaknesses in risk processes and systems can be offset by vigilant, expert staff. Thus, the need for a robust culture in the effective management of operational risk cannot be overstated. As has been explained, creating, instilling and communicating this culture is largely the role of senior management, the board of directors and the leadership of a firm.

Creating a robust risk and control culture starts with the firm having a clearly defined business strategy and objectives. Its strategy is its method or plan chosen, given the often limited resources available, to achieve its desired objectives and is typically viewed as its long-term planning.

A firm's risk officers play a significant part in continuing a robust risk and control culture. This is achieved through a combination of engagement with the business, providing risk training and promoting awareness of risk and continuous monitoring and reporting of key risk events. A firm's risk officers will act as an independent challenge to the business and will provide assurance to senior managers that risks are being managed within the firm's risk appetite. A robust risk culture will depend on the ability of the organisation to develop positive attributes in the areas discussed in sections 2.4.1 to 2.4.9.

### 2.4.1 Personal Responsibility

A high degree of personal responsibility and empowerment gives individuals the freedom to take appropriate risks within the controlled and accepted risk appetite of the firm. Encouraging risk-taking by the right people, at the right time, is essential to a firm's success. The key is to know when and how much risk should be taken.

As part of the UK regulators' reform programme, the Senior Managers & Certification Regime (SM&CR) introduced individual accountability for the conduct and activities of the parts of the firm that they are responsible for. It also included the introduction of formal statements of responsibility which provide clear, documented areas of responsibility for named senior managers within the firm. This increased focus on individual responsibility on both activities and outcomes is designed to promote better outcomes across the financial sector and for consumers. SM&CR is covered in further detail in chapter 7.

## 2.4.2 Motivation

Motivation is a psychological phenomenon that relates to the amount of effort, care and commitment that people put into a task. People's levels of motivation are recognised as being a key factor in improving their performance.

Examples of factors that motivate people are the interest, challenge and rewards of their job. Incentive schemes and remuneration initiatives help to keep staff motivated. Motivation also depends on limiting the negative effect of 'hygiene factors' such as poor pay, working conditions or management style.

If jobs and careers can be designed to unlock an individual's motivation, a more positive risk culture will result, and organisational performance will be enhanced.

However, remuneration and poor reward practices can incentivise staff to take inappropriate risks in an attempt to earn more, for example, where a fund manager's remuneration is entirely linked to the performance of a fund they may enter into riskier transactions outside of the firm's policy (or not permitted within the Fund Prospectus) when the fund is underperforming to bring the performance back on track.

## 2.4.3 Morale

Excellent morale is related to how positively staff view their organisation, working conditions, outlook and leaders. It is linked closely to motivation and commitment. Positive morale among staff can be important in encouraging other areas, such as taking personal responsibility.

## 2.4.4 Integrity

Firms need staff with high integrity that have pride in their performance, are professional in their approach and demonstrate high levels of honesty. A lack of integrity (perceived or otherwise) can cause significant damage to a firm's reputation. The quality of integrity is instilled into the culture through the words and actions of its leaders and senior managers, however this does not diminish the importance of careful recruitment and selection practices to ensure that firms only hire employees whose values are aligned with those of the firm.

## 2.4.5 Appropriate Environment

The FCA expects organisations to have effective arrangements, processes and mechanisms to manage the risk relating to the firm's activities, processes and systems. An appropriate environment for managing operational risk encourages staff to challenge the status quo and question why things are done. This includes healthy levels of positive conflict and competition and means the absence of a blame culture, so that people do not feel intimidated or persecuted if they make mistakes or challenge accepted norms or report problems and losses.

There should be adequate levels of transparency within the firm for the staff to understand the objectives and relevant working practices of the firm as a whole and how risk management can support the achievement of its goals.



The culture of the firm will also be affected by the degree of training and development opportunities the staff are offered. Having a skilled and dedicated workforce will only add further to the success of the firm and provide a wide range of benefits to it and its staff.

The firm's senior management are held accountable by the regulator to ensure that they have organised and controlled the affairs of the firm responsibly and effectively, and developed and maintained adequate risk management systems. The attitudes and behaviour of the board of directors and senior management will have a huge impact on the firm's risk and control culture. Management should be seen to lead by example and set the right tone because the firm's approach to these key areas will influence the rest of the firm and its staff to follow suit.

## 2.4.6 Continuous Improvement

Continuous improvement is a frame of mind where people constantly look for ways of doing things better, challenge the status quo and take personal responsibility for being more effective and efficient. It also involves the continuous measurement of performance against targets. A wholehearted commitment to continuous improvement supports the process of good risk management where measurement is key.

## 2.4.7 Collective Awareness

A collective 'conscience' about risk is the idea of a risk-aware organisation where staff are comfortable with the language and ideas behind risk management, and risk management practices are embedded throughout the business, supported by ongoing training and appropriate reward and recognition policies.

## 2.4.8 Managing Change

An ability to absorb and adapt to change at all levels of the organisation is essential. Managing change is one of the most difficult aspects of maintaining a controlled environment. Introducing new processes, procedures and technology to cope with changing business conditions creates uncertainty, which can have a major adverse impact on organisational culture and the control environment. For example, these changing business conditions could develop as a result of a merger between two companies.

## 2.4.9 Expertise

The technical ability and experience of staff is a major factor in perceiving and anticipating risks. Ongoing training and development is a key component in ensuring that the business maintains the right level of expertise which, in turn, provides confidence that business is being conducted to high standards.

### 3. Operational Risk Policy

#### Learning Objective

- 3.4.1 Understand the following areas required by an operational risk policy: board-level sponsorship; identification of key officers; cross-divisional involvement and agreement; clearly defined roles and responsibilities; definition and communication of the risk management framework; segregation of duties; consistency of approach firm-wide; coordination; documentation of acceptable risk levels; definition and communication of the control standards framework

The **operational risk policy** is the document that outlines a firm's strategy, methodology and objectives for operational risk management including defining the levels of risk it is prepared to accept (risk appetite). It is also where the boundary between operational risk and other risk areas, such as market and credit risk, is clarified.

In order to meet the prime objectives of operational risk management, the risk policy should address the following areas:

- sponsorship
- identification of key officers
- cross-divisional involvement and agreement
- roles and responsibilities
- definition and communication of the risk management framework and explicitly the firm's risk methodology
- consistency of the firm-wide approach
- coordination and escalation
- segregation of duties, and
- risk appetite.

#### 3.1 Sponsorship

The firm's policy and approach should be agreed and sponsored at board level. As it is firm-wide and often requires significant cultural change, it must have the full and continued support of senior management if it is to succeed.

#### 3.2 Identifying Key Officers

It is important for firms to identify and empower those individuals who are given the key responsibilities of managing the operational risk function. Key risk officers are the people in the organisation who manage operational risk. Line managers within the independent operational risk management function will be key officers, responsible for monitoring and reporting to the board, senior business managers, audit committee, the group risk management function (responsible for the firm's overall financial risk) and, via senior management, to regulators.

Key risk officers may also be designated from within the business itself. If ownership of operational risk issues is assigned to the department or business process where they originate, the relevant line manager will often be made responsible for risk management. For this reason, managers may have direct reporting lines through their own business lines and dotted lines into the risk management function.

### 3.3 Cross-Divisional Involvement and Agreement

The policy should promote collaboration between functions, departments and divisions, as it is becoming increasingly recognised that many of the key operational risks occur at the interface between these boundaries.

The cultural tendency of departmentalisation should be addressed and cross-functional teamwork encouraged through incentives, education and a supportive organisational structure.

Collaboration with other risk management disciplines is becoming ever more important as understanding of the interrelationship of financial risk increases.

### 3.4 Roles and Responsibilities

The policy should provide clear responsibility and accountability for risk management at all levels. Staff throughout the organisation need to know precisely what is expected of them and why. If they are accountable for managing risk, then they also require the necessary control and authority to be able to take action and implement risk reduction plans.

The risk policy should include clear lines of authority, identify key risk officers to carry out prescribed actions, and define specific roles and responsibilities. The risk policy should also make clear the consequences of non-compliance for staff not observing the policy.

### 3.5 Defining and Communicating the Risk Management Framework

The risk management framework itself is the responsibility of the board of directors to agree and define. It is then the responsibility of senior management to implement, monitor and report on the risk management policy and how successfully the firm is adhering to the policy.

Regular reviews of the policy are needed to ensure that the success criteria remain valid and relevant. The policy must be communicated to all relevant staff and they should be made aware of the implications of not following the firm's risk management policy.

### 3.6 Segregation of Duties

In order to control and manage specific risks associated with certain procedures (such as the risk of errors, internal fraud or collusion) effectively, the firm will need to ensure effective segregation of duties between the trading and support functions, such as front office, operations, accounting and risk monitoring.

### 3.7 Consistency of a Firm-Wide Approach

A coherent, consistent and comprehensive approach should be defined that will provide a 'road map' to move the organisation from what might be a fragmented, non-strategic attitude towards operational risk management to a more comprehensive, global and firm-wide methodology, with the use of a common risk language throughout the firm.

The approach lays out the framework or rules of engagement under which the firm will operate. This must be in unison with, and support, the overall business strategy. This means:

- employing a methodology that identifies and categorises all the operational risks that exist in the organisation
- employing a methodology for measuring and assessing the significance of all the identified risks
- working with line managers to agree the mitigating action required to reduce the risk exposure to acceptable levels
- monitoring the effects of the mitigating action to ensure its success, and
- reporting and escalating risk issues to all appropriate levels of the organisation. This ensures that there is transparency and aids the decision-making process.

This process is covered in greater depth in section 4.

In practice, the framework described is rarely fixed and standardised immediately. It is more evolutionary to begin with, and its maturity will reflect the maturity of the organisation with respect to operational risk management.

The process of developing the approach is, therefore, cyclical and continuous, and can result in refinements to the risk policy.

Some common factors to consider in developing the approach are:

- the need for centralised control
- regional differences
- divisional differences and autonomy, and
- the level of ownership of risk within the business.

The strategy should be consistent throughout the firm. A common operational policy and terminology, existing globally and across all functions, allows:

- a meaningful overall capital adequacy assessment to be performed across the organisation
- objectivity when risk prioritisation needs to be performed, and
- a sense of fairness when rewarding or penalising risk performance.

### 3.8 Coordination and Escalation

Again, because the risk policy takes a firm-wide approach and cuts across departmental boundaries, there should be a central, independent risk management role responsible for the coordination and implementation of risk policies and procedures. Depending on the size and type of organisation, this role may be set up as an independent department.

Most large organisations have now developed an independent operational risk management function that reports to an overall group risk officer. This is described in further detail in section 4.

### 3.9 Control Standards Framework

The firm needs to properly define and then communicate an effective control standards framework under which it will operate, and then monitor it on an ongoing basis.

### 3.10 Principles of the 'Three Lines of Defence Approach'

#### Learning Objective

##### 3.4.2 Understand the three lines of defence model

Increasingly, firms are using the 'three lines of defence model' to implement risk management across the organisation as an important method of demonstrating and structuring roles, responsibilities and accountabilities for decision-making and risk and control. This helps the firm achieve effective and suitable levels of governance, risk management and assurance. The operational risk policy adopted by the firm will include details of how the firm has utilised the model operationally in order to provide a robust risk framework within the firm as a whole.

#### First Line of Defence: Business Operations – Risk and Control within the Business

The first line sits within the business itself and details the controls a firm has in place to deal with the day-to-day business activities of the firm. Controls are integrated into the firm's systems and processes. Assuming that the design of these systems and processes is sufficient to reduce risk to an acceptable level, compliance with the process should ensure an adequate risk control environment. There should be an appropriate level of supervision in place to ensure compliance and to highlight any breakdowns in control, any inadequacies of process and other eventualities. The first line of defence provides management of the firm with verification and provides feedback to the audit committee by identifying risks and business improvements, implementing controls, and reporting on progress.

#### Second Line of Defence: Risk Management and Compliance Functions

The second line of defence comprises the risk professionals and compliance groups, which help the risk management process in facilitating and monitoring the implementation of effective risk management systems and controls within the firm. These functions also support management in reporting risk-related information and providing an overview of key business risks.

The second line of defence is enforced by the advisory and monitoring functions of risk management and compliance. There are many functions in companies that are linked to risk management and compliance roles including:

- enterprise risk management (ERM)
- quality functions, and
- environmental risk factors such as changes in the legal or regulatory landscape.

### Third Line of Defence: Internal Audit and Other Independent Assurance Providers

The third line of defence is the independent verification provided by the firm's audit committee and the internal audit function that reports to that committee.

The internal audit function undertakes a programme of risk-based audits covering all aspects of both the firm's first and second lines of defence. The internal audit function may well take some assurance from the work of the second-line functions and amend its checking of the first line.

The level of assurance taken will depend on the effectiveness of the second line and the internal audit function will need to coordinate its involvement with compliance and risk management at the firm. The feedback from the audits will need to be reported to all three lines, ie, accountable line management, the executive and oversight committees and the board audit committee of the firm.

There is a reasonable assumption that the internal audit function will identify any weaknesses in both the first and second lines of defence which may otherwise have led to significant loss at the firm. All three lines of defence have specific roles in the internal risk control governance model, and they are:

- the model of management control in the first line of defence
- the oversight challenge in the second line of defence, and
- the independent verification in the third line of defence.

## 3.11 Setting Risk Appetite

### Learning Objective

- 3.6.1 Understand the following: the meaning of the term risk appetite; the meaning of the term risk capacity; the importance of documenting a firm's risk appetite; the content and target audience for a risk appetite statement

Risk appetite (also referred to as a risk tolerance) is defined as the level of risk the organisation is comfortable to accept in the course of its business activities. A risk appetite defines the level of acceptable risk based on the balance between the potential benefits of the risk and the threats that risk may bring to the organisation.

The firm needs to establish and document acceptable risk levels for all relevant aspects of its business. This has to be sponsored at the highest level within the organisation to provide a consistent and validated benchmark for all risks across the business. This allows individual risks to be identified, monitored, reported and escalated effectively and consistently to ensure the firm does not face unnecessary levels of risk.

Setting a benchmark level of risk appetite by way of a risk appetite statement provides a foundation for objectively defining when risks can be accepted, thus allowing the firm to focus its resources on managing and monitoring key risks as well as defining a consistent level of acceptable risk that the business is prepared to undertake to achieve its strategic objectives. This facilitates the early escalation of risks that are outside of tolerance and supports a business case for prioritisation of resources or further investment to address these risks.

Risk appetite can be expressed in any number of ways including an absolute value or limit (eg, £1 million per risk event) or a relative limit (eg, 3% of revenue, or 1% of clients in default). While the risk appetite statement will vary from one organisation to another, it would usually be sponsored at board level and would be made available within the business to communicate the limits and provide transparency around the risk management process. A risk appetite statement should include the:

- date of issue
- document approvals and revisions
- definition of risk and risk ratings to ensure consistency across the business
- risk appetite value or limit
- escalation procedures for any risk identified exceeding the risk appetite
- frequency of review or date of next review, and
- distribution.

Risk appetite is closely linked to the concept of risk capacity. Risk capacity is defined as the amount of risk an organisation can afford to take in the course of its business activities. This is, essentially, the organisation's ability to absorb a loss of a certain size over a period of time. For example, a firm may express a risk appetite of losses not exceeding £1 million within a financial year, however, its risk capacity may be at £5 million as its capital resources would allow it to absorb this loss without affecting the ongoing viability of the business.

## 4. The Operational Risk Management Process

### Learning Objectives

- 3.3.1 Know the following terms in relation to operational risk management: inherent (gross) risk; residual (net) risk
- 3.3.2 Understand the role of operational risk management
- 3.3.3 Understand the key aims of operational risk management: identification and assessment of risks; management of operational risk exposure within appetite
- 3.3.4 Know the stages of the operational risk management process: policy; setting operational risk appetite and/or tolerance; identification/classification; risk and control measurement and assessment; risk response; monitoring; reporting and escalation; planning and change

As described in chapter 1, the role of operational risk management is to ensure that the likelihood of risks being realised, and the potential impacts, are reduced to acceptable levels, namely within risk appetite, allowing the organisation to continue to operate in a controlled and risk aware manner that supports the long-term goals of the business as a going concern. For many firms, risk management is more than simply a matter of compliance with the current regulatory regime, and there are several benefits to good operational risk management that any organisation can enjoy including:

- reduction of operational errors and associated loss
- prevention or early detection of unlawful activities
- reduced exposure to future risks, and
- decreased cost of audit and compliance.



This means exploiting the business opportunities that risk-taking provides (or the upside of risk) whenever possible, while at the same time managing the potential loss (or the downside).

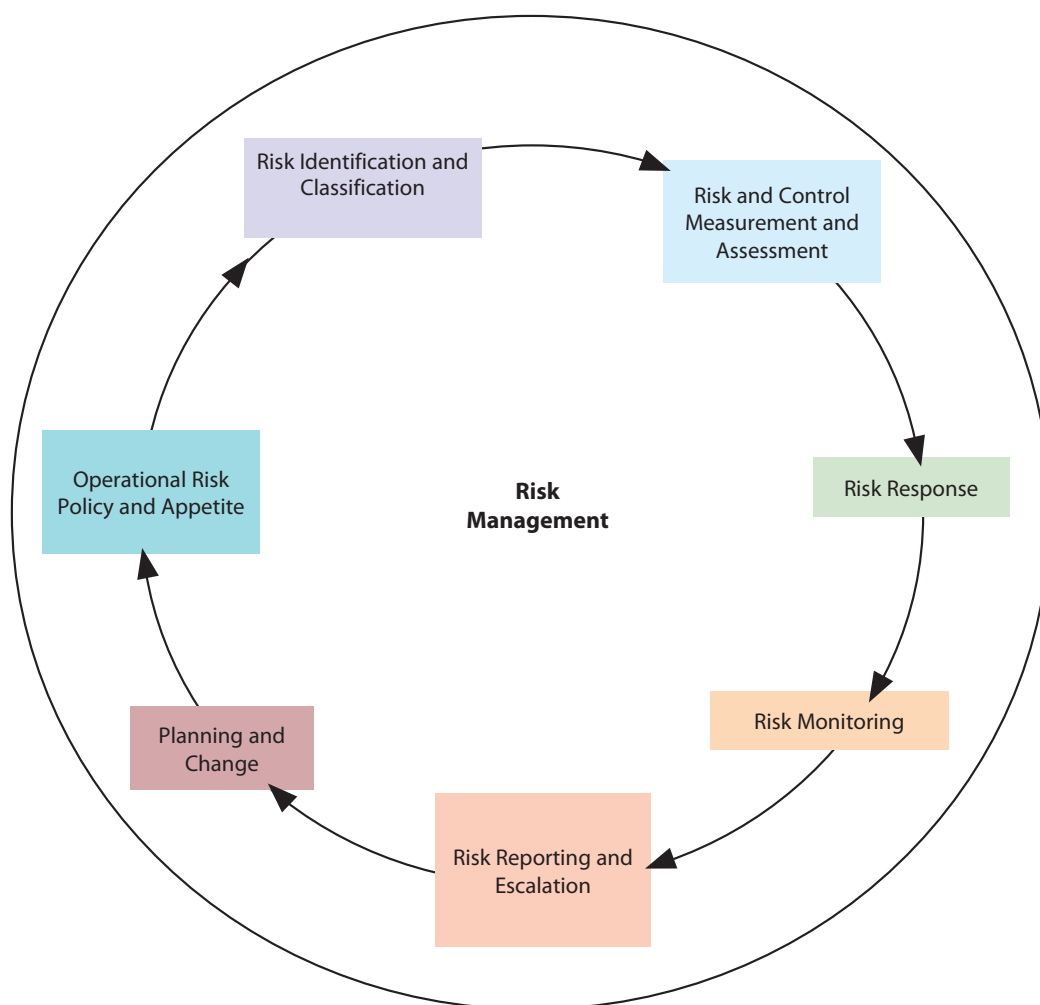
The main focus within the financial services sector is managing the downside, or the potential loss, due to operational risk. Practically, operational risk management has three key aims:

1. the effective identification, measurement, assessment and management of operational risk
2. the reduction or mitigation of the potential impact to acceptable levels (ie, within risk appetite), and
3. to adopt consistent, structured approach to risk management embedded across the firm.

Once the operational risk policy has been agreed, a risk management process must be implemented to enable the organisation to achieve its aims. It is the role of the operational risk management function to embed, oversee and support the risk management processes across the firm to ensure that risks are being appropriately identified and assessed to assign risk owners throughout the business and to monitor ongoing risks to ensure that they remain within the risk appetite of the firm. The level of risk that the firm will wish to be exposed to, and the risk appetite of the firm, will have been agreed by the board of directors and senior management.

Figure 3.2 illustrates the typical operational risk management process.

**Figure 3.2 – The Risk Management Process**



The key stages of the operational risk management process and how they interrelate is explained in further detail in this chapter:

- Setting operational risk appetite and/or tolerance (section 4)
- Identification/classification (section 5)
- Risk and control measurement and assessment (section 6)
- Risk response (section 8)
- Monitoring (section 7.1)
- Reporting and escalation (section 7.2)
- Planning and change.

The operational risk management process should be integrated throughout the business to allow it to be effective in supporting the business in achieving its strategic aims. This approach promotes engagement across business lines as well as utilising the expertise and specialist knowledge of subject matter experts throughout the organisation.

Timely risk information should be provided to key stakeholders to facilitate the effective prioritisation and allocation of resources across the firm, including the updating of operational risk policies and risk appetite documents for the approval of the board.

## 4.1 Risk Register

A risk register, sometimes referred to as a 'risk log' or 'risk management matrix', is a risk management tool commonly used in organisational risk assessments. It acts as a central record of all risks identified by the organisation and is designed to capture every stage of the risk management cycle as well as providing a clear line of sight between risks, their rating and the resulting actions taken by the risk manager. A risk register typically contains:

- risk reference (used internally to help identify this risk in the future)
- date identified
- description of the risk
- risk owner
- risk cause
- key controls
- risk effect/harm
- risk scores (inherent and residual)
- risk response/proposed action (immediate)
- remedial actions (follow-up) and deadlines, and
- methods of monitoring the risk.

One of the key benefits of a risk register is that it allows risk managers to aggregate risk data across various group entities to facilitate risk reporting of consolidated risk profiles at group level, or to drill down to various teams to identify process level risks at the lowest level of detail contained within the risk register. This consistency of approach also provides an objective way of recording risk assessments and comparing the appropriateness of risk response across different parts of the business to ensure that risks are being treated consistently across business lines.

Risks can be recorded in a simple spreadsheet or in sophisticated enterprise risk software, depending on the level of complexity of the business, its risk management approach and its appetite for investment in risk management tools.

## 4.2 Inherent and Residual Risk

The concept of inherent (gross) versus residual (net) risk is simple yet fundamental to risk management.

- **Inherent risk** is the risk associated with an activity or an event before the risk response, ie, the level of risk before any controls have been put into place.
- **Residual risk** is the amount of risk remaining once the controls have been implemented. It is impossible to remove risk from a process or business line completely without ceasing the activity, and reducing residual risk to a level within the risk appetite is one of the ways the risk management function supports the business in achieving its strategic objectives.

The difference between inherent and residual risk levels can be viewed as a measure of the effectiveness of the controls that have been put in place.

## 5. Risk Identification and Classification

### 5.1 Why Identify Risks?

#### Learning Objective

##### 3.5.1 Understand the purpose of identifying risks

For a firm, the purpose of identifying operational risks is to understand, record and categorise these risks. By doing this, the firm can create a basis for establishing its risk profile and gain an understanding of the types of risk it faces and its level of exposure. There is a need to do this in order to:

- provide information to management on which decisions to make and to take action to ensure a controlled environment
- establish the chain of events relationship of operational risk (as described in section 1 of this chapter) and understand where they occur throughout the firm
- provide a basis for risk measurement and assessment which may, for example, be used for capital allocation purposes
- set boundaries to differentiate between operational risk and other risk types (such as market and credit risk) and assign ownership for their mitigation, and
- develop a common language for discussing, assessing and managing risk that allows clear and transparent communication and decision-making.

When identifying risks, a firm needs to consider not only its own processes and systems, but also its relationships with its clients, the nature of its products and the wider business environment.

Risk identification is the fundamental first step in understanding how operational risk affects the firm, raising awareness of risk issues and assessing the culture of the organisation. It can be a difficult exercise due to the diverse nature of risk causes and the difficulty in distinguishing cause from effect.

## 5.2 Basel – Operational Risk Categories

### Learning Objectives

3.5.2 Know the Basel operational risk event types

3.5.3 Be able to apply risk classification in accordance with Basel II categories

The Basel Accords are a series of three international banking regulation agreements that were developed over several years, beginning in the 1980s. Set by the Basel Committee on Banking Supervision (BCBS), the Accords establish capital requirements and risk measurements for global banks, with the aim of enhancing financial stability worldwide.

The second of these Accords (Basel II) was first published in 2004 and has since undergone several revisions. For the first time, Basel II incorporated a detailed categorisation of operational risk, credit risk and market risk and, in particular, provided a breakdown of the seven specific risk event types that give rise to operational risk exposure.

These event types are:

1. **Internal fraud** – examples include employee theft, bribery or insider trading on an employee's own account.
2. **External fraud** – examples include robbery, forgery and theft via computer hacking and cyber attacks.
3. **Employment practices and workplace safety** – examples include violation of employee health and safety rules and discrimination claims.
4. **Clients, products and business practices** – examples include misuse of confidential information and [money laundering](#).
5. **Damage to physical assets** – examples include loss or damage to physical assets from natural disasters or man-made events such as terrorism, war, arson or vandalism.
6. **Business disruption and systems failures** – examples include hardware, software and telecommunications outages, utility failure and problems with real estate facilities.
7. **Execution, delivery and process management** – examples include unapproved access to client accounts and outsourcing vendor disruptions or failures.

Please note that these risk event types are banking-focused and, as such, other types of financial institutions may find it difficult solely to use this list to provide them with meaningful risk analysis and may, therefore, choose to supplement the following event types.

## BASEL II – Loss Type Classification

| Event Type – Level 1                      | Event Type – Level 2                          | Activity Examples – Level 3                                                                                                                                                                                                                                                                                                                                                                                                                                            |
|-------------------------------------------|-----------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Internal fraud                            | Unauthorised activity                         | <ul style="list-style-type: none"> <li>• Transactions not reported (intentional)</li> <li>• Transaction type unauthorised (with monetary loss)</li> <li>• Mismarking of positions (intentional)</li> </ul>                                                                                                                                                                                                                                                             |
|                                           | Theft and fraud                               | <ul style="list-style-type: none"> <li>• Fraud/credit fraud/worthless deposits</li> <li>• Theft/extortion/embezzlement/robbery</li> <li>• Misappropriation of assets</li> <li>• Malicious destruction of assets</li> <li>• Forgery</li> <li>• Cheque kiting</li> <li>• Smuggling</li> <li>• Account take-over/impersonation</li> <li>• Tax non-compliance/evasion (wilful)</li> <li>• Bribes/kickbacks</li> <li>• Insider trading (not on a firm's account)</li> </ul> |
| External fraud                            | Theft and fraud                               | <ul style="list-style-type: none"> <li>• Theft/robbery</li> <li>• Forgery</li> <li>• Cheque kiting</li> </ul>                                                                                                                                                                                                                                                                                                                                                          |
|                                           | Systems security                              | <ul style="list-style-type: none"> <li>• Hacking damage</li> <li>• Theft of information (with monetary loss)</li> </ul>                                                                                                                                                                                                                                                                                                                                                |
| Employment practices and workplace safety | Employee relations                            | <ul style="list-style-type: none"> <li>• Compensation, benefit, termination issues</li> <li>• Organised labour activity</li> </ul>                                                                                                                                                                                                                                                                                                                                     |
|                                           | Safe environment                              | <ul style="list-style-type: none"> <li>• General liability (eg, slip and fall)</li> <li>• Employee health and safety rules events</li> <li>• Workers' compensation</li> </ul>                                                                                                                                                                                                                                                                                          |
|                                           | Diversity and discrimination                  | All discrimination types                                                                                                                                                                                                                                                                                                                                                                                                                                               |
| Clients, products and business practices  | <b>Suitability</b> , disclosure and fiduciary | <ul style="list-style-type: none"> <li>• Fiduciary breaches/guideline violations</li> <li>• Suitability/disclosure issues, eg, know your customer (KYC)</li> <li>• Retail consumer disclosure violations</li> <li>• Breach of privacy</li> <li>• Aggressive sales</li> <li>• Account churning</li> <li>• Misuse of confidential information</li> <li>• Lender liability</li> </ul>                                                                                     |
|                                           | Improper business or market practices         | <ul style="list-style-type: none"> <li>• Antitrust improper trade/market practices</li> <li>• Market manipulation</li> <li>• Insider trading (on a firm's account)</li> <li>• Unlicensed activity</li> <li>• Money laundering</li> </ul>                                                                                                                                                                                                                               |

| Event Type – Level 1                       | Event Type – Level 2                           | Activity Examples – Level 3                                                                                                                                                                                                                                                                                                                                                                   |
|--------------------------------------------|------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Clients, products and business practices   | Product flaws                                  | <ul style="list-style-type: none"> <li>Product defects (eg, unauthorised)</li> <li>Model errors</li> </ul>                                                                                                                                                                                                                                                                                    |
|                                            | Selection, sponsorship and exposure            | <ul style="list-style-type: none"> <li>Failure to investigate a client per guidelines</li> <li>Exceeding client exposure limits</li> </ul>                                                                                                                                                                                                                                                    |
|                                            | Advisory activities                            | <ul style="list-style-type: none"> <li>Disputes over performance of advisory activities</li> </ul>                                                                                                                                                                                                                                                                                            |
| Damage to physical assets                  | Disasters and other events                     | <ul style="list-style-type: none"> <li>Natural disaster losses</li> <li>Human losses from external sources (terrorism, vandalism)</li> </ul>                                                                                                                                                                                                                                                  |
| Business disruption and process management | Systems                                        | <ul style="list-style-type: none"> <li>Hardware</li> <li>Software</li> <li>Telecommunications</li> <li>Utility outage/disruptions</li> </ul>                                                                                                                                                                                                                                                  |
| Execution, delivery and process management | Transaction capture, execution and maintenance | <ul style="list-style-type: none"> <li>Miscommunication</li> <li>Data entry, maintenance or loading error</li> <li>Missed deadline or responsibility</li> <li>Model/system misoperation</li> <li>Accounting error/entity attribution error</li> <li>Other task misperformance</li> <li>Delivery failure</li> <li>Collateral management failure</li> <li>Reference data maintenance</li> </ul> |
|                                            | Monitoring and reporting                       | <ul style="list-style-type: none"> <li>Failed mandatory reporting obligation</li> <li>Inaccurate external report (loss incurred)</li> </ul>                                                                                                                                                                                                                                                   |
|                                            | Customer intake and documentation              | <ul style="list-style-type: none"> <li>Client permissions/disclaimers missing</li> <li>Legal documents missing/incomplete</li> </ul>                                                                                                                                                                                                                                                          |
|                                            | Customer/client account management             | <ul style="list-style-type: none"> <li>Unapproved access given to accounts</li> <li>Incorrect client records (loss incurred)</li> <li>Negligent loss or damage of client assets</li> </ul>                                                                                                                                                                                                    |
|                                            | Trade counterparties                           | <ul style="list-style-type: none"> <li>Non-client counterparty misperformance</li> <li>Miscellaneous non-client counterparty disputes</li> </ul>                                                                                                                                                                                                                                              |
|                                            | Vendors and suppliers                          | <ul style="list-style-type: none"> <li>Outsourcing</li> <li>Vendor disputes</li> </ul>                                                                                                                                                                                                                                                                                                        |

## 5.3 Methods of Identification

### Learning Objective

- 3.5.4 Understand the following methods for identifying operational risk: risk and control self-assessment; reviews and audits; focus workshops; risk event analysis; management information
- 3.9.3 Understand how indicators can be used as a method of monitoring operational risk

Classifying operational risk using common categories is the first step in developing a consistent risk language. It also helps to distinguish causes from effects and can be used as a basis for the development of a risk capture, identification and measurement system.

Different organisations will put a different emphasis on risks and will, therefore, categorise risks in different ways. It is not important what categories are chosen, providing that they are:

- logical and understood
- relevant and appropriate, and
- consistent across the organisation.

A common method is to categorise risks by the root causes of operational risk: process, people, systems and events. This can further be broken down into subcategories that support the firms own risk taxonomy and will typically expand over time as the risk management process matures within the organisation; an example of how a firm might approach this is summarised in the following table:

| Example<br>Risk Categorisation |                           |                  |                     |
|--------------------------------|---------------------------|------------------|---------------------|
| Process                        | People                    | Systems          | Events              |
| Procedures                     | Role and responsibilities | Availability     | External technology |
| Capacity management            | Authority to act          | Design           | Regulatory change   |
| <b>Volume sensitivity</b>      | Supervision               | Security         | Integration         |
| Controls                       | Escalation procedures     | System integrity | Pace of change      |
| Documentation                  | Training                  | System controls  | Vendor issues       |
| Delivery mechanisms            | Human error               | Testing          | Catastrophe         |
| Level of automation            | Integrity/honesty         | Cybercrime       | Political climate   |
| Process variability            | Culture                   | Identity theft   | Terrorism           |



There are a variety of methods used for the practical capture and identification of risk. Some of the more common ones are:

- risk and control self-assessment
- reviews/audits
- focus workshops
- risk event analysis and historical loss data, and
- management information statistics and **key risk indicators (KRIs)**.

In order to capture the complete risk profile, all of these methods require the involvement and partnership of risk owners and risk experts. Risk owners include senior management, process and product heads and the line staff who deal with the risks on a daily basis.

The methods described below can be used either individually, or in combination.

### 5.3.1 Risk and Control Self-Assessment

Risk and control self-assessments involve using the expertise of managers and staff to produce a checklist of the risks that the firm faces and their causes. It usually includes a regular reassessment of potential risk exposure as part of the measurement process. This will also consider the probability and impact of the risk identified and the effectiveness of the controls in place.

These self-assessments can be based on a silo within a team or department, or can encompass an entire end-to-end process spanning multiple teams.

### 5.3.2 Reviews and Risk Audits

This involves a review of an aspect of the organisation from a risk perspective by a risk expert. Risk experts are analysts trained in operational risk management, with responsibility for monitoring the risk environment.

The risk expert will work together with management and staff in order to produce a risk profile that can be used in the risk measurement or assessment phase.

Reviews and audits can also be performed on the external risk environment to identify and compare the risks faced by competitors and other market participants.

They will typically consider:

- clarity of risk ownership
- adequacy of the existing controls
- potential impact of losses or control breakdown to the firm
- existence of a suitable mechanism for monitoring the risk.

### 5.3.3 Focus Workshops

Organisations use focus workshops to identify risks and their causes. They are most effective when organised by process rather than function. By involving all of the functional activities in a process, the workshops have the ability to:

- engage all of the relevant risk owners at the same time
- analyse the end-to-end chain of events
- investigate cross-functional dependencies, and
- raise risk awareness.

### 5.3.4 Risk Event Analysis

After a particular risk event has occurred within a firm, it can be analysed by key staff to help identify the reasons for the occurrence and ways in which any further occurrences may be avoided. The firm may learn more about the way it operates and question its own practices to help develop its risk policy further. See section 6.2.6 for further information on risk event analysis.

### 5.3.5 Management Information

Management information (MI) can provide insight into a firm's risk position. Management information may be in the form of statistics, dashboards, or written reports, depending on the needs of the organisation, and may be real time or at a point in time. MI can provide an early warning about trends that have been identified by management before risk events have occurred, for example, an increase in the volume of payment requests over the past three months could act as a lead indicator that the firm could expect an increase in the number of payment related errors unless it brings in additional resource to support the increased work load.

## 5.4 The Practical Problems of Risk Identification

### Learning Objective

- 3.5.5 Understand the practical problems of risk identification: changes to business operating models; changes to business environment; firm-wide engagement; differing individual perception of risk

---

The biggest practical problems with the risk identification phase are:

- **Resource constraints** – the amount of time required to be invested by managers and staff to ensure the compilation of a good-quality, comprehensive risk profile.
- **Operating model** – changes in the mix of business carried on by the firm, changes to its business operating model and the particular environment in which it operates can complicate the identification of risk as these changes may not have been included in existing risk reviews.
- **Business environment** – an immediate and unforeseen firm-wide impact can occur as a result of changes to the regulatory environment, or external systems may hinder the identification of risk as these changes may not have been included in existing risk reviews.

- **Availability and consistency of data** – difficulties in consistently categorising risk data resulting in the lack of good quality, consistent historical data on operational risk available to a firm both internally and externally does present a practical limitation.
- **The lack of robust policies** – the approaches to recording, consistency and utilisation of data may mean that disparate internal data sets are not comparable from a risk perspective.
- **The methods of collecting and compiling a risk profile.**
- **Lack of engagement** – firm-wide engagement may vary over time as a result of natural business cycles, financial performance, remuneration or business volumes; staff may be disengaged or simply not have the capacity to focus on risk identification consistently across the business.
- **Subjectivity** – the opinions and perceptions of staff at the firm towards risk may differ, for example a senior manager at a firm may not regard a particular activity as being of a higher risk than perhaps a less senior manager and vice versa.

## 6. Risk and Control Measurement and Assessment

### Learning Objective

- 3.7.1 Know the basic terms used in the assessment and measurement of operational risk
- 3.7.2 Understand the main reasons for assessing and measuring operational risk

Risk assessment and risk measurement are concerned with understanding the likelihood of risks occurring and their impact on the business in terms of direct or **indirect loss**. Risk assessment is the process of assessing a risk at a point in time with appropriate controls in place (ie, the residual risk), along with estimating the expected impact on the business, and can involve both qualitative and quantitative factors. It is especially useful for considering those risks which cannot be actuarially or statistically measured given the lack of appropriate data.

Risk measurement is associated with the use of quantitative techniques to understand the size of risk such as measuring losses, measuring the frequency and impact of risk events and making statistical predictions.

For instance, a firm's risk measurement system might record that the front-office trading system is 98.5% reliable. A risk assessment would make the judgement as to whether this is acceptable for normal business performance. Put another way, risk assessment is generally more subjective whereas risk measurement is generally more objective. These terms are closely linked and are often used interchangeably – both address the question: how big is the problem?

It should be stressed that the processes for assessing and measuring operational risks are not unique to the operational risk management process as they can also be applied to other types of risk as well.

## 6.1 Why Assess and Measure Risk?

Once an understanding of the size of a problem has been gained, appropriate action can be taken to address it.

The reasons for assessing and measuring operational risk are to:

- establish a **quantitative baseline** for improving the control environment
- ensure there is appropriate **accountability and responsibility** for risk management. By understanding where risk occurs and measuring how big it is, accountability and responsibility can be assigned to the people that are in a position to manage it
- provide an **incentive for risk management** and the development of a **risk-aware culture**. The development of the right environment and culture cannot be overemphasised as a key aspect of managing operational risk. Measuring risk can powerfully demonstrate the impact of operational risk issues and help to gain the commitment that is essential for driving cultural change
- improve **management decision-making**. By knowing the size of the risks they face, managers are in a position to decide how much risk they wish to take
- satisfy regulators and shareholders that a firm is adopting a **proactive and transparent approach** to risk management, and
- make an assessment of the **financial risk exposure** that can be used for capital allocation purposes.

## 6.2 Methods of Measurement

### Learning Objectives

- 3.7.8 Understand the difficulties involved in measuring operational risk
- 3.7.12 Be able to apply the following methods of risk assessment and risk measurement to simple, practical examples: rating and ranking; risk and control self-assessment; scenario analysis; benchmarking; risk event analysis

---

Measuring risk in terms of quantifying the precise financial impact it has on the business would be the ideal basis for decision-making; however, the problem with using financial measures and models is supporting them with accurate, comprehensive data. The acquisition of this data is the most difficult aspect of measurement due to operational risk's complex nature and the fact that much of the data is difficult to derive automatically from the firm's systems.

Objective measurement is difficult because of the same practical problems explained in section 5.4 on risk identification. Objectivity is further complicated by the cyclical and variable nature of most financial institutions, for example, most organisations will have more than one transaction type and the risk impact could vary with transaction type; risk events that occur during the firms quieter periods may have an entirely different impact than those occurring during peak times. It might be difficult for firms to measure the impact of low-frequency events where there is insufficient historical data or a lack of relevant external loss data to make a comparison with a high degree of confidence.

For these reasons, it is hard to measure and assess operational risk precisely, so it is common for a combination of both qualitative and quantitative methods to be used, such as:

- rating, ranking and assessing
- risk and control self-assessment
- scenario analysis
- benchmarking
- material top-down risk assessment
- risk event data analysis.

## 6.2.1 Rating, Ranking and Assessing

### Learning Objective

#### 3.7.3 Understand the ranking method of assessing operational risk

From the control perspective, one of the simplest methods of assessing risk is the creation and application of a rating or ranking hierarchy. This is a method of rating or **ranking** risks in order of their importance.

The assessment may be subjective – depending on the experience of the professionals involved – or objective – being supported by historical data – or both. In either event, the ranking decision depends on two criteria – the likelihood of the risk being realised and the magnitude of the impact.

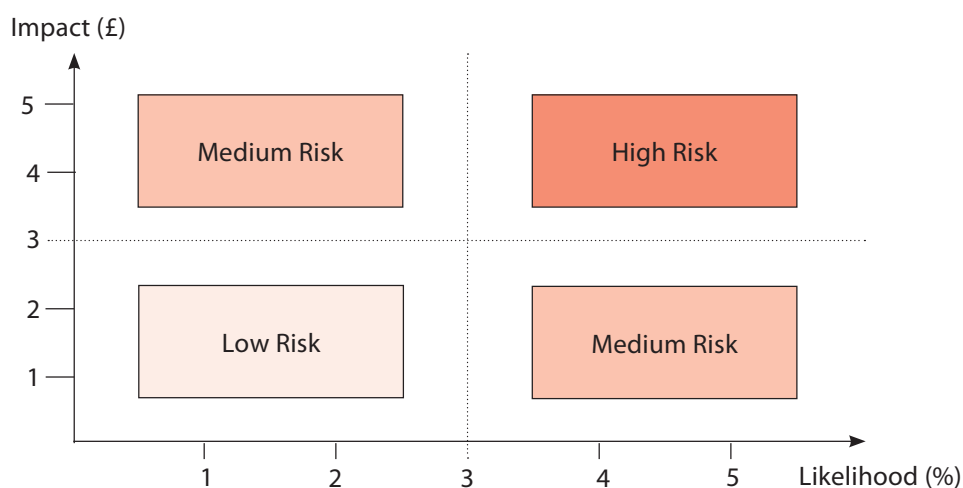
The likelihood of the risk being realised can be represented as a range of probabilities which correspond to a rating, for example:

|           |   |                  | Rating |
|-----------|---|------------------|--------|
| Very Low  | = | less than 1%     | 1      |
| Low       | = | 1% to 5%         | 2      |
| Medium    | = | 5% to 10%        | 3      |
| High      | = | 10% to 20%       | 4      |
| Very High | = | greater than 20% | 5      |

The magnitude of the impact is the potential loss if the risk is realised and can be represented as a monetary range, and also assigned a rating, for example:

|           |   |                    | Rating |
|-----------|---|--------------------|--------|
| Very Low  | = | 0 to £5m           | 1      |
| Low       | = | £5m to £20m        | 2      |
| Medium    | = | £20m to £50m       | 3      |
| High      | = | £50m to £100m      | 4      |
| Very High | = | greater than £100m | 5      |

**Figure 3.3 – A Risk Ranking Chart**



Note that the monetary ranges will change depending on the business area being measured and the scale of the firm's activities.

An overall risk assessment can be made by multiplying together the likelihood or probability and impact ratings to provide a risk score (risk rating) which is effective in prioritising risks:

$$\text{Risk Score} = \text{Likelihood} \times \text{Impact}$$

If there is good quality historical data available, actual percentages of monetary figures can be used.

Each risk can be plotted on a ranking chart to produce a risk profile as shown in Figure 3.3.

Firms will often perform this process for both inherent and residual risks. Inherent risk assessment considers likelihood without controls in place, while residual risk assessment includes consideration of the control environment. This procedure allows the effectiveness of controls to be evaluated and provides an analysis of risk based on:

- existing controls working (residual risk)
- existing controls failing (inherent risk).

A firm which falls into the top right-hand box of 'High Risk' will, in theory, fail and would, in practice, not exist for long.

The advantages of rating or ranking are that it:

- provides a simple, powerful method for viewing the range of risks the business faces
- provides an evaluation of the effectiveness of the control environment
- focuses management attention on the most important risks
- can be used where there is limited historical data, where subjective measurement can still be performed
- can capture a wide range of risk possibilities – from large, strategic risks to everyday, more detailed issues. For this reason it can be effective at all levels of an organisation
- can be used to anticipate loss by ranking the potential risks of new situations. This means it is forward-looking as well as backward-looking. It is, therefore, a useful method if fundamental industry changes need to be understood, such as the impact on the control environment of new ways of working (remote working)
- encourages a risk-aware culture and a more transparent risk environment. In order to maintain the risk profiles, a culture of continuous assessment is needed. This encourages line staff and risk managers to work closely and allows good practice to be adopted more easily, and
- enables a firm to assess its risk exposure against its defined risk appetite.

Problems with applying such a process may occur on the edges or centre, which lie between risk boxes (for example between high and medium) when the cost benefit of remedial action is difficult to ascertain. Its other main disadvantages are that it is subjective and may present an oversimplified view. All subjective assessments should be validated by:

- real loss data, and
- an independent party, such as internal audit, a central risk function or peer review.



## 6.2.2 Risk and Control Self-Assessment

### Learning Objective

3.7.4 Understand the risk and control self-assessment (self-certification) method of assessing operational risk

Risk and control self-assessment (RCSAs), also sometimes known as the 'bottom-up' method or 'self-certification', can be used for measurement as an extension of the risk identification and control process. It generally utilises the ranking approach mentioned previously in section 6.2.1.

Once managers have compiled a list of risks, they make their own assessment of the firm's exposure to each risk on a regular basis.

Self-assessment as a single method of measurement has limitations because:

- it can be subjective and possibly open to abuse and manipulation by managers. For this reason, it should be independently validated
- it can be difficult to apply consistently across the various business units and multiple locations that exist within a global financial institution.

Depending on the approach adopted within a firm, individual RCSAs may be completed at individual team level, department level or business line level for example. This can result in gaps within the RCSAs where teams or department assume that other areas are best placed to record a risk within their own RCSAs; this is exacerbated where there is a lack of clarity around risk ownership within a firm or where there is little visibility across all RCSAs.

Self-assessments are more effective when used in conjunction with other methods.

## 6.2.3 Scenario Analysis

### Learning Objective

3.7.5 Understand the scenario analysis method of assessing operational risk

**Scenario analysis** is a subjective method of highlighting potential risk issues in order to enable preventive action to be taken. It uses the experience of business professionals to capture possible scenarios that have occurred in the past, or that may result in loss in the future.

One of the key advantages of scenario analysis is that it considers more than one variable (risk) in combination to identify the impact and gives the organisation an opportunity to consider how the existing controls would perform. By investigating these scenarios that would not have been apparent when reviewing each risk in isolation, preventative measures can be taken to reduce their risk of occurrence.

It is not uncommon to discover that when viewed in conjunction, one risk event may increase the risk in other areas, eg, a business continuity event may increase the potential risk of fraudulent payments due to a weakened control.

The main disadvantage of scenario analysis is that it depends on the expertise of the professionals involved; if there are gaps in knowledge or experience, the scenarios may lack rigour. It is also challenging to identify all combinations of risks (scenarios) and generally firms will therefore focus on high impact, worst-case scenarios.

### Example of a Scenario Analysis

A firm has an internal policy for the processing of client withdrawals. This involves a member of staff inputting a payment request into the company system and providing supporting evidence of the request. This is subsequently reviewed by another member of staff within the payments team (segregation of duties) who reviews the request and, if approved, inputs the transaction details into the banking system.

Payment instructions are then printed alongside the supporting evidence and are reviewed by two senior managers, and a control sheet is signed before the payment is released on the banking system.

Scenario analysis could be used to as a tool to consider, for example, how the controls would operate in the event of increased volumes of payment requests combined with a business interruption such as loss of access to office locations. In this scenario staff may be working remotely and may not have access to all of the systems or equipment that they would usually have access to within their office such as printers to print the payment instructions for review; senior managers would not also be able to sign control sheets as per the existing process.

In light of the increased payment volumes, the firm would have to consider delaying client withdrawal requests which could be to the detriment of a large number of clients, or temporarily weakening or suspending this control until normal business conditions had been restored, increasing the risk of errors or fraudulent transactions. This highlights a new risk considerations that would not have been visible if each condition was looked at in isolation and allows the firm to consider how it might respond as well as how it could adapt its controls including:

1. Agreeing conditions whereby payments would continue to be made until the electronic withdrawal process has been embedded, including:
  - a. Payments under a specific value that may be considered low risk ie, < £1,000
  - b. Payments over a specific value ie, > £100,000, to reduce client detriment or resulting compensation claims
  - c. Where clients have vulnerable circumstances ie, health conditions
2. Developing an electronic withdrawal process which would remove the need to access printers and to obtain physical signatures, it could also be more efficient allowing for the firm to manage increased payment volumes.

## 6.2.4 Benchmarking

### Learning Objective

#### 3.7.9 Understand the benchmarking method of measuring operational risk

---

**Benchmarking** involves comparing loss data and measures of operational risk with competitors and other firms in the industry. This allows the firm to establish how effectively it manages risk compared with its peer group.

The advantages of benchmarking are that it:

- allows the firm to make a judgement on what represents good performance and set a standard for the industry based on the best firm, and
- makes operational risk more transparent within the industry.

Its disadvantages are that it:

- is difficult to find suitable data sources that compare like with like
- may be difficult to verify open and honest reporting of risk measures, and
- may create a false sense of security for market leaders. Just because a firm ranks highly in its industry does not imply that it manages risk effectively – it merely outperforms its competitors in the risk areas.

## 6.2.5 Top-Down Risk Assessment

### Learning Objective

#### 3.7.6 Understand the top-down risk assessment process

---

A **top-down risk assessment** process involves the senior management of an organisation reviewing the key risks that their business may be exposed to. Typically, this process may comprise of several stages including:

A typical top-down risk assessment process may comprise the following stages:

- identifying the relevant business objectives
- determining risk tolerance (risk appetite)
- identifying events that could affect the achievement of objectives, and
- assessing the inherent likelihood and impact of risks.

The top-down risk assessment process tends to identify the existential threats to the business including changes to the external environment that may not be identified through the more detailed bottom-up process, this may be in part as senior managers or board members may have information not available to all employees. Equally, compared to the 'bottom up' RCSA approach employees may have greater specialist knowledge in relation to their own processes and when this detail is aggregated up to the organisational level, it is not uncommon for the list of key risks to differ substantially between these two approaches.

## 6.2.6 Internal Risk Event Data Analysis

### Learning Objective

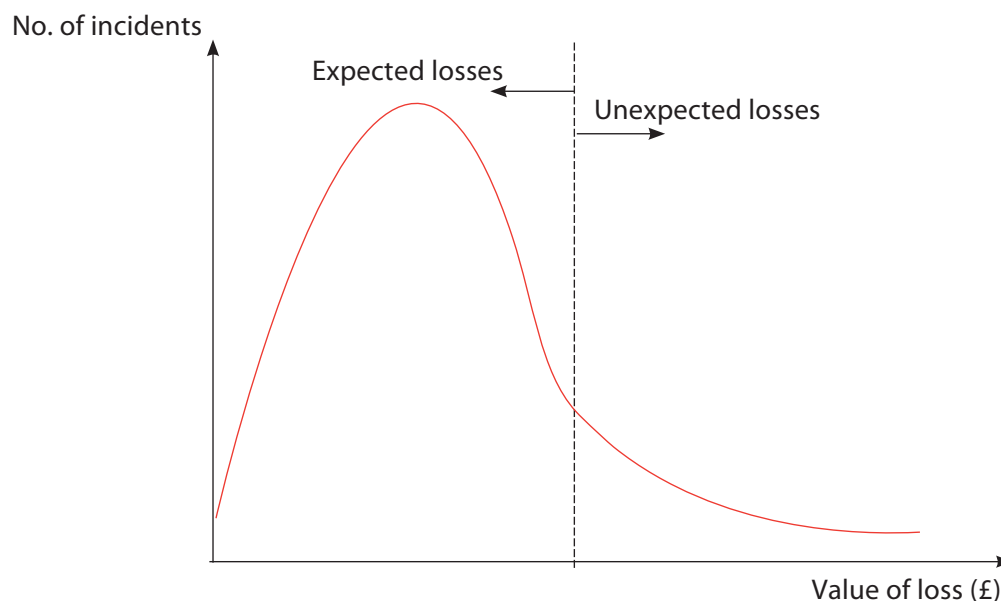
3.7.7 Understand the uses and limitations of internal risk event data in assessing operational risk

Internal risk event data evaluation is important in mapping the actual risk events and losses experienced by the firm back to a sensible categorisation system. Once the data has been collected (from either internal or external sources) it can then be used in the assessment process, often using benchmarking or statistical methods.

For instance, a loss distribution curve may be created that records the value of all material (direct) losses in a particular risk category over a time period of, say, three years. By analysing this curve using similar value at risk (VaR) techniques to those introduced in chapter 2, some prediction of future losses can be made within specified confidence limits.

A typical loss distribution curve might look like Figure 3.4.

Figure 3.4



Expected losses are those that occur with reasonable frequency. They represent known weaknesses, or sit within the risk appetite of the firm. They must be managed by good process controls and an effective, continuous risk management process.

Unexpected losses are those low-frequency, high-impact events that can create serious problems. They are much more difficult to manage on a day-to-day level because they do not occur often enough to test the control environment. They are best managed using contingency planning.

The advantage of using this assessment method is that it allows the firm to understand the size of losses, in monetary terms, which can be attributed to particular risks.

Its main disadvantage or limitation is that it does not predict unexpected losses very well, owing to the lack of data. Some firms also do not make allowance for **near misses**, ie, potential events that might have caused serious harm but were detected in time, by luck or judgement. Consequently, reporting the results of **historical loss analysis** in a way that makes decision-making easier can be difficult. It is also worth noting that firms do not always include indirect or 'soft' costs, as these are not easily identifiable from the accounting system or general ledger.

## 6.2.7 External Loss Data

### Learning Objectives

3.7.10 Know the sources and uses of external loss data

3.7.11 Understand the limitations of using external loss data

As well as being derived from data generated internally, loss data can also be derived from data that is generated and hosted by external data collectors and organisations. This so-called external loss data (ie, the data relating to losses that have been suffered by other firms, either in the same or a different industry, because of operational risk) can then be used in an operational risk framework to support its risk analysis (eg, risk measurement) model impacts by informing stress testing and to benchmark against peer organizations. Using external loss data can therefore inform, refine and enrich an organisations operational risk management framework.

Although there are many sources of external data of value and relevance to institutions, the main ones in the UK include the British Bankers' Association (BBA), the Operational Riskdata eXchange Association (ORX), the Operational Risk Consortium (ORIC) and Fitch.

By looking beyond its own four walls, a firm may be able to identify and address potentially catastrophic risks. In turn, firms that use external loss data effectively have the potential to place themselves ahead of the game in terms of strategic planning and competitiveness within the sector.

| Benefits of Using External Loss Data                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                    | Limitations of Using External Loss Data                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |
|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <ul style="list-style-type: none"> <li>• External data providers make available high-quality information and data for re-use by institutions to support strategic planning.</li> <li>• The quality of data held is assured.</li> <li>• Large quantities of data are available free to institutions on providers' websites.</li> <li>• Bespoke services are provided when more detailed data is required.</li> <li>• Some providers provide regular publications in hard copy form.</li> <li>• High-level data on peer institutions enables firms to make meaningful comparisons.</li> <li>• Time series and historical data enable comparisons over time.</li> <li>• Some providers offer training in the use of data.</li> <li>• Ongoing discussion between providers aims to deliver a rounded service.</li> <li>• Data providers work proactively to enhance the usability of their data.</li> <li>• Such data allows an institution to benchmark specific aspects of its own performance against that of industry peers.</li> </ul> | <ul style="list-style-type: none"> <li>• Working with statistics is still seen as a burden rather than a benefit by some firms.</li> <li>• Without experience, it can be difficult to frame the right question to ask external providers.</li> <li>• It can be expensive to acquire data from external data providers.</li> <li>• It can be difficult to translate statistics into meaningful information accurately.</li> <li>• Providers need to supply more guidance and case studies on re-use.</li> <li>• A lack of data consistency (regarding the same data) between external providers can lead to inefficiency and inaccurate outcomes.</li> <li>• It can be difficult to map external data to internally held data in order to draw accurate conclusions; this could be due to differences in internal systems that support the data collation, or differences in the firms respective business models, so while the data is available it is not a like for like comparison.</li> <li>• It is difficult to obtain data at a sufficient level of detail for making useful comparisons with competitors.</li> </ul> |

## 7. Risk Monitoring and Reporting

### 7.1 Monitoring

#### Learning Objective

- 3.9.1 Understand the main activities that comprise the risk monitoring of the risk management process: measurement; assessment
- 3.9.2 Understand the importance of risk monitoring in the risk management process
- 3.9.3 Understand how indicators can be used as a method of monitoring operational risk

---

The monitoring and reporting cycle allows the risk management process to be continuous. The monitoring stage comprises the following activities:

- an ongoing, continuous process of objective measurement and assessment against a pre-agreed risk appetite
- the establishment and firm-wide adoption of appropriate risk parameters such as risk indicators to measure the level of risk, and
- an independent policing of risk parameters by the firm's risk managers.

During the monitoring process, if risks are found to be unchanged or increasing, then the following may be required:

- a reassessment of risk appetite
- further mitigating action taken, or
- the risk policy may need to be reviewed and amended to improve risk management at the strategic level.

Monitoring risks is typically performed by reviewing key risk indicators (KRIs) which can provide insight into a firm's risk position. Essentially, they are a 'health check' on the performance of the business and may be used by all functions to ensure that risk is satisfactorily controlled. They usually monitor the effects (rather than the causes) of risk at set control points in the business, and come in the form of leading (forward-looking) and lagging (backward-looking) indicators; the former warns that something may go wrong, the latter highlights when something has gone wrong already – typically, organisations should have a mixture of both.

KRIs can be thought of in terms of:

- process-related indicators, which tend to relate directly to performance, and
- non-process-related indicators, which incorporate other important measures of control, especially relating to people.

Examples of process-related and non-process-related indicators are as follows:

| Process-Related Indicators                                                                                                                                                                                                                                                                                                                                                                                                                                      | Non-Process-Related Indicators                                                                                                                                                                                                                                                                                                                                          |
|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <ul style="list-style-type: none"> <li>• Number of settlement failures occurring over a given time period.</li> <li>• Number of times a trader exceeds agreed credit limits.</li> <li>• Number of times funding deadlines are missed in a given time period.</li> <li>• Number and value of cash (nostro) or position (depot) reconciliation breaks over a given time period.</li> <li>• Value of interest claims incurred over a given time period.</li> </ul> | <ul style="list-style-type: none"> <li>• Staff turnover.</li> <li>• Percentage of temporary staff to permanent staff.</li> <li>• Amount of overtime.</li> <li>• Percentage of staff with an agreed training plan.</li> <li>• Period of time to review departmental plans.</li> <li>• Response and resolution times to audit queries.</li> <li>• Absenteeism.</li> </ul> |

These indicators allow the firm to set its risk appetite and give managers the autonomy to make business decisions within specified boundaries. Levels of acceptable risk can be established by attaching limits, or thresholds of acceptability, to each indicator. In this regard, many firms monitor KRIs on a red/amber/green basis (often referred to as the RAG status), and ensure that staff understand the implications, escalation process and actions to be taken when risk indicators go into the amber or red zones.

By identifying and assessing the severity of risks and properly understanding the cause of the chain of events, objective measurement criteria can be chosen to monitor ongoing risk status.

Other indicators that the firm may use include:

- **Key performance indicators (KPIs)** – used to measure activity within the organisation and often used as a measure of success in meeting performance targets.
- **Key control indicators (KCIs)** – used to monitor the effectiveness of controls in meeting their objectives.

All these indicators tend to be reviewed on a periodic basis (generally monthly) to alert firms to changes in risk concerns. Such indicators may include the number of failed trades, staff turnover rates, and the frequency and/or severity of errors and omissions. Firms could benefit from having a robust process for changing KRI thresholds.



## Case Study

Using risk indicators to measure operational risk – setting risk bands for cash (nostro) breaks

Reconciliations are a key internal control for all organisations. As a measure of risk, a firm may determine the number of unreconciled items (ie, unresolved cash nostro breaks) on a firm's cash reconciliations along with the age of the break. This allows the firm to gauge how effectively this control is working and identify the current risk associated with the outstanding reconciling items.

The table which follows shows how risk bands might be set in practice to assess this risk of unresolved cash (**nostro**) breaks. For instance:

- risk is considered to be medium, if the total number of unresolved breaks is between 5% and 7% of total volumes
- risk is considered to be medium, if the number of breaks that have remained unresolved for between 8 and 14 days is between 1% and 1.5% of total volumes
- risk is considered to be medium, if the value of unresolved breaks is between £800 million and £2 billion.

| Assessment Criteria | Risk Bands<br>(approximate percentage of total volumes) |                |            |
|---------------------|---------------------------------------------------------|----------------|------------|
|                     | LOW (green)                                             | MEDIUM (amber) | HIGH (red) |
| Number of breaks    | 3%                                                      | 5%             | 7%         |
| Ageing 0–7 days     | 2%                                                      | 4%             | 6%         |
| Ageing 8–14 days    | 0.75%                                                   | 1%             | 1.5%       |
| Ageing 15–29 days   | 0.25%                                                   | 0.5%           | 1%         |
| Ageing 30–59 days   | 0.10%                                                   | 0.25%          | 0.5%       |
| Ageing 60+ days     | 0.05%                                                   | 0.10%          | 0.25%      |
| Value               | £200m                                                   | £800m          | £2 billion |

In summary, the advantages of using KRIs are:

- They allow trends to be monitored and can, therefore, be used to anticipate problems.
- They allow limits of acceptability to be established.
- They provide a basis for objective performance measurement. Performance measurement can be used to encourage staff to become more risk aware, especially when performance targets, expressed in terms of key indicators, are linked to compensation.
- They act as early warning signals to alert management to problem areas.

The disadvantages are:

- They can be misleading if used in isolation.
- It can prove difficult to report on qualitative measures automatically.

Monitoring is, therefore, an important feedback step that ensures that the risk management process is functioning as expected, specifically that the firm is operating within its risk appetite and that appropriate mitigating controls or action plans have been agreed to bring the risk back into appetite within a suitable timeframe.

Its effectiveness is dependent on the ability of the firm to retrieve, collate and, when necessary, accrue the required information in real-time or on demand.

## 7.2 Reporting and Escalation

### Learning Objective

- 3.9.4 Understand the main functions of operational risk reporting to internal and external stakeholders

Risk reporting is the mechanism of communicating the losses, exposure and risks to the right level of management in the firm. Its functions are to:

- provide transparency of risk status and issues
- aid communication
- reduce uncertainty
- escalate issues and recommendations, and
- facilitate early, decisive action to address the risk.

Risk reporting involves defining periodic reports in consultation with their intended audience and ensuring that real-time escalation systems and procedures are implemented. These procedures need to have predefined thresholds that define how high up the management structure the issue needs to be escalated and who is responsible for escalating it.

It is necessary to report risk internally (across and up the organisation to internal stakeholders) and externally (to clients, regulators, auditors and analysts). A firm's risk policy should also include controls to ensure that the right reports are received by the right people at the right time to support their decision-making. It is important to make sure that the type of information to be collected is clearly defined, including the time at which it is required and the timescale to which it relates. It is also important to ascertain what methods should be used to report and communicate the findings.

After an incident has occurred, the event itself needs to be escalated and reported to the incident management team as well as the relevant risk and risk management committees. This will, in turn, lead to a full analysis of the incident after it has been resolved, including why it occurred, even if the firm had already taken precautionary measures to prevent such occurrences. It may well be that the firm needs to review, change or add procedures and controls following an event in order to ensure that future recurrences are prevented.

Prompt escalation to the incident management team will be required in all instances but particularly when customers of the firm have been impacted. The priority should be to resolve the issues that affect the customers quickly and then undertake the necessary investigations and intensive data collection for the root cause of the problem to be corrected.

## 8. Risk Response

### Learning Objective

- 3.8.1 Understand the type of risk response: risk acceptance; reducing the likelihood and the impact; risk avoidance; risk transfer
- 3.8.2 Understand the use of the following examples of operational controls in reducing the impact or likelihood of operational risk: supervision and segregation of duties; business continuity and contingency planning; information and physical security; risk awareness training
- 3.8.3 Understand how the following examples can be used to transfer operational risk; insurance; outsourcing

---

Once risks have been identified and measured, a firm is in a position to take effective action or respond to address them. Treatment aims to make risks less intense or severe, and there are five potential mitigation methods:

1. Reduce the likelihood of the risk occurring
2. Reduce the impact of the risk, should it occur
3. Transfer the risk
4. Accept the risk
5. Avoid the risk – by ceasing the activity that gives rise to the risk.

### 8.1 Reducing the Likelihood

The likelihood of operational risk exposure can be reduced through the use of **operational risk controls** and, therefore, the impact of the risks on the firm, should they occur, can hopefully be minimised.

Operational risk controls are activities that are inserted into a process to protect it against specific operational risks. Controls do not generally add value to processing in direct terms (ie, by moving the process forward from one state to another), but they can add value in indirect terms by protecting against error and consequential loss.

For example, a procedural control might be set up to protect against the risk of a member of staff diverting funds to a personal bank account when making a payment (ie, committing fraud). This procedure might ensure that one person prepares the documentation to send a payment and another person approves it and physically sends it (ie, segregation of duties). This action does not directly make the process any quicker or cheaper (in fact it might make it slower and more costly); however, it is necessary to protect the firm against fraudulent activity, in order to save money in the longer term. There should be an independent control function and/or internal system audit trail in place to deter this from happening in practice.

Potential risks should be anticipated and evaluated when the process is first designed and the necessary controls embedded within it. There are four types of control – directive, preventative, detective and corrective controls:

**Directive controls** are usually found in the form of policies and other documentation designed to direct individuals to adhere to, or avoid, certain practices. An example of a directive control in use would be the setting up and ongoing maintenance of good procedures to prevent unauthorised actions and errors.

**Preventative controls** are those that prevent errors occurring in the first place. They attempt to tackle the root causes of risk and are most effective when incorporated within processes at the outset by anticipating a risky outcome. Technology solutions are often used as a key means of implementing preventative controls.

A key preventative control is also ‘supervision and segregation of duties’. This means the separation of trading, operation and control, financial reporting and risk management functions. The aim of segregating these functions is to prevent too much responsibility and authority being concentrated in the hands of specific individuals. In turn, this prevents the possibility of the internal control structure being compromised and the risk of fraud arising. The lack of appropriate segregation of duties is one of the major process causes of operational risk.

From the transaction processing perspective, another important area is the maintenance of data integrity in systems, for example, the incorrect capture of a transaction’s details in a firm’s systems due to errors created through manual input. If the process were to be designed so that the transaction is captured once at the point of execution and checked, after which this data may flow automatically into the downstream systems,, the risk of manual errors would disappear, but it would be replaced by system risks, which are generally considered to be lower. This illustrates the benefit of a straight-through processing (STP) or automated environment.

Other examples of preventative controls are:

- the use of training to reduce the likelihood of human error arising from a lack of expertise
- the use of well-designed systems to automate processes such as STP that prevent users re-keying data, and
- the use of systematic controls to eliminate risk due to human error, such as validating data fields to prevent users from inputting a date of birth for a future date.

**Corrective controls** are designed to remediate errors or losses where the previous control types have failed. An example of a corrective control in use would be an authorisation process to make a payment to a client’s account to cover losses incurred due to an internal process or control failure, putting the client back in the position they would have been in had the error not occurred.

**Detective controls** detect errors once they have occurred. They can be further split into two sub-categories – internal and external detection:

- **Internal detective controls** detect errors after they have occurred but before a potential loss is realised in the outside world (ie, they detect the risk event in order to prevent the effect). Checking and inspection-type activities fall under this category. For example, checking the legal drafting of a contract before it is signed is a control that may detect errors in the terms and conditions of the contract. These errors would then be rectified and the contract sent out at no loss to the firm. If the control did not exist, the potential for legal risk to be realised would increase.
- **External detective controls** are those that detect errors and losses once they have been realised (ie, they detect the effects). Post-settlement checks such as statement-to-ledger reconciliations fall under this category. If a problem is found, (eg, if a counterparty has not been paid on time) there could be a loss realised due to a compensation claim for lost interest. If the detective control is effective, the problem will be resolved quickly and the loss effect limited. External detective controls are important because they can limit the direct and indirect losses to the firm. They are really concerned with reducing the impact of loss, rather than reducing the likelihood of loss (because the loss has already occurred). This is discussed further in section 8.2.

## 8.2 Reducing the Impact

If a risk does crystallise, there are several ways that the resulting loss to the firm can be reduced.

As stated in the previous section, using detective controls is one method. Other strategies include:

- **Diversification strategies** – an over-reliance on a particular customer, product or market may expose the firm to heavier losses than if it operated a more diverse business.
- **Risk-sharing** – by collaborating with other firms, or pursuing joint ventures, it is possible to share any potential operational losses. Risk-sharing differs from risk transfer, an explanation of which appears in section 8.4 below.
- **Business continuity and contingency planning** – this includes emergency response and crisis management, and covers a whole range of scenarios as identified by the business. Businesses need to understand the underlying risks and the potential impact of each type of disaster, as this will help determine which scenarios are most likely to occur and to which ones resources should be given. From this, businesses should then draw up contingency plans to reduce the impact of each scenario on the organisation. These plans need to be maintained, tested and checked regularly to ensure they remain up to date and reflective of the risks within the business. It is also important to consider the magnitude of the risks that could result in these impacts. This will help to inform which scenarios are most likely to occur, and to which ones resources should be given at the planning stage. Examples of potential risks that lend themselves to continuity planning include:
  - fire
  - system failure
  - power failure
  - earthquake
  - explosion
  - civil unrest
  - pandemic
  - strikes, and
  - adverse weather conditions.

- **Operational resilience** – this describes how well an organisation is able to absorb or adapt to an ever-changing environment and ensures that the design of infrastructure, processes and systems is able to resist a business interruption. A key distinction between operational resilience and business continuity is that operational resilience includes changes in customer demand or the wider market in addition to business continuity scenarios and is concerned with reducing these impacts on the business.
- **Disaster recovery** – this is concerned with responding to events after they have occurred and ensuring the business can return to 'business as usual' with the least impact, usually within a set timeline agreed.
- **Information and physical security** – the operational risks associated with information and physical security can be reduced by firms making adequate and suitable arrangements for safeguarding them. The level to which this can be done depends on the amount, type and value of the things that need to be safeguarded and can range from restricted access to hard copies of information to data encryption for data stored electronically.
- **Risk awareness training** – providing training on operational risks and how to mitigate them can help to strengthen the firm's internal controls environment as well as its culture. Often, those directly involved in or closet to the operational activities are best placed to recognise emerging risks and escalate concerns. Their proximity to the underlying processes enables them to offer valuable insights into most appropriate mitigation strategy. This training may be across the organisation, or targeted to key individuals such as those responsible for completing risk and control self assessments.
- **Good communication and reporting** – having high quality, integrated management information systems allows information to be shared globally and efficiently. This means that, if a risk is realised, the firm is able to react quickly to reduce its impact.

### 8.3 Risk Avoidance

Avoiding risk means either withdrawing from a business line, industry sector or geographic market because of an unacceptable level of risk, or deciding not to take on new business, mergers or growth for the same reasons.

While this avoids the risk entirely, it also removes the opportunity to generate revenue in this area so is often considered as a last resort where other methods of reducing the impact are not considered appropriate by the firm.

### 8.4 Risk Transfer

Transferring risk can be achieved in a number of ways, including:

#### Outsourcing

If a firm understands the amount of operational risk it carries, it may choose to outsource aspects of its business to a third party with specific expertise in managing certain risks who will carry the risk exposure for a fee. This option of risk management is gaining popularity with financial institutions; however, it is important to remember that a firm only transforms the risk from, say, direct process risk to managing the quality of the outsourced process, in other words, a risk still exists. On the other hand, some firms also actively take on risk from others, as seen in insourcing businesses.

## Insurance

Insurance is a means of transferring a specified amount of risk to an insurance provider for a fee (the premium). For example, it may:

- cover the event of loss due to fire, theft, risk of non-payment of monies owed, losses when they occur and/or loss of profits
- provide potential balance sheet protection
- smooth income flows for the business.

When taking out insurance, a firm needs to know what the insurance will pay out for, and when it will pay out. In practice, insurance companies will usually cap their potential liability under a policy by imposing limits and may stipulate conditions on the firm (eg, a firm may take out an insurance cover of up to £1 million to protect against theft; however, the insurance company may require the firm to have minimum levels of security in operation). Insurance can reduce the impact of a risk event, but it will not remove it completely; reputational damage, and subsequent potential loss of income, could still occur.

## Financial Reserves

Financial reserves is essentially a form of self-insurance that can be used to increase a firm's ability to withstand the impact of a risk event being realised. Financial reserves also serve to reduce liquidity risk and need to be held in a form that ensures that they are sufficiently liquid (such as cash or liquid assets) so that they can be accessed at short notice and without delay in any crisis situation.

While risk transfer can be attractive to businesses seeking to reduce their direct financial losses and capital adequacy costs, it does not address the reputational impact which can lead to loss of clients. Also, the indirect costs of operational losses incurred by an insurer or third party will most likely still have to be borne by the firm.

## 8.5 Accepting the Risk

As covered in section 1 of this chapter, simply operating requires exposure to some level of certain types of risk. If a firm is satisfied that its identification and measurement systems are rigorous and effective, and that it has a good understanding of its risks, it may decide to retain a certain level of risk. In other words, a degree of risk exposure is within the organisation's risk appetite and it is prepared to accept the risk in return for higher profit. Accepting risks within tolerance allows the organisation to focus its resources and its risk management function on higher priority risk areas, thereby having a greater impact in reducing the organisational risk profile.

## 9. Practical Constraints of Implementing an Operational Risk Management Framework

### Learning Objective

- 3.3.5 Understand the practical constraints of implementing an operational risk management framework

Understanding the constituents of a risk management framework is one thing; implementing it successfully is another.

Summarising some of the themes that have been discussed so far in this chapter, some of the practical constraints of implementation are:

- **Data collection and management constraints** – in practice, it is very difficult to build a truly comprehensive data set. Apart from the general lack of data, system constraints and a lack of standardisation mean that the required data feeds from disparate sources cannot be easily developed. There is also relatively little availability of industry-wide data, as this depends on firms 'self-reporting' and, by definition, it is not straightforward to gain an understanding of high-impact, low-frequency events. Firms may also not be allowed to report for legal disclosure reasons.
- **Cultural constraints** – business heads need to be convinced of the value that operational risk management will bring. If not implemented in a well-structured manner, it is often seen as a cost to the business, and even a nuisance, rather than a real asset. Consequently, many firms have rolled out risk management frameworks little by little, attempting to gain the confidence and support of one business area before moving on to another.
- **Resource and cost constraints** – firms continually underestimate the amount of time and resources required to implement identification and measurement systems. In an era of tight cost controls, resource constraints put a limit on how quickly or comprehensively implementation is carried out.
- **Indicator constraints** – it can be difficult to design risk indicators that monitor the full range of risks. There is a natural tendency to use indicators that are already available (such as existing management information) but these are often designed to monitor performance rather than risk. The extra cost and time required to design and maintain a truly comprehensive set of risk indicators is often prohibitive.



## 10. Operational Resilience

### Learning Objective

- 3.10.1 Understand the difference between operational risk and operational resilience and the significance placed upon operational resilience by the regulators

---

Operational resilience has been the focus of regulators both in the UK and around the world as the financial services and banking sectors become more interconnected. In the UK, the FCA, PRA and Bank of England have been working on a joint policy statement on operational resilience, which is defined by the Basel Committee on Banking Supervision (BCBS) as: *'the ability of a bank to deliver critical operations through disruption'*.

In practical terms, operational resilience is one of the outcomes of good operational risk management; however there are some key differences between the two. Firstly the term, critical operations, needs to be defined based on the range of services an organisation provides its clients, in the UK these critical services are known as Important Business Services (IBS).

Once an organisation has mapped its important business services, it will need to assess its impact tolerances which describes the maximum tolerable level of disruption to an IBS. These impact tolerances will vary between organisations and are impacted by the firm's appetite to risk as well as understanding the potential impact to its clients.

Finally firms are expected to perform scenario testing against a range of extreme but plausible scenarios to ensure that the firm can continue to deliver these important business services within these impact tolerances.

While there is clearly overlap between the objectives of operational resilience and operational risk, operational resilience can be thought of as managing the risk relating to the delivery of important business services whereas operational risk concerns itself with managing risks to the firm.

## End of Chapter Questions

Think of an answer for each question and refer to the appropriate section for confirmation.

1. **What are the three stages of the operational risk chain of events?**  
*Answer Reference: Section 1*
2. **Which nine areas should an operational risk policy address?**  
*Answer Reference: Section 3*
3. **Why does an operational risk policy require board-level sponsorship?**  
*Answer Reference: Section 3.1*
4. **What are the three key objectives of operational risk management?**  
*Answer Reference: Section 4*
5. **Name the stages of the risk management process.**  
*Answer Reference: Section 4*
6. **Why do operational risks need to be understood, recorded and categorised?**  
*Answer Reference: Section 5.1*
7. **List five common methods of risk identification.**  
*Answer Reference: Section 5.3*
8. **How do risk measurement and risk assessment differ?**  
*Answer Reference: Section 6*
9. **Give three reasons why it is important to measure operational risk.**  
*Answer Reference: Section 6.1*
10. **Why is it difficult to measure operational risk quantitatively?**  
*Answer Reference: Section 6.2*
11. **List six common methods of risk measurement and assessment.**  
*Answer Reference: Section 6.2*
12. **List three advantages of ranking as a form of risk assessment.**  
*Answer Reference: Section 6.2.1*
13. **What does benchmarking involve?**  
*Answer Reference: Section 6.2.4*
14. **What are some of the benefits of using external loss data?**  
*Answer Reference: Section 6.2.7*
15. **What are the five main risk response strategies?**  
*Answer Reference: Section 8*

**16. Continuity planning is an example of which risk response strategy?**

*Answer Reference: Section 8.2*

**17. Name the three main ways of transferring risk.**

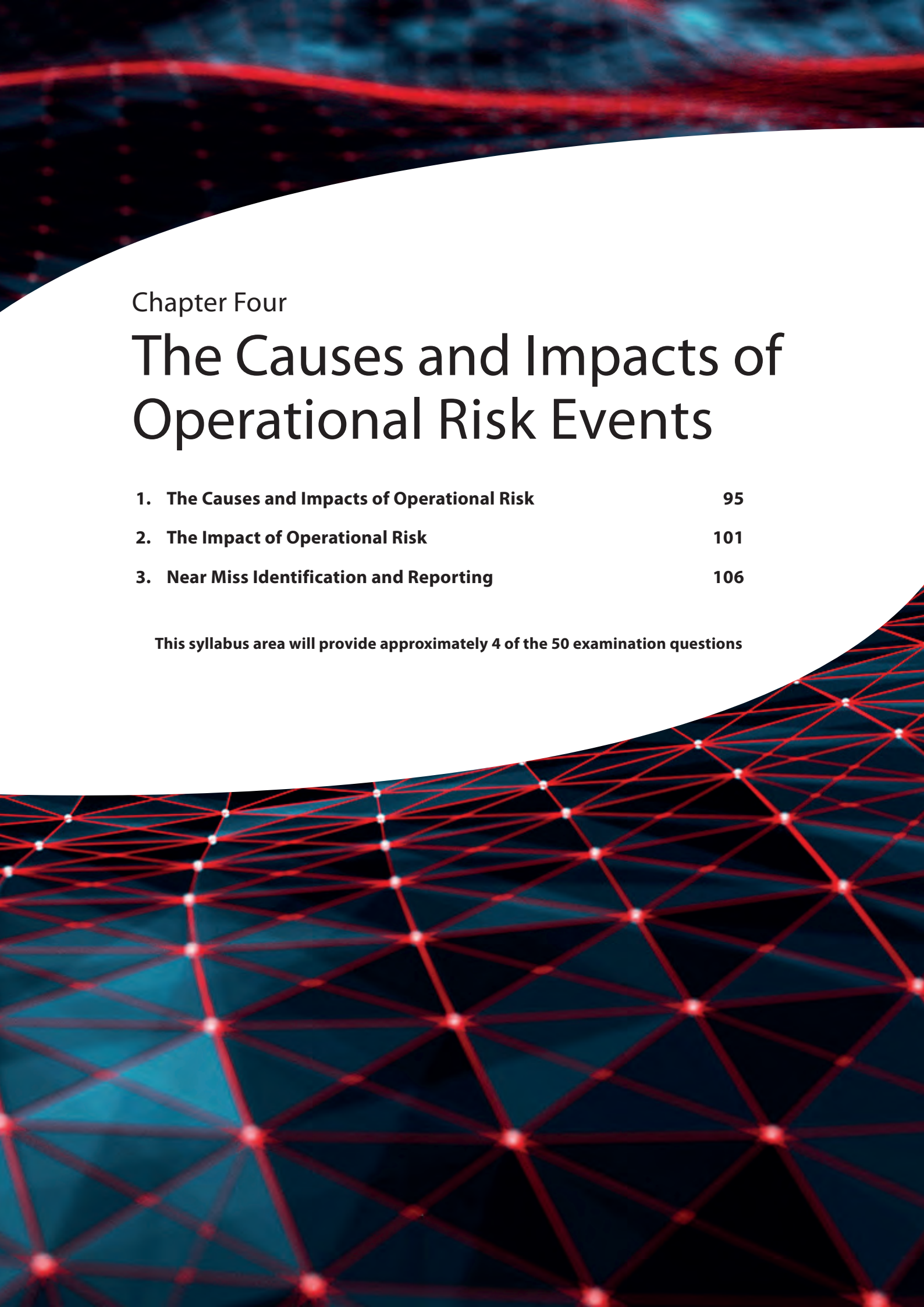
*Answer Reference: Section 8.4.1*

**18. Why might a firm decide to retain a certain level of risk?**

*Answer Reference: Section 8.5*

**19. List some of the practical constraints that might be encountered when implementing an operational risk management strategy.**

*Answer Reference: Section 9*



## Chapter Four

# The Causes and Impacts of Operational Risk Events

|                                               |     |
|-----------------------------------------------|-----|
| 1. The Causes and Impacts of Operational Risk | 95  |
| 2. The Impact of Operational Risk             | 101 |
| 3. Near Miss Identification and Reporting     | 106 |

**This syllabus area will provide approximately 4 of the 50 examination questions**





# 1. The Causes and Impacts of Operational Risk

## Learning Objectives

- 4.1.1 Know the four causes of operational risk events
- 4.1.2 Understand why knowledge of causes is important in operational risk management

## 1.1 Root Causes

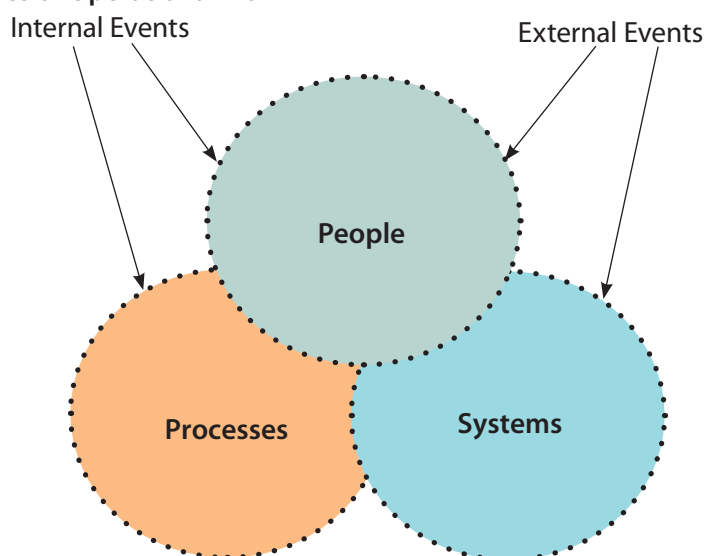
All types of operational risk can be traced back to four root causes:

- **people** – failure of the people or staff employed by the institution
- **processes** – failure of inadequate processes they are involved in to execute business
- **systems** – failure of the systems that are developed to support the processes and the people
- **external events** – which impact the people, processes and systems, such as economic conditions, regulation, competition, law, tax policy, the labour market, the pace of change, pandemics, war and natural disasters.

The relationship of these causes is represented in Figure 4.1. The diagram shows that each cause of risk cannot be considered in isolation, rather each one affects the others and they are mutually interdependent. This means that an ineffective approach to the management of risk within one area will have knock-on effects on the others.



**Figure 4.1 – The Causes of Operational Risk**



How well an organisation influences and adapts to its environment and harmonises its people, processes and technology dictates how successful it will be in managing its risk.

For example, if staff are using old, manually intensive and incompatible systems, the reliance on their integrity and expertise to deal with system-related problems is greater and the complexity of the process design to ensure control is increased. This will have an impact on the firm's ability to adapt to its changing environment and its effectiveness in controlling its risk environment.

Conversely, adopting an efficient straight-through processing (STP) system will greatly reduce people risk, but will increase system risk due to the increased reliance on Information Technology (IT).

## 1.2 Operational Risk Events

An operational risk event is an actual loss/gain event resulting from inadequate processes, people, systems or from external events.

Due to the breadth of operational risk, the potential events that link root causes to effects cover a wide range of activities that can eventually result in loss. Some of the important events are:

- incorrect data
- delayed processing and documentary omissions
- regulatory non-compliance
- project mismanagement
- fraud and theft
- unforeseen litigation
- information technology failures.

The events are described in section 1.3 and their consequent impact in section 2.

## 1.3 The Relationship Between Risk Events and Root Causes

### Learning Objective

- 4.1.3 Understand operational risk events in simple, practical examples: incorrect data; delayed processing and documentary omissions; regulatory non-compliance; project mismanagement; fraud and theft; unforeseen litigation; information technology failures
- 4.3.1 Understand the links between, causes, events and impacts of operational risk

Due to the breadth of operational risk, the potential events that link root causes to effects cover a wide range of activities that can eventually result in loss. We will now describe some of these events and their consequential impacts.

### 1.3.1 Incorrect Data

Institutions hold and process vast quantities of data often in different forms and in more than one place. However, data can be incorrect for several reasons, for example:

- it has been captured or calculated incorrectly
- overwritten in error, or
- it has not been updated to reflect changes.

This lack of data integrity can originate from any or all of the four causes described in section 1.1. For example, data may need to be manually keyed into a system because two systems are incompatible with each other (system cause), leading to mis-keying because of human error (people cause). The error may then not be detected due to the lack of an effective control procedure (process cause), which may then result in incorrect documentation being sent to a client. The chance of this problem occurring might be increased due to the pressure of increasing volumes (event cause).

Examples of the potential effects of incorrect data are:

- direct loss due to failed transactions
- direct loss if the error is not spotted early enough, eg, a transaction being incorrectly priced with the market moving against the trader
- indirect loss due to damaged reputation resulting from incorrect documentation, and
- incorrect order raised and executed due to incorrect data analytics.

### 1.3.2 Delayed Processing and Documentary Omissions

Delays and documentary omissions can occur due to a number of causes, including increases in work volumes or too much change affecting the business. These are often early warning signs of process weakness or a lack of appropriate controls. They may also be caused by a lack of awareness of the operational risk issues leading to a lack of timely action due to the pressure of mistakes and errors.



Delays in the processing of a transaction or omissions in documents can result in interest claims or financial penalties (direct losses), and damaged reputation resulting from incorrect documentation (indirect losses).

### 1.3.3 Regulatory Non-Compliance

Institutions operate within a set of industry rules and regulations defined by law, or industry guidelines enforced by their regulators. Firms aim to operate within these rules. However, they may inadvertently transgress due to incorrect interpretation of the requirements or a lack of adequate people, processes or systems. For instance, reporting deadlines may be missed, reports may be incorrect or limits may be exceeded.

Examples of the potential effects of regulatory non-compliance are direct loss through fines or penalties, and indirect loss through regulatory censure resulting in damaged reputation or inability to trade.

### 1.3.4 Project Mismanagement

The way that many firms bring about change is through the implementation of projects. Projects are packages of work that deliver a defined change. They usually form part of an integrated programme that helps the firm to manage its changing environment.

Projects can be large and strategic (eg, the design and implementation of a new system capable of processing ten times the volume of business with lower risk and for the same cost), or small and tactical (eg, the design and implementation of a client query system that helps to improve the quality of client service). Either way, the sum total of all project work occurring in an organisation has an effect on its business-as-usual operations. Examples of projects are:

- The design and implementation of a new system capable of processing ten times the volume of business with lower risk and for the same cost. This would be a large, strategic project and would involve people, process or system aspects.
- The design and implementation of a client query system that helps to improve the quality of client service. This may vary in size from a small project in one particular area of operation to a more strategic project involving a number of departments.
- The design and implementation of a management training programme to support a cultural change to a more consensual style of management.
- The design and implementation of a new organisational structure for a firm to provide greater autonomy and better decision-making for middle managers.

**Project risk** is the risk that the failure, or partial failure, of a project to meet its objectives leads to financial loss, lost opportunity and resource costs. Since projects can overlap several areas, take significant time and require a great deal of resources to implement, undertaking a project and assuming project risk can be significant.

The potential effects of project mismanagement are:

- a **direct loss** to the firm because of:
  - the need to use more resources, including management time, to bring a delayed project back on course
  - project delays creating higher costs of operating the business
  - cancelling a project midway through its life
  - having to set up further projects to take remedial action due to the initial project delivering an inadequate solution
- an **indirect loss** due to:
  - the opportunity of using the resources employed on the unsuccessful (or semi-successful) project in a more effective manner
  - the project destabilising day-to-day operations. For instance, the involvement of line staff in the project may put extra pressure on the business. This has knock-on effects of causing events such as incorrect data, delayed processing and documentary omissions, or deterioration in client service, which then lead to financial loss
  - the project being part of a change programme that is uncoordinated or inadequately controlled. The sum total of all projects may be beyond the capacity of the business.

### 1.3.5 Fraud and Theft

Fraud and theft can be committed from within the organisation (internal fraud) or by persons outside the organisation (external fraud). They can occur due to a combination of causes, such as the dishonesty of the fraudster (people cause) or the weakness in process or system design that gives him or her the opportunity to commit the crime (process cause).

For fraud and theft to occur, there must be opportunity, and this opportunity is usually the result of an operational issue. For example, if a single individual has end-to-end authority in the processing of client payments, the opportunity for fraud is greatly increased; this could be the ability to amend bank account details stored within the system as well as the authority to release payments in its banking systems. This is one of the main reasons why firms have established controls in place to ensure segregation of duties between front and back office functions.

The potential effects of fraud and theft are direct loss as a result of the crime, and indirect loss due to adverse publicity damaging the firm's reputation.

### 1.3.6 Unforeseen Litigation

Unforeseen litigation is an aspect of legal risk. This includes instances when the firm is sued, for example, due to:

- contractual differences or ambiguities relating to the level of service to be expected from a third-party systems provider or outsourced partner
- any litigation brought by a competitor due to issues such as intellectual property, or
- employee litigation resulting from grievances involving equal opportunities, health and safety, compensation or employee contracts.

The potential effects of unforeseen litigation are direct loss related to potentially large compensation and legal bills resulting from losing a lawsuit, and indirect loss due to the effects of adverse publicity on the firm's reputation.

### 1.3.7 Information Technology Failures

Technology failures can occur for many different reasons, some of which are in the control of the firm, some of which are not. The ultimate effect or impact of operational risk systems being realised is direct or indirect financial loss.

Examples include:

- power failure
- hardware failure
- back-up power systems not working
- hardware failure
- viruses and bugs affecting the operation of systems
- loss of data or data corruption
- systems or software becoming obsolete or insufficient
- over usage or overloading of systems, and
- cyber attacks such as distributed denial-of-service (DDoS) attacks.

Failure can also occur where a firm has interrelated systems that are dependent on one another for the effective operation of the business. For example, system upgrades to one system may affect the communications and compatibility with other systems, both internally and externally. The number of system dependencies grows exponentially as the business adopts new interconnected systems.

The huge amount of data being generated by modern financial services firms means organisations must plan well ahead to have systems which can handle the volumes of transactions taking place. Failure to do so may harm customers and also put the firm into regulatory non-compliance.

The potential effects of technology failures are direct loss through fines or penalties, indirect loss due to the amount of time spent by staff that are unable to proceed with their responsibilities, and indirect loss resulting from adverse publicity negatively impacting the firm's reputation.

## 2. The Impact of Operational Risk

### 2.1 Financial Loss

#### Learning Objective

- 4.2.1 Understand direct and indirect financial loss
- 4.2.2 Understand the following examples of financial and non-financial impact of an operational risk event: potential loss of earnings; regulatory censure/closure and reputational damage; staff demotivation; poor conduct risk outcomes; remedial and litigation costs

As with market and credit risk, the ultimate effect or impact of operational risk being realised is financial loss. Such financial losses can be either direct or indirect.

#### 2.1.1 Direct Loss

Direct loss is the direct financial costs or penalty that a firm incurs as a result of a risk being realised. It can be due to:

- claims for damages or compensation as a result of failure to meet contractual obligations
- penalties and fines arising from regulatory censure, or revocation of licences
- loss of income from transaction fees, direct fees and commissions
- loss of assets or cash through unenforceable contracts
- costs associated with compensating client loss as a result of poor conduct risk outcomes
- corrections to profit and loss (P&L) due to mistakes in booking, or
- the associated direct remedial or litigation costs of rectifying the operational weakness that led to the loss.

#### 2.1.2 Indirect Loss

Indirect loss is sometimes referred to as consequential loss. Indirect loss may be incurred due to the associated remedial costs of rectifying the operational weakness that led to the loss, such as through re-allocating staff from profitable activities to help correct the problem.

Indirect loss can have both financial and non-financial impacts, for example reputational damage, known as reputational risk, can influence client opinion of the integrity of a financial institution, which is a major factor in its competitiveness and success.

They can be damaged by:

- adverse publicity due to a lack of client suitability, ie, being associated with criminals, notoriety or scandal
- perceived malpractice, such as inflating commissions, mis-selling, concealing losses and the identification of accounting irregularities
- not responding to client complaints in a timely manner leading to further complaints requiring additional resources to resolve
- client dissatisfaction resulting in loss of not only existing clients, but also future business opportunities.

### **Examples of Direct and Indirect Financial Loss**

A firm has been subject to enforcement action from the regulator in relation to its protection of client money and assets. This has resulted in a number of losses to the firm including:

Direct losses:

- the cost of appointing a skilled person under Section 166 skilled person review
- the cost of the regulatory fine
- the cost of implementing new systems.

Indirect losses:

- the resource cost in reviewing and rectifying the process weakness over a prolonged period
- the loss of future business as a result of the enforcement action
- the loss of productivity due to staff demotivation.

While the immediate impacts may be considered non-financial, these may ultimately lead to a financial consequence. For example, a lack of morale could lead to a loss of productivity which, in turn, could result in failing to attract new clients, or having to hire additional staff.

## 2.2 The Effects of Operational Risk Events

### Learning Objective

- 4.1.3 Understand the operational risk events in simple, practical examples: incorrect data; delayed processing and documentary omissions; regulatory non-compliance; project mismanagement; fraud and theft; unforeseen litigation; information technology failures

This table gives some examples of the main impacts of the risk events described earlier.

| Risk Event                                   | Risk Effect                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                |
|----------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Incorrect data                               | <p>Examples of the potential effects of incorrect data are:</p> <ul style="list-style-type: none"> <li>• direct loss due to failed transactions</li> <li>• direct loss if the error is not spotted early enough, eg, a transaction being incorrectly priced with the market moving against the trader</li> <li>• indirect loss due to damaged reputation resulting from incorrect documentation</li> <li>• incorrect order raised and executed due to incorrect data analytics.</li> </ul>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                 |
| Delayed processing and documentary omissions | <p>Delays in the processing of a transaction or omissions in documents can result in the following effects:</p> <ul style="list-style-type: none"> <li>• direct loss due to a payment or funding deadline being missed resulting in interest claims or financial penalties</li> <li>• indirect loss due to damaged reputation resulting from incorrect documentation.</li> </ul>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                           |
| Regulatory non-compliance                    | <p>Examples of the potential effects of regulatory non-compliance are:</p> <ul style="list-style-type: none"> <li>• direct loss through fines or penalties</li> <li>• indirect loss through regulatory censure resulting in damaged reputation or inability to trade.</li> </ul>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                           |
| Project mismanagement                        | <p>The potential effects of project mismanagement are:</p> <ul style="list-style-type: none"> <li>• a direct loss to the firm because of:             <ul style="list-style-type: none"> <li>• the need to use more resources, including management time, to bring a delayed project back on course</li> <li>• project delays creating higher costs of operating the business</li> <li>• cancelling a project midway through its life</li> <li>• having to set up further projects to take remedial action due to the initial project delivering an inadequate solution</li> </ul> </li> <li>• an indirect loss due to:             <ul style="list-style-type: none"> <li>• the opportunity of using the resources employed on the unsuccessful (or semi-successful) project in a more effective manner</li> <li>• the project destabilising day-to-day operations. For instance, the involvement of line staff in the project may put extra pressure on the business. This has knock-on effects of causing events such as incorrect data, delayed processing and documentary omissions, or deterioration in client service, which then lead to financial loss</li> <li>• the project being part of a change programme that is uncoordinated or inadequately controlled. The sum total of all projects may be beyond the capacity of the business.</li> </ul> </li> </ul> |

| Risk Event            | Risk Effect                                                                                                                                                                                                                                                                                                                                                                 |
|-----------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Fraud and theft       | The potential effects of fraud and theft are: <ul style="list-style-type: none"> <li>• direct loss as a result of the crime</li> <li>• indirect loss due to adverse publicity damaging the firm's reputation.</li> </ul>                                                                                                                                                    |
| Unforeseen litigation | The potential effects of unforeseen litigation are: <ul style="list-style-type: none"> <li>• direct loss related to potentially large compensation and legal bills resulting from losing a lawsuit</li> <li>• indirect loss due to the effects of adverse publicity on the firm's reputation.</li> </ul>                                                                    |
| Technology failures   | The potential effects of technology failures are: <ul style="list-style-type: none"> <li>• direct loss through fines or penalties</li> <li>• indirect loss due to the amount of time spent by staff that are unable to proceed with their responsibilities</li> <li>• indirect loss resulting from adverse publicity negatively impacting the firm's reputation.</li> </ul> |

## 2.3 The Links Between Causes, Events and Impacts of Operational Risk

### Learning Objective

#### 4.3.1 Understand the links between causes, events and impacts of operational risk

In chapter 1, we defined risk as *'The chance or possibility of damages, loss, injury or other adverse consequences'*. For any risk to be crystallised within an organisation, there must be the realisation of a risk event, ie, the risk event is essentially the loss event that occurs. In contrast, the risk effect is the loss incurred by the firm.

Below are some examples of these operational risks. In each example, there are details of the root cause, the event and the impact of the operational risks.

## Examples

### 1. Data stored in the system incorrectly

**Root cause** – Technology (complex systems) and/or people (lack of training).

**Event** – Traders incorrectly inputting trade details into their systems.

**Effects** – Financial loss due to a failed trade (eg, interest claims) plus possible knock-on effects if the trade is part of a structured product or hedge, as well as reputational damage leading to a loss.

### 2. Unexpected litigation

**Root cause** – People (lack of training or carelessness), compounded by process (the complexity of the job).

**Event** – An ambiguous clause inserted into a contract.

**Effects** – Financial loss arising from the contention of a contract by a client or third party (eg, cost of litigation, inability to claim profits) as well as reputational loss.

### 3. Regulatory non-compliance or breach

**Root cause** – Either technology (a poor design of the model) or process (the mistranslation of the business requirements when developing the model).

**Event** – An error in a credit model resulting in a client exceeding its credit limit. This may lead to regulatory censure and unexpected financial loss if the client defaults.

**Effects** – Potentially larger-than-expected loss, if the client defaults, and financial penalties from regulators (with consequential reputational damage).

### 4. Delayed processing

**Root cause** – Weak process and controls in identifying and monitoring open option positions and exercise events.

**Event** – The expiry date of an option being monitored.

**Effects** – Financial loss due to not exercising an in-the-money option.

Identifying the root cause of the risk is required in order to be able to identify appropriate controls later in the risk management cycle.

Identifying the risk effects involves recognising the various negative impacts on the business associated with the risk identified. This could be financial, reputational, operational (ie, reduced capacity) or result in the loss of future customers.

There are countless other example of operational risk that can occur anywhere in the transaction life cycle.



### 3. Near Miss Identification and Reporting

#### Learning Objective

- 4.4.1 Understand the concept and importance of near miss identification and reporting as a result of an operational risk event

---

A risk event can either deliver an actual loss or gain or it could be a **near miss**. The definition of a near miss is effectively embodied in its very name: it is where a risk event has occurred but it did not result in an actual loss (ie, the risk effects were not realised). It could represent an event that would have occurred if preventative control measures had failed or been inadequate; alternatively, it might be an event that ultimately did not cause any loss because a firm's detective control mechanisms operated successfully. It could also be that a loss was avoided simply by luck or chance.

An example of a near-miss incident could be a trader incorrectly inputting trade details into their systems with the wrong price detail, which ordinarily may lead to a financial loss for the brokers or its client. However, an operational control system may identify this error and cause the matter to be investigated, corrected and reconciled without any resulting loss.

The recording, resolution, reporting and escalation of any near misses should broadly follow the same process as any other operational risk event, even if no actual loss occurs in practice. When details of the near miss are reported to management, the full details of the incident need to be provided so that there is no misunderstanding as to how the event actually occurred. Companies need to establish a suitable reporting mechanism to avoid any misunderstandings; this may be incorporated in practice as part of regularly supplied management information (MI).

It is important to record and incorporate near misses in the operational risk reporting mechanisms because they help to give a complete overall picture of the incidence of risk and its resolution. Near-miss events provide a clear indicator of failed or inadequate controls as well as affording the institution the opportunity to put suitable controls in place before a recurrence of the risk event.

## End of Chapter Questions

Think of an answer for each question and refer to the appropriate section for confirmation.

1. **What are the four root causes of operational risk?**

*Answer Reference: Section 1.1*

2. **What is project risk?**

*Answer Reference: Section 1.3.4*

3. **Name six results of operational risk within a business.**

*Answer Reference: Section 2.1.1– 2.1.2*

4. **What are the potential effects of delayed processing and documentary omissions?**

*Answer Reference: Section 2.2*

5. **What are the potential effects of fraud or theft?**

*Answer Reference: Section 2.2*

6. **What are the potential effects of unforeseen litigation?**

*Answer Reference: Section 2.2*

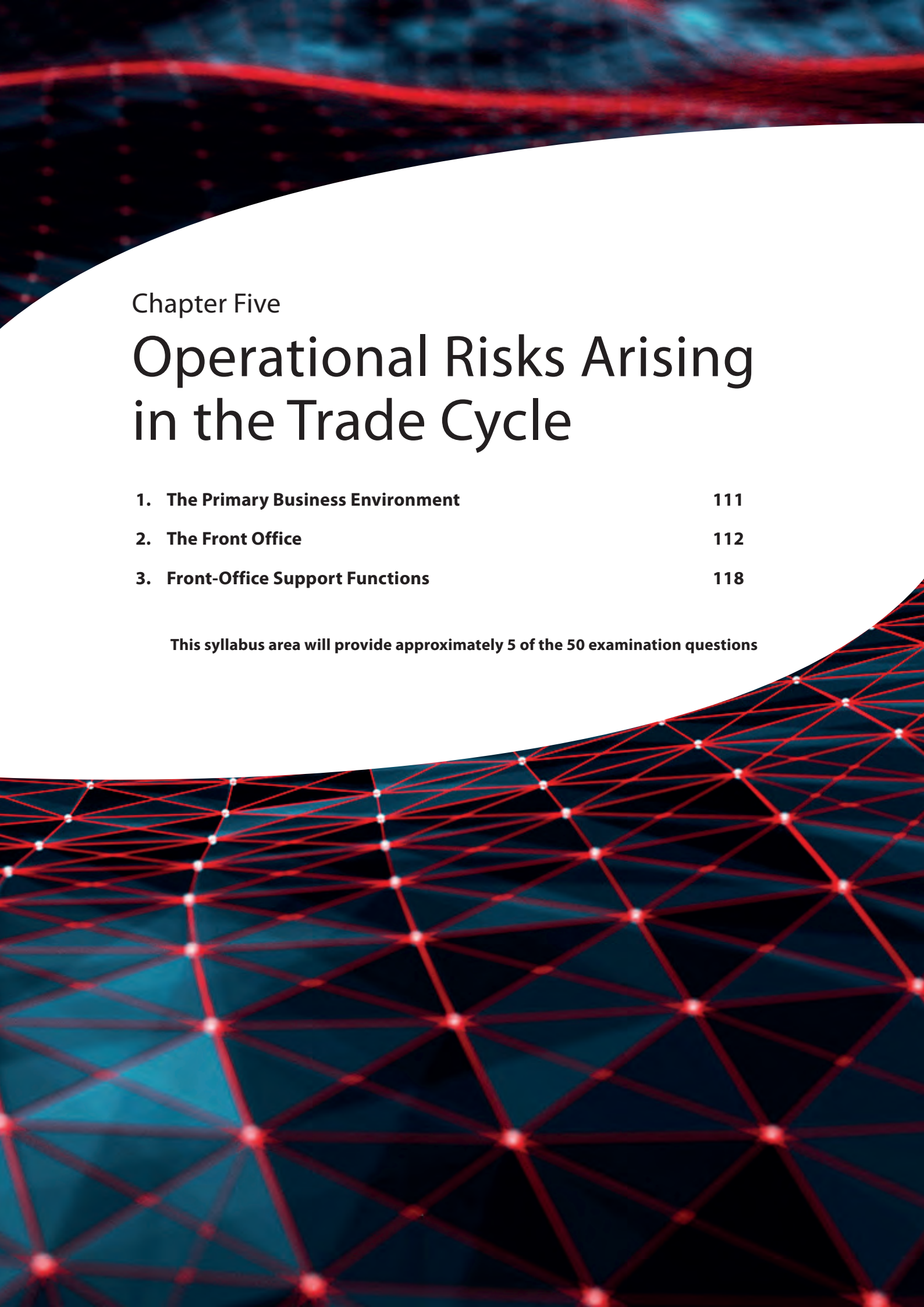
7. **What are the potential effects of technology failures?**

*Answer Reference: Section 2.2*

8. **What is the definition of a near miss in an operational risk context?**

*Answer Reference: Section 3*





## Chapter Five

# Operational Risks Arising in the Trade Cycle

|                                            |            |
|--------------------------------------------|------------|
| <b>1. The Primary Business Environment</b> | <b>111</b> |
| <b>2. The Front Office</b>                 | <b>112</b> |
| <b>3. Front-Office Support Functions</b>   | <b>118</b> |

**This syllabus area will provide approximately 5 of the 50 examination questions**





## 1. The Primary Business Environment

A financial services company is logically broken up into three parts:

- the front office includes sales and trading personnel, investment managers and corporate finance
- the middle office supports the front office and acts as a point of control, which may include control over an outsourced provider, and
- the back office (or operations) provides administrative and support services.

At every stage during the operations processes, there is potential exposure to an array of different risks. Systems must be designed and personnel trained to allow the institution to be continuously alert to these risks and to detect, prevent and measure them. The exact nature of risks can vary according to the business and service type, but many aspects are common.

The primary business environment comprises the areas that are most closely associated with revenue generation and processing activities. It consists of various functions: the front office and related support functions. These are explained in more detail in the following sections.

## 2. The Front Office

### Learning Objectives

- 5.2.1 Understand the role and responsibilities of the front office
- 5.2.2 Understand the nature of the key risks, controls and indicators in the front office: transaction capture; exchange of transaction instructions; monitoring position and credit limits

---

The front office of a financial institution is where trading and investment decisions take place. It is populated by the firm's revenue-earners. These are the traders, fund managers, salespeople and market risk managers.

Only authorised employees in the front office can commit the firm to a contract, and a clear distinction must be drawn between staff having the status of traders or dealers (who provide the actual execution of the trades or deals) and trade support staff (support functions who assist in order handling and the provision of quotations/prices to the client – see section 3).

The revenue-earners are interested primarily in making a profit for the firm, and generally have most involvement in the transaction life-cycle up to the point of transaction execution (ie, the commitment of funds). After this point, the administration of the transaction is conducted by the support staff.

Revenue-earners will monitor transactions throughout their life in order to manage market risk (implicit in the daily profit & loss (P&L) calculation) and may also be involved in specific issues or problems, such as dealing with sensitive clients or making decisions on complex transactions.

The roles within the front office will vary from one organisation to another, and so will the associated responsibilities. For example, a fund manager may be responsible for making investment decisions in accordance with the fund's investment restrictions, whereas a dealer may be responsible for the best execution of a trade.

### 2.1 Risk and Control

Some of the most serious operational risk issues (eg, fraud, exceeding credit limits, and point-of-trade errors) occur in the front office. Front offices must, therefore, have effective control and management procedures in place. Also, they will have several key risk indicators (KRIs), as defined in chapter 3, section 5.3.5.

Some typical controls will cover the following aspects:

- Ensuring that an effective **segregation of duties** is in place between trading and support functions, such as the front office, operations, accounting and risk monitoring.
- Having clear **escalation procedures** in place covering all key risks, such as exceeding agreed limits.
- Ensuring adequate **research** has been carried out before dealing in a new product, portfolio or counterparty. This may include, for instance, the production and authorisation of a detailed business plan.



- Controlling new **market and credit limit requests** and ensuring they are adhered to.
- Effective **capital requirement** reporting and details relating to the usage of capital.
- Conducting continuous **limit reviews** in order to maintain the firm's risk appetite. For instance, counterparty credit limits may be reviewed at set intervals or whenever there is an adverse material change in either their financial status or market.
- Ensuring effective control over **front-office systems**, including reference data, computer models, spreadsheets and algorithms. This is particularly important when complex mathematical models are used involving 'chaining' of calculations, so that the output from one calculation is used as the input for another, or when there are no easily devised plausibility checks possible on the results of the model.
- Ensuring **after-hours trading** is properly defined and controlled.
- Tightly controlling **dealing tickets** and ensuring they are processed quickly and efficiently, eg, numbering them consecutively, using timestamps and transmitting them immediately to the settlement department after they have been produced in the dealing room.
- Continuously updating **positions**. Dealers should always know the value of their long, short and net positions, as well as the value of any hedge relating to a position.
- Maintaining **high ethical standards** by having effective procedures in place to ensure that:
  - there is no trading at off-market rates, or at rates which deviate from prevailing market levels
  - dealing only occurs within the dealing room, unless specifically authorised otherwise
  - there is client confidentiality in accordance with data protection principles
  - trading errors are immediately reported and dealt with, and
  - compliance rules are followed, particularly with respect to the rules of conduct and entertainment, and ensuring that token gifts are not excessive and are only accepted in accordance with rules.

When setting up operational risk management processes in the front office, appropriate risk indicators are chosen to monitor the effectiveness of these controls such as the number of limits breaches, system availability and dealing ticket processing times.

## 2.2 Accepting New Customers

### Learning Objectives

- 5.1.1 Understand what tasks must be completed during set-up: marketing and sales; Know Your Customer; international sanctions; suitability; account set-up; reference data; credit assessment; standard settlement instructions; legal contract negotiation; client and counterparty agreements
- 5.1.2 Understand the key risks, controls and indicators associated with the set-up phase

In this section, we will look at the various tasks that need to be completed during the client set-up, or onboarding stage. Improving the client onboarding process is an important factor in their ability to attract and retain clients. Client on-boarding will encompass several checks, including Know Your Customer (KYC), account set-up, operational and systems set-up, and credit risk reviews. Client onboarding also includes the periodic review, account maintenance and off-boarding of clients.



If a firm is advising a retail customer, or acting as an investment manager, or arranging a pension opt-out or transfer for a retail customer, it must take reasonable steps to ensure that it is in possession of sufficient personal and financial information relevant for the services that the firm has agreed to provide. This could include information about income, other assets, outgoings, age, investment objectives and attitude towards, and understanding of, risk. Potential customers may also be credit-checked to confirm that they may be accepted as customers. They may also be sent a 'terms of business' letter or may need to complete and return a client agreement letter.

There are a number of considerations firms must take into account when accepting new customers to ensure that it is able to serve them appropriately and in line with the regulatory requirements placed upon them:

- **Marketing and sales** – the UK regulators have very specific rules regarding how investments should be marketed, particularly to retail customers. Some of these rules require advertisements to be clear, fair and not misleading; certain minimum amounts of information to appear in the advertisement; and contact details of the advertising firm to be included. Further, the regulator has rules relating to cold-calling and record-keeping.
- **Know your customer (KYC)** – KYC is conducted prior to transacting with a client and forms a key part of an organisation's onboarding controls. It also needs to be refreshed periodically; the regulator's penalties for non-compliance with KYC requirements can be severe. KYC requirements are essential to an institution for three reasons:
  - It forms a key part of anti-money laundering (AML) controls by helping to prevent the introduction of illegal funds into the financial system as well as preventing terrorist financing.
  - KYC is central to the firm's ability to give proper advice as without up-to-date knowledge of the customer, their circumstances and objectives, it becomes difficult to make sure that strategy and product recommendations are suitable and meet their needs.
  - Client requirements change throughout their lifetimes; vulnerable customers, in particular, may require additional support as a result of bereavement, job loss, health- or mental health-related issues, all of which could impair decision-making or the client's ability to make payments (eg, insurance premiums or loan repayments). Firms are required to ensure that they are able to identify vulnerable customers and to engage with them in a way which is appropriate to their circumstances. Strong KYC procedures are at the heart of this.
- Consequently, the rules require that the firm takes 'reasonable steps' to gather information about the customer. This is commonly done using a KYC fact-finding questionnaire, which may be supplemented by personal identification, address history or confirmation of the source of funds (for example, if making an investment or obtaining a mortgage). In the UK, the Financial Conduct Authority (FCA) has issued requirements in its Handbook for firms to abide by.
- **International sanctions** – are political and economic decisions made by countries against specific countries, organisations or individuals to protect the national interest or international law. These sanctions vary from economic sanctions placed on a country to financial sanctions placed on organisations or individuals which may pre-empt the provision of financial services. It is, therefore, important that firms are able to implement controls to ensure that they are not transacting on behalf of a sanctioned entity or individual. In the UK, It is a criminal offence not to comply with a financial sanction unless you have an appropriate license or authorisation from the Office of Financial Sanctions Implementation, and regulators expect firms to have appropriate systems and controls in place to comply with financial sanctions obligations.

- **Suitability** – it is very important that the needs of the client are ascertained and taken into account before advising and dealing with them so that the firm can help meet these needs and objectives with the products and services that it is planning to offer them. These requirements will need to be reviewed and checked on a regular basis to ensure that they remain valid under the FCA's suitability requirements. The firm will need to collect certain reference data (see below for further details). Information relating to 'soft facts' will also need to be obtained from the customer, eg, 'If the market were to fall significantly tomorrow, would you see that as an opportunity or a threat?' The reply to such questions will help the firm determine the client's acceptable level of risk exposure.
- **Account set-up** – certain details relating to the customer will need to be recorded by the firm and the correct customer classification must be applied on the firm's internal records.
- **Reference data** – also called 'standing data' or 'static information'. This includes details to be recorded by the firm, eg, customer's name, address, contact details, or investment objectives. These details need to be rechecked by the firm on a regular basis so as to ensure they are still correct.
- **Credit assessment** – the firm may also need to carry out credit reference searches on potential customers and counterparties to assess their financial standing.
- **Standard (or standing) settlement instructions (SSIs)** – this includes details of how customers will pay for their investment purchases and how they wish to receive their settlement monies when selling investments.
- **Legal contract negotiation** – this includes agreeing terms and conditions by the legal department within the business that may be used in client or counterparty agreements and terms of business.

The table below illustrates examples of some of the key risks, potential mitigating controls and risk indicators associated with the set-up phase that firms could employ to monitor the risks associated with the onboarding of new clients.

| Key Risk                                                                                                                                                                                                                                                                                                                          | Controls                                                                                                                                                                                                                                                                                                                         | Risk indicators                                                                                                                                                                                |
|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Marketing and sales</b> <ul style="list-style-type: none"> <li>• Marketing may not comply with regulatory requirements.</li> <li>• Products and services may be marketed to unsuitable client group (ie, high complexity, high risk products being offered to retail clients without appropriate risk disclosures).</li> </ul> | <ul style="list-style-type: none"> <li>• Screening and approval workflows for all marketing materials to ensure that they meet regulatory requirements.</li> <li>• Contact database which is cross referenced against marketing campaigns to prevent products or services being marketed to unsuitable client groups.</li> </ul> | <ul style="list-style-type: none"> <li>• Number of customer complaints.</li> <li>• Contact by the regulators (in response to marketing, or the provision of products and services).</li> </ul> |

| Key Risk                                                                                                                                                                                                                           | Controls                                                                                                                                                                                                                                                                         | Risk indicators                                                                                                                                                                                                                   |
|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Know Your Customer</b> <ul style="list-style-type: none"> <li>KYC or AML requirements not met resulting in regulatory censure.</li> </ul>                                                                                       | <ul style="list-style-type: none"> <li>Appropriate trained staff with experience of KYC and AML requirements.</li> <li>Clear, documented procedures for onboarding a client, including what documents are acceptable.</li> <li>Ongoing training and periodic testing.</li> </ul> | <ul style="list-style-type: none"> <li>Number of new clients.</li> <li>Number of clients from high risk jurisdictions.</li> <li>Training pass rates.</li> <li>Number of risk events or near misses related to KYC/AML.</li> </ul> |
| <b>International Sanctions</b> <ul style="list-style-type: none"> <li>Non-compliance with the sanctions is a criminal offence.</li> <li>Reputational damage.</li> </ul>                                                            | <ul style="list-style-type: none"> <li>Reconciliations of client data against sanctions lists.</li> <li>Reconciliations of assets held per jurisdiction against sanctions jurisdictions.</li> </ul>                                                                              | <ul style="list-style-type: none"> <li>Number of clients who appear on an official sanctions list.</li> <li>Number of assets held in sanctioned companies or jurisdictions.</li> </ul>                                            |
| <b>Politically exposed persons (PEPs)</b> <ul style="list-style-type: none"> <li>Non-compliance with the money laundering and terrorist financing regulations resulting in regulatory censure.</li> </ul>                          | <ul style="list-style-type: none"> <li>Robust controls to identify all PEPs within the client population.</li> <li>Enhanced Due Diligence (EDD) processes to ensure that the increased level of risk has been understood and addressed.</li> </ul>                               | <ul style="list-style-type: none"> <li>Number of PEPs.</li> <li>Number of PEPs where EDD remains outstanding.</li> </ul>                                                                                                          |
| <b>Suitability</b> <ul style="list-style-type: none"> <li>Advice provided or products sold may not be suitable for clients and the firm could find itself liable to pay compensation to clients for loss or wrongdoing.</li> </ul> | <ul style="list-style-type: none"> <li>Peer reviews prior to issuing a suitability letter to ensure that all products and services are suitable for the clients needs.</li> <li>Independent suitability reviews.</li> </ul>                                                      | <ul style="list-style-type: none"> <li>Number of complaints.</li> <li>Number of clients where suitability reviews are incomplete or overdue.</li> <li>Value of compensation or redress.</li> </ul>                                |
| <b>Account set up</b> <ul style="list-style-type: none"> <li>Incorrect or incomplete account set up could result in clients receiving products or services that are not suitable.</li> </ul>                                       | <ul style="list-style-type: none"> <li>Peer review quality checks.</li> <li>Dual keying.</li> <li>Independent quality review.</li> </ul>                                                                                                                                         | <ul style="list-style-type: none"> <li>Number of accounts set up.</li> <li>Number of missing data fields.</li> <li>Number of risk events or near misses related to account set up.</li> </ul>                                     |

| Key Risk                                                                                                                                                                                                                                                                                                                                                                                                | Controls                                                                                                                                                                                                                                                                                                                                                                     | Risk indicators                                                                                                                                                                                           |
|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Reference data</b> <ul style="list-style-type: none"> <li>Incorrect reference data could result in a poor client experience or increase the risk of regulatory breaches or fraud (eg, a letter containing sensitive information is sent to a clients old address and is then used fraudulently to access their account).</li> </ul>                                                                  | <ul style="list-style-type: none"> <li>Periodic screening of client contact details against external data (including the use of 'gone-away tracing' and 'living as stated' services).</li> <li>Robust internal controls to respond to items marked as 'return to sender' to prevent further communications being sent until a verified address has been provided.</li> </ul> | <ul style="list-style-type: none"> <li>Number of letters marked as 'return to sender' following a marketing campaign or mailshot.</li> <li>Reference data reconciliation exceptions.</li> </ul>           |
| <b>Credit assessment</b> <ul style="list-style-type: none"> <li>If the credit assessment process is not robust, this could increase the risk of default.</li> </ul>                                                                                                                                                                                                                                     | <ul style="list-style-type: none"> <li>Clear credit risk policy.</li> <li>Robust credit assessment processes.</li> <li>Ongoing monitoring of account statuses.</li> <li>Regular review of credit assessment against historic loss data.</li> </ul>                                                                                                                           | <ul style="list-style-type: none"> <li>Number of client defaults.</li> <li>Value of client defaults.</li> </ul>                                                                                           |
| <b>Standing settlement instructions</b> <ul style="list-style-type: none"> <li>If SSI's are incomplete or missing then this information will need to be provided manually, increasing the risk of errors or omissions; furthermore this could delay money being receive from clients to fund purchases which would result in the firm having to use its own resources to complete the trade.</li> </ul> | <ul style="list-style-type: none"> <li>Periodic review of SSI data for completeness.</li> <li>Reconciliation of internal SSI against 3rd party data sources.</li> <li>Peer reviews (four eye checks). on all manual settlement information before it is sent to the counterparty.</li> </ul>                                                                                 | <ul style="list-style-type: none"> <li>Number of missing SSIs.</li> <li>Number or value of late transactions (due to missing SSIs).</li> <li>Value of corporate funding (due to missing SSIs).</li> </ul> |

| Key Risk                                                                                                                                                                                                                                                                                                          | Controls                                                                                                                                                                                                                                                                                  | Risk indicators                                                                                                                                                                        |
|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Legal contract negotiation</b> <ul style="list-style-type: none"> <li>Agreeing bespoke legal clauses with clients may require additional monitoring to ensure compliance to the legal terms; this becomes increasingly complicated where firms have multiple contracts with non-standard agreements</li> </ul> | <ul style="list-style-type: none"> <li>Stringent exception processes whereby bespoke clauses need to go through an approval process</li> <li>Database of bespoke clauses</li> <li>Mapping document of bespoke arrangements against controls to ensure these are being provided</li> </ul> | <ul style="list-style-type: none"> <li>Number of non-standard agreements</li> <li>Number of contractual breaches</li> <li>Legal claims of redress due to breach or contract</li> </ul> |

### 3. Front-Office Support Functions

#### 3.1 Pre-Settlement Phase

##### Learning Objectives

- 5.3.1 Understand the components of the pre-settlement phase: transaction capture; trade confirmation; asset and cash positioning; centralised clearing; calculation of collateral
- 5.3.2 Understand the key risks, controls and indicators associated with the pre-settlement phase

The front-office support functions (sometimes referred to as control functions) ensure that trade information from the front office passes smoothly and accurately into the position-keeping and settlement systems in the pre-settlement phase. In most organisations, these post-trade activities take place within the operations department, and generally involve the capture of transactions in the front-office systems and trade **confirmation processes**.

##### 3.1.1 Transaction Capture

**Transaction capture** is the process that ensures that all transactions are recorded accurately within the firms books of record. Operational risk can arise from errors or delays in transaction capture and processing, resulting in incorrect hedging, funding and settlement of the trade as well as impacting the accuracy of regulatory reporting.

KRIs might include:

- trends in the volume of transactions compared with the percentage handled manually
- the number of errors detected by reconciliations
- the time taken to detect and resolve the errors, and
- the number of transactions not captured within a specific time from trade execution.

Key controls might include:

- implementing straight-through processing (STP) through system integration or automation (a preventative control)
- daily sign-off of front-to-back positions (an internal detective control), and
- funding position reconciliations (an internal detective control).

5

### 3.1.2 Trade Confirmation

Transactions are confirmed with clients and counterparties prior to settlement and as close to the trade day as possible. The prime aim of this activity is to ensure that the other party recognises the transaction and that there is agreement with respect to the key legal, economic and settlement terms. It also allows for discrepancies to be quickly identified and resolved.

Trade confirmations are made in a 'durable medium', typically they will be provided electronically although other methods exist; their format is usually agreed through a legal agreement signed by the two parties involved as part of the set-up activity. For some products, such as listed derivatives and others that use a central counterparty (CCP), confirmation can involve a high degree of automation and is being performed electronically. For other products, such as some uncleared over-the-counter (OTC) derivatives, confirmations are performed as part of a bilateral agreement using hard copy documents that are largely standardised. This standardisation helps reduce the risk of error and legal ambiguity and allows firms to design processes assuming consistent inputs.

Operational risk exists due to the possibility of disputes of transaction details, confirmation errors or delays when confirming trades, all of which could result in the counterparty defaulting without the firm having legal recourse.

KRIs might include:

- length of time taken to formalise a legal agreement
- number and type of confirmation errors found in the checking process
- number of confirmations not yet agreed with the counterparty, and
- time taken for counterparties to return confirmations.

Key controls might include:

- ensuring that a legal agreement covering confirmation protocol is in place prior to trading (a preventative control)
- a confirmation checking function performed by a different person to the creator (an internal detective control)
- front office sign-off of the economic terms of the confirmation (an internal detective control), and
- follow-up actions to counterparties that have not returned written confirmations (an internal detective control).

### 3.1.3 Asset and Cash Positioning

The asset and cash **positioning process** ensures that there is sufficient stock or cash available at the time of **settlement** to fulfil the settlement of a contract. Operational risk exists because positioning is part of an overall inventory management process in which firms strive to make the most efficient use of their resources. This means that stock and cash are continually being recycled and used in a way that will generate the maximum return for the firm. Because of this dynamic process, there may be insufficient assets available when they are required.

This leads to two potential consequences:

- settlement being delayed exposing the firm to interest claims, potential fines and reputational damage
- higher borrowing costs as, in order to ensure settlement, a firm may have to borrow cash or securities at a higher cost than would otherwise be necessary.

KRIs might include:

- the number of transactions missing the internal funding deadlines
- the number of late-settled transactions due to a lack of funds
- extra cost of borrowing to ensure settlement.

Key controls might include:

- the use of internal funding deadlines for the confirmation and transaction instructions to be completed. These deadlines would allow enough time for the funding and settlement activities to be completed (a preventative control)
- system limits to warn users that there are insufficient assets available to cover an upcoming settlement (a detective control).

### 3.1.4 Centralised Clearing

The use of a centralised clearing system such as using a central clearing counterparty (CCP) is a means practised on several exchanges and other structures globally to reduce credit risk. Futures and options exchanges around the world have adopted a central clearing house system, and the same approach has been applied to securities exchanges and to other markets (including energy contracts and OTC derivatives).

The clearing house acts as a CCP, or guarantor of contracts, for the market and products concerned. By this means, the clearing house assumes the credit risk, thereby limiting the exposure of its clearing members by protecting them from the potential impact of the default of others. A leading UK CCP is **LCH** and in the US, the CME Group also acts as a CCP and clearing house.

Rather than being involved in a direct counterparty-to-counterparty contract (and so assuming each other's credit risk), the clearing house acts as the CCP to each. If one clearing member defaults, the clearing house will guarantee the performance of the contract to the other.

In order for clearing houses to be credible in their ability to reduce credit risk, they need to have significant financial resources to cope with potential major market default events and scenarios. They obtain these resources in a variety of ways, such as capital supplied by:

- their members
- their share capital and reserves
- the exchange, or
- other parties that do not have a direct relationship with the economics of their market.

For example, LCH has a series of sources providing financial backing. The major tranche of this support, which is next in line after clearing member margin cover held, is the member default fund, to which every clearing member contributes in cash (interest-bearing) according to the volume of its clearing activities and size of open position. This contribution is reviewed and adjusted every three months.

Since the clearing house takes on the credit risk of all trades, it must manage the risk effectively. This is done through stringent membership requirements, continuously reviewing the financial status of existing members, and employing position monitoring and margining. Position monitoring is the analysis of an individual member's exposure risk in relation to their ability to cover their margin liabilities and delivery obligations. This is performed on an intra-day basis. Margining refers to the practice of evaluating the risk to the clearing house of a member's position and making collateral calls to insure against the risk of the member's default.

### 3.1.5 Calculation of Collateral

Collateral has already been discussed in chapter 2 of this workbook. Collateral provides protection in the form of security against the possibility of payment default by one or more of the parties associated with a particular trade or trades. Collateral can be accepted in a wide range of forms, including cash, government securities, letters of credit, equities and other measures. Collateral management relates to the notification and verification of collateral transactions in order to reduce the level of credit risk. It will take into account the calculation, delivery and receipt of the collateral in order to meet margin calls.



Two principal types of margin are taken into account by the clearing house when calling for margin at the start of the day's trading:

- **Initial margin** – which reflects the typical worst-case scenario of a one-day price move on all registered open positions.
- **Variation margin** – based upon a **mark-to-market** calculation at the previous day's closing prices which reflects the profit or loss on all registered open positions.

## 3.2 Settlement, Post-Settlement and Asset Servicing Phases

### Learning Objectives

- 5.4.1 Understand the components of the settlement phase: payment instructions; payment receipts; securities transfers and custody
- 5.4.2 Understand the key risks, controls and indicators associated with the settlement phase
- 5.5.1 Understand the components of the post-settlement phase: reconciliation; inventory management; margin/collateral management
- 5.5.2 Understand the key risks, controls and indicators associated with the post-settlement phase
- 5.6.1 Know the main types of corporate action: dividend and coupon payments; redemption of fixed-income securities; rights issues; stock buy-backs; takeovers and mergers; conversion of convertible bonds; proxy voting
- 5.6.2 Understand the main risks associated with corporate action processing: missed announcements; complex structure of information and instruction flows between participants; late election; incomplete or incorrect information or instructions

Traditionally, operations departments (also referred to as back office) exist to process and settle transactions throughout the lifecycle of a trade. Their objectives are to:

- monitor the life of a transaction through to settlement, ensuring that key events are flagged and acted upon when necessary
- fulfil the settlement, payment and other actions in respect of each transaction and position held
- provide the transaction, position and cash movement information used for the accounting function.

Typical activities within this function include:

- transaction instruction
- settlement, and
- **reconciliation**.

### 3.2.1 Payment Instruction

Transaction instruction is the process of agreeing delivery instructions with a third party. For exchange-traded products (ETPs), a clearing house or clearing agent will fulfil this function on behalf of the market participants using a clearing system. For OTC transactions, the process will often involve a bilateral written or verbal agreement between the transacting parties.

As stated in section 2.2, in order to perform the transaction instruction activity effectively, firms will hold SSI data for most of their counterparties. This allows the automation of the instruction process, as SSI details are received when the counterparty is first set up in operational systems. In some cases, and for some products, SSI details are not available when the settlement date approaches and a separate transaction-specific instruction must be used. This introduces additional risk.

Automated trade confirmation and matching systems (which link trading organisations with custodians and other counterparties) are commonly provided by third-party systems vendors. One example is the OMGEO service provided by the Depository Trust & Clearing Corporation (DTCC).

In order to reduce the chances of error and improve process efficiency, the transaction instruction stage can sometimes be combined with the confirmation stage, whereby a single combined transaction confirmation and instruction is sent.

Risks and controls are similar to the **confirmation process** described above.

### 3.2.2 Settlement

Settlement in securities operations is the physical delivery of an asset in exchange for an equivalent amount in cash or payment receipt. The main operational risk is that the preceding steps in the process break down, resulting in settlement failure or delay. This is exacerbated in markets that do not employ true delivery versus payment (DvP) systems.

A risk indicator that measures the quality of the overall process is the number of times a firm settles late, but this could also be affected by market influences.

### 3.2.3 Post-Settlement

**Post-settlement** refers to the stage immediately after the trade has settled as per the previous section. This stage will typically include reconciliation and inventory management, along with margin and collateral management. It also includes financial, management and regulatory reporting as covered in chapter 6 of this workbook.

The firm has a duty of care to ensure that its customers' trades are carried out in accordance with their instructions and it is the firm's responsibility to make sure that the customer is treated fairly at all times. This requirement extends into the post-settlement phase as well.

### 3.2.4 Reconciliation

Firms will reconcile their records and positions of the trades after the trades have settled in order to make sure that the correct amounts of assets and cash and assets were exchanged and that there is no shortfall. Firms will reconcile as often as they need to with respect to customer assets held in custody in order to demonstrate to the regulator that they have treated their customers fairly.

**Reconciliation** is an accounting/control function which ensures that the firm's record of cash and stock movements (the 'internal world') is accurate and, furthermore, agrees with its statement of balance and holdings (the 'external world'). It is a key detective control that ensures that the differences are identified and resolved in a timely manner. It forms part of the post-settlement phase in the lifecycle of a trade.

Reconciliation controls are typically applied to provide checks against a wide range of records, such as cash, stock or (depot) accounts, collateral, margin, dealing positions, client money and custody accounts.

The volume of unreconciled events (or breaks) is commonly used as a risk indicator to assess the quality of the **transaction capture** and processing activity. The more errors a firm detects when reconciling its many positions after the settlement date has passed, the higher the level of risk the firm may be exposed to. Reconciliation errors will involve more staff time in trying to resolve the issues, leading to lower levels of productivity.

The amount or value of reconciliation breaks is an important KRI, along with the amount of time spent by staff and other resources in rectifying the discrepancy. Other KRIs include the amount of overtime being worked by the reconciliations team, the monetary cost of this overtime and any other associated costs, for example, fines imposed by regulators for not following the correct reconciliation procedures or not reconciling records on time. Unreconciled positions may also involve the payment of interest or compensation claims to parties that have been disadvantaged.

### 3.2.5 Inventory Management

Inventory management involves how a firm keeps records of its customers' stock and cash movements. For example, if it uses an electronic system to record these details, then the firm must ensure that the system is sufficient for this purpose.

### 3.2.6 Asset Servicing

Asset servicing is an essential part of the post-settlement phase and includes monitoring and responding to events which affect companies and their underlying shareholders. These events are known collectively as 'corporate actions' and need to be monitored and managed on an ongoing basis in order to mitigate the associated risk (which is covered later in this section). There are several types of corporate action that could take place, including the following:

- **Dividends and coupon payments** – these represent the income element of holding equities (also called shares and common stock) and fixed-income securities (eg, bonds), respectively. Both dividends and coupons are usually paid at a predefined frequency and can be a fixed or variable amount depending on the security type.

- **Redemption of fixed-income securities** – most fixed-income securities have a maturity date attached to them upon their creation at which point the principal (the capital element) will be returned to the investor.
- **Rights issues** – these are issues of shares that are offered at a discounted price by a company to its shareholders in proportion to their existing shareholding. If a shareholder chooses not to take up a rights issue, they can usually sell the rights to another investor.
- **Stock buy-backs** – also known as share repurchase schemes or, simply, share repurchases, these involve the company buying back its own shares from its shareholders. This is usually done in one of two ways:
  - through purchasing its own shares on the open market, or
  - through a tender offer where its investors are (usually) offered a premium to sell a proportion of their shares back to the company.

Whichever method is used, this has the effect of increasing the relative value of the remaining shares for shareholders.
- **Takeovers and mergers** – where a company puts in a bid to take over another company, typically by attempting to buy the shares in the target company to obtain a majority shareholding thereby gaining control of the company. The main difference between a takeover and a merger is that in a merger both companies are in agreement to combine the two existing companies into one new company whereas in a takeover this is not always the case.
- **Conversion of convertible bonds** – convertible bonds can be converted into a specified number of shares, usually at a predetermined price. This gives the investor the flexibility to move away from the fixed-income bond into an equity position in the same issuing firm.
- **Proxy voting** – most equities carry voting rights, essentially providing an investor with the ability to vote on important decisions at shareholder meetings. Many investors choose to delegate voting on their behalf to another individual or organisation rather than personally attend the shareholder meeting; this is known as a proxy vote.

Owing to the complexity of corporate actions, there are several risks to which securities firms are exposed that give rise to the need to have appropriate controls in place, including good quality and timely information feeds on corporate actions. This gives firms time to respond appropriately and in line with client instructions.

The main risks associated with corporate actions processing fall into two categories – financial, where clients or counterparties claim compensation as a result of errors and omissions, or reputational, where client or market relationships are damaged, potentially resulting in the loss of future business. There are a number of risk events associated with the processing of corporate actions, including the following:

- **Missed announcements** – a large proportion of stocks are held by asset managers and if an announcement is missed then it is likely that the underlying client will not have had the opportunity to respond.
- **Complex structure of information and instruction flows between participants** – the complexity of asset servicing is further increased in a global marketplace, particularly where there are many market counterparties, such as brokers, investment managers, custodians, subcustodians and transfer agents. Timing differences and different methods of communication all increase the possibility of error.

- **Late elections** – corporate actions have a deadline associated with them; failure to respond within the deadline can result in financial loss for the underlying clients. Many corporate actions will have a default option. Failing to respond in time usually triggers a default election; this may be contrary to the client's wishes.
- **Incomplete or incorrect information or instructions** – this can result in the information or instruction being rejected, or the wrong election being made; this could result in even greater financial loss, for example, if the firm acted contrary to client instructions in error.

Where a corporate action has been processed in error, such as an incorrect instruction, it can be harder to place a financial value on the error and this may damage the client relationship.

With the increasing focus on environmental, social and governance (ESG) criteria, some organisations are holding positions in securities purely to influence the decision-making of the underlying firms to bring about positive change. Proxy voting essentially helps to steer management in the right direction from an ESG perspective (eg, reducing carbon emissions, improving working conditions, and separation of powers on the board respectively). An alternative to voting is shareholder engagement, whereby shareholders (as partial owners of a business) may enter into dialogue with management to encourage behavioural change and address serious ESG issues.

### 3.2.7 Margin and Collateral Management

Margin or collateral is an asset held by a lender on behalf of an obligor, under certain agreed conditions, as a form of security for a loan perhaps. It can be in the form of cash, securities or a physical asset. It is a form of insurance to reduce the amount of credit exposure (or credit risk) to a particular counterparty. The lender may retain the margin or collateral if the obligor defaults. The management of margin and collateral forms part of the pre- and post-settlement phases of the lifecycle of a trade.

The value of any margin or collateral held during the transaction instruction and settlement phases will need to be closely monitored to ensure that it remains sufficient to cover the potential exposure should one party default on their obligations. The value of any margin or collateral held will be marked to market, ie, compared against the current price of the asset in the relevant market. The value of margin or collateral held will, in practice, be monitored on a daily basis, either on an end-of-day basis or an intra-day basis and any shortfall in the value will need to be notified to the obligor so that additional margin or collateral may be requested and supplied.

A 'margin call' is the request for additional funds when a margin account falls below the minimum requirement to be deposited. The need for a margin call will typically arise as a result of an adverse change in the value of the asset or contract.

Whenever the firm has less cover for margin or collateral than it requires, it is exposed to potential risk.

New trades may be processed without a problem and may settle on their intended settlement date. However, sometimes the trade may not settle in accordance with the market practice applicable, leading to possible brokers' claims, payment of interest or compensation along with decreases in the level of customer satisfaction. These results of poor post-settlement processes can be used by firms as KRIs to assist them in monitoring the level of operational risk that they are exposed to.

### 3.2.8 Record-Keeping

Financial regulators around the world have set high-level rules for records that are maintained by authorised firms within their jurisdiction. For example, in the UK, the FCA requires firms to arrange for accurate records to be kept of their business and their internal organisation, including all services and transactions undertaken by them. The medium for holding records is not prescribed, but the records should be capable of being reproduced in English and on paper. This includes a requirement to provide a translation if the records are retained in a language other than English. Records do not need to be readily accessible, but must be capable of being retrieved within a suitable timescale to meet the needs of the firm, its customers and the regulators.

The general principle for retention periods for records is that they should be retained for as long as relevant to the purposes for which the record was made. However, in addition to these high-level requirements, there are more specific record-keeping rules pertaining to certain types of business (the rules are outside the scope of this particular syllabus). While the exact length that records must be retained depends on the products involved, generally all records of transactions must be kept for at least five years in the UK.

Firms will most probably have software systems that will be used to capture, manage, store, preserve and deliver records relating to organisational processes and customer records. The management of records is of growing importance for the financial services sector in order that firms meet regulators' requirements and also those of the firms themselves.

## End of Chapter Questions

Think of an answer for each question and refer to the appropriate section for confirmation.

**1. What is a firm's front office?**

*Answer Reference: Section 2*

**2. Give six examples of controls that may be used in a front office to reduce risks.**

*Answer Reference: Section 2.1*

**3. Give three examples of key risk indicators (KRIs) that may be used by the front-office support functions when capturing transactions.**

*Answer Reference: Section 3.1.1*

**4. What is positioning?**

*Answer Reference: Section 3.1.3*

**5. What is the main reason for the existence of clearing houses?**

*Answer Reference: Section 3.1.4*

**6. What are the three objectives of a typical operations department?**

*Answer Reference: Section 3.2*

**7. What is transaction instruction?**

*Answer Reference: Section 3.2.1*

**8. What does settlement within securities operations?**

*Answer reference: Section 3.2.2*

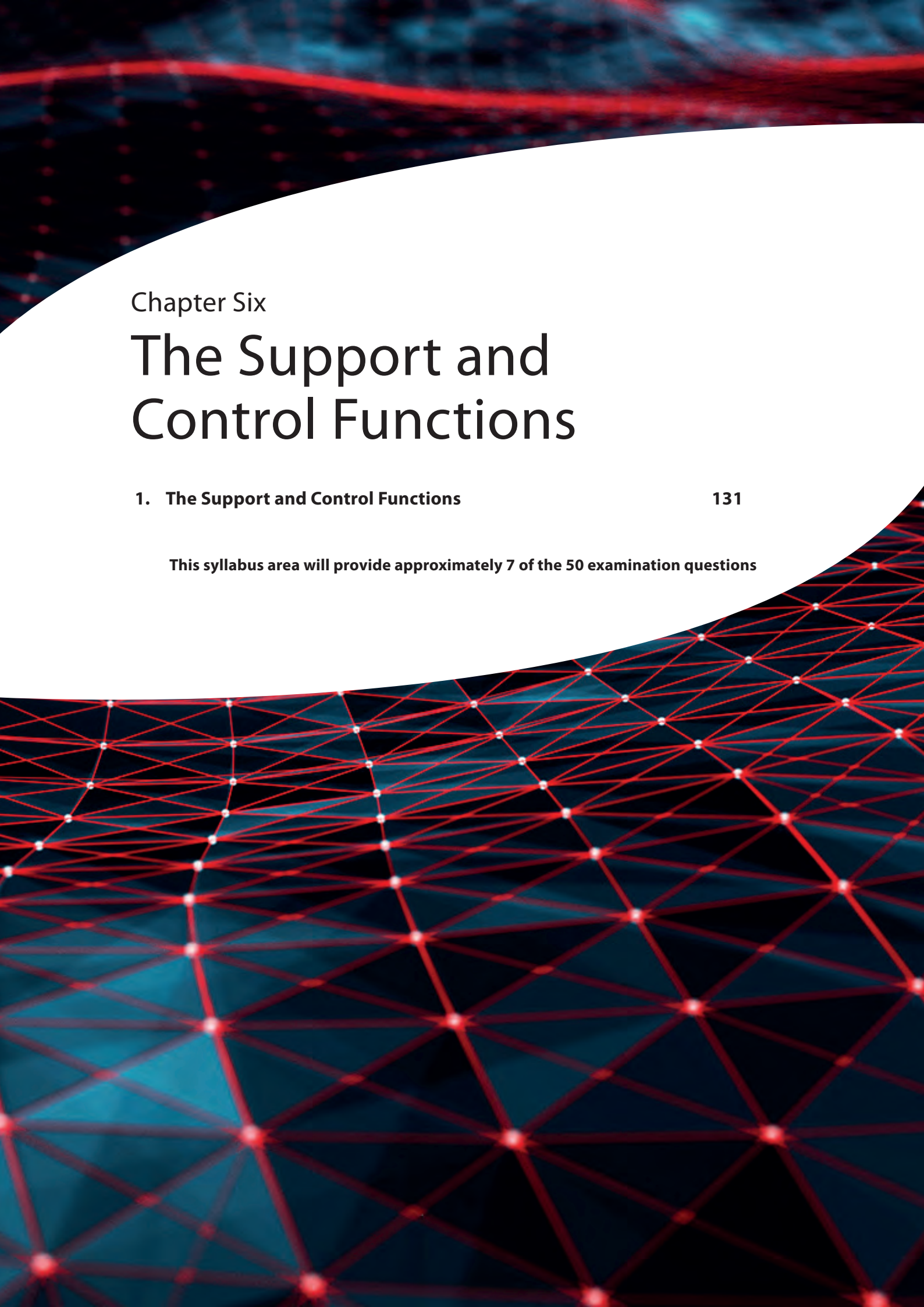
**9. Name three types of corporate actions?**

*Answer reference: Section 3.2.6*

**10. Why does a financial services firm need to manage the amount of margin or collateral that it holds?**

*Answer Reference: Section 3.2.7*





## Chapter Six

# The Support and Control Functions

### 1. The Support and Control Functions

131

**This syllabus area will provide approximately 7 of the 50 examination questions**







## 1. The Support and Control Functions

There is a wide variety of support and control functions within a typical firm and a number of these are covered in this section along with their various responsibilities and how they may be involved with managing operational risk. It is worth noting that while the syllabus specifically refers to these areas of the firm, there may be in practice additional areas (or functions) of the firm that may also exist to cover other activities. In practice, some of these may be absorbed within the functions covered below. Some other areas of responsibility for the firm will include those dealing with business continuity, health and safety, information security and physical security.

### 1.1 Risk Governance

#### Learning Objectives

- 6.1.1 Understand how risk governance is established in financial institutions: the role of the Board of Directors; the role of the Board Risk Committee; the role of the Chief Risk Officer (CRO)

#### 1.1.1 The Board of Directors

The chief executive officer (CEO) is the highest-ranking individual member of staff within a company. The CEO will typically advise and report to the board of directors who set the CEO's responsibilities, which may be either quite limited or extensive. They will be responsible for making high-level decisions relating to strategy and policy within the organisation and for the executive team in the day-to-day operation of the firm.

The board of directors is a group of individuals who have been appointed into their roles and will jointly oversee the various activities of the company; collectively, they are often referred to as 'the board'.

Their roles and responsibilities are detailed in the constitutional documents of the company.

Some members of the board will be executives and others, typically the majority, will be independent or non-executive.

The board will have many responsibilities, including:

- overseeing the firm
- establishing board policies, strategy and objectives
- reviewing risk and setting risk appetite with a management approach
- appointing the CEO
- ensuring the firm has sufficient financial resources
- approving annual budgets for the organisation, and
- agreeing the salaries of senior management.

The board is accountable to the shareholders of the company.

In terms of the governance of a firm, responsibility is essentially divided between the board of directors and the shareholders. In smaller companies, these may be the same people in practice. Ensuring that the board operates effectively is essential in any well run organisation; in the US, the Sarbanes-Oxley Act 2002 introduced new standards of accountability for the boards of all companies that have a listing in the US, and directors potentially face large fines and imprisonment if they are found guilty of accounting-related crimes.

### 1.1.2 The Board Risk Committee

The board risk committee has the responsibility of providing oversight and giving advice to the board of directors in relation to identified risk exposures of the organisation, including both current and potential risks, future risk strategy, and the levels of risk appetite and risk tolerance of the organisation. While board risk committees have long been common to large firms, smaller firms are less likely to have them in their organisation. The activities of the CRO (see section 1.1.3) are typically overseen by the board risk committee.

### 1.1.3 The Chief Risk Officer (CRO)

The chief risk officer (CRO) is responsible for ensuring the efficient and effective governance of risks that are deemed to be significant at the firm while ensuring that the firm operates in full compliance with the applicable rules and regulations. CROs are accountable to the executive committee and the board of directors at the firm. In larger firms, they are often responsible to a risk committee and are usually responsible for implementing the firm's ERM approach. Forming an enterprise-wide view of risk across the organisation will require the agreement of a number of different areas in a financial firm, given the level of understanding that the CRO needs to have, and the willingness of a department to provide key data and avail themselves and their people to a greater level of oversight, which may or may not be welcome.

The role of the CRO became more common after the Basel Accord and the Sarbanes- Oxley Act (see chapter 7). This senior position entails enabling the organisation to balance risk and reward.

The increasing number of CROs being appointed within financial services represents a key area of development for risk management. While very important in times of financial stress and trouble, the perceived importance of this role may be diminished during more profitable parts of the economic cycle. It is important to note that not all firms are required to appoint a CRO or to have the governance structure noted above in place, this is an expectation of FTSE 100 firms and larger institutions such as banks and insurance companies; however, smaller firms may choose not to based on their risk profile or complexity.

## 1.2 Middle and Back Offices

### Learning Objectives

- 6.2.1 Understand the role and responsibilities of the middle and back office functions in managing operational risk

A financial services company is logically broken up into three parts:

- the front office includes sales and trading personnel, investment managers and corporate finance
- the middle office supports the front office and acts as a point of control, which may include control over an outsourced provider, and
- the back office, generally referred to as 'operations', provides administrative and support services.

At each stage during the operations processes, there is potential exposure to an array of different risks. Systems must be designed and personnel trained to allow the institution to be continuously alert to these risks and to detect, prevent and measure them. The exact nature of risks can vary according to the business and service type, but many aspects are common.

The middle office is responsible for helping manage operational risks that the firm may be exposed to. It will have systems in place to ascertain and assess the types of clients the firm has, their risk profiles and their risk requirements, as not all clients have the same wants and needs. Before the date is passed to the back office, the middle office ensures that due diligence is correctly carried out:

- ensuring that trades are correctly booked onto the various systems and that all procedures are being correctly followed by traders, salespeople and other related business functions
- monitoring existing trades, which may involve making amendments for rate re-fixes, processing trade unwinds and assignments of existing positions and also overseeing collateral management
- revaluing portfolios, including the maintenance and verification of market data inputs and daily and monthly profit and loss calculations
- reporting profit and loss positions, risk and process metrics
- providing a point of contact as well as a point of control over an outsourced provider (further information on outsourcing can be found in section 8.4 in chapter 3).

Often, monitoring corporate actions and ensuring proper response from traders or investment managers is also a function carried out by the middle office.

The back office (or operations) refers to the administration and support personnel in a financial services company. It carries out functions such as settlement, clearing, record maintenance, asset servicing and interface with regulatory compliance and accounting.

By managing these activities expertly, it helps to manage operational risks by ensuring that the correct settlement instruction information is added to the trade, that the trade is correctly confirmed and affirmed, and that the trade settles correctly on its intended settlement date. The back office ensures that:

- actual exchanges and deliveries of money and assets between the firm and its various counterparties are arranged, monitored, verified and fulfilled
- settlement instructions are rigorously maintained and checked
- flows between cash **nostro accounts** and deposit accounts at securities depositories are correctly managed.

The various participants in the financial markets, including banks, brokers, fund managers, regulators and clients, all require transparency for there to be orderly and efficient markets. Regulators state that details of each trade, whether a buy or sell order, must be reported to the market, which, in turn, makes the trade details public, while complying with client confidentiality rules. The market is usually represented by an exchange. Trade-reporting regulations require firms to report details of the trades, including such aspects as the date of the deal, the time of the deal, the price of the deal, the volume traded, the stock traded and the identifier of the firm transacting the deal. Trade reporting takes place in near-real time via an approved publication arrangement (APA).

Transactions need to be reported to the relevant regulators and trade repositories for different reasons. Transaction reporting is needed by regulatory authorities in order to identify possible instances of market abuse and the data is not made available to other market participants. Transaction reporting takes place generally within one business day after the date that the trade was made and is referred to as 'T+1', where the 'T' stands for trade date. Specialist-reporting service provider companies, referred to as approved reporting mechanisms (ARMs), are approved by the regulator for this purpose.

Firms must ensure that they comply with the regulatory authorities and will set up their own reporting functions whose responsibility it will be to ensure that both trade reporting and transaction reporting is carried out in accordance with these rules.

## 1.3 Compliance

### Learning Objectives

- 6.3.1 Understand the role and responsibilities of the compliance function in relation to operational risk
- 6.3.2 Understand the impacts of compliance risk

Compliance with regulatory requirements and ethical conduct standards is a major concern to boards of directors and senior executives because they are held accountable and personally liable for violations. In a complex and decentralised business environment, corporations must institute consistent, firm-wide compliance policies and procedures to prevent litigation and reputational damage and meet shareholder accountability demands.

Under the UK Markets in Financial Instruments Directive (UK MiFID), which was adopted in 2007, it is a requirement for sufficiently large firms, to have an independent and permanent compliance function. This independent function must have sufficient authority and be structured, resourced and operated effectively. In smaller firms, compliance with regulation is also mandatory and the use of external compliance support services may be utilised to meet regulatory requirements.

The compliance function may not be directly responsible for the ethical issues of the firm, but, in practice, they typically will be charged with the oversight of the compliance arrangements within the firm (including the firm's adherence to regulatory requirements as well as internal policies), advising the business in respect of compliance issues, providing training on regulatory requirements and internal policies across the firm, managing regulatory breaches and ongoing reporting to the firm's governing bodies in respect of their oversight of the firm's regulatory compliance ie, the firm's compliance risk.

### 1.3.1 Compliance Risk

**Compliance risk** (or **regulatory risk**) is the risk to earnings or capital arising from violations, or from non-conformance with laws, rules, regulations, prescribed practices or ethical standards. It exposes the firm to fines, payment of damages, the voiding of contracts and reputational damage (with its accompanying indirect costs).

Compliance risk is intimately tied up with operational risk because it is often the breakdown in processes, procedures and a weak control culture that allows compliance risk to be realised. For example, compliance risk may arise if:

- product-related legal regulations are not complied with
- due diligence is not observed
- clients' interests are not protected, or
- the firm engages in market abuse or product mis-selling.

The compliance function in a firm exists to combat this risk. This function defines the programmes and processes and their related accountability. Its objectives are to ensure:

- **Good corporate governance** by defining the way the board of directors and senior executives execute and govern the company's overall compliance strategy and ethical mission.
- **Organisational integrity** through the development of ethics and integrity programmes. These define the training and communication programmes and related accountability processes (such as a self-assessment process) that exist to motivate, measure and monitor the organisation's ethical performance.
- **Regulatory compliance** by defining the programmes and processes that measure and monitor the extent to which the organisation adheres to existing laws, regulations, industry guidelines and general business norms or conventions.

In many firms, the compliance function is also one of the top-level internal policy-makers for risk control across all functions and covers key areas of market, credit and operational risk. When operating successfully, the compliance role balances the limiting effects of necessary controls with the empowerment of the workforce to operate within clear boundaries (which may be enforced by other functions).

The policies and procedures that the compliance function generates are designed to meet these objectives and to provide direction and clarity to the firm's employees. Its responsibilities are wide, covering all aspects of the business and interacting with all of the firm's functions.

These responsibilities may typically include:

- **Good practice** – the compliance function keeps abreast of good practice in the industry and the recommendations of the regulators. It ensures that the following are incorporated into the firm's policies:
  - advice for business units on regulatory issues
  - compliance monitoring
  - communication with the regulatory authorities and reviewing regulatory policy initiatives
  - routine compliance duties such as staff registration and staff dealing approval.
- **Regulatory reporting requirements** – this covers the reporting of required information to the relevant regulators. Compliance will ensure the firm sets policies for requirements such as:
  - financial accounts
  - client money and client asset returns
  - lists of authorised traders, counterparties and products
  - transaction and position reporting.
- **Employee conduct** – the compliance function will ensure that employees are provided with clear guidelines and training reflecting law, industry regulations and the firm's expectations. Issues that would be addressed include:
  - insider dealing and other forms of market abuse
  - acceptance of gifts
  - client entertainment
  - whistleblower protection
  - conflicts of interest
  - relationship with competitors

- relationship with the media
- confidentiality, and
- money laundering.

### 1.3.2 The Impacts of Compliance Risk

The impacts of regulatory non-compliance can vary based on the nature of the breach, scale of the breach, consumer impact and (potentially) the actions taken by the firm to mitigate the breach. Regulators can censure both firms and individuals in a number of ways including:

- private warning
- public censure
- fines
- restrictions on taking on new business
- removal of regulatory permissions
- individual bans, and
- criminal prosecution.

The firm may also have to pay damages, incur remediation costs, and reputational damage may occur, all of which could materially impact the firm.

## 1.4 Financial Reporting and Regulation

### Learning Objective

- 6.4.1 Understand the role of the financial reporting and regulatory function in the context of the operational risk environment

The financial reporting and regulatory function exists to ensure that the firm's assets, liabilities, and profit and loss (P&L) are accurately compiled and reported on their financial statements.

**Accounting risk** is the risk of inaccurate financial reporting. Its effects are poor management decision-making (based on incorrect information) and regulatory non-compliance. These effects can lead to the consequences of direct and indirect loss such as fines and penalties.

Accounting errors can also conceal already realised losses. These can often go undetected for a long period as they become lost among other problems and causes.

The financial reporting and regulatory functions perform both internal reporting and external reporting:

- **Internal reporting** is performed to assist management decision-making and is concerned with assessing the daily profitability of the firm (the P&L).
- **External reporting** is performed to satisfy legal and regulatory requirements to report financial accounts.



Operational risk is inherent in the policies, processes or procedures that ensure accurate financial reporting. If these break down, accounting risk can be realised; for example:

- Traders misreporting a transaction's details in the trading book to make it appear more profitable. The key control is to validate front-office positions on a daily basis as part of the daily reporting function. This is done by reconciling front-office positions (the trader's view of the world) with the back office positions (which, when the transactions have settled, should represent the external view of the world). Some firms call this activity the 'product control function'.
- Misreporting accounts because of complex aggregation rules. Financial institutions usually report internally by trading book because information is collected at the trader's book level in order to assess trader performance. However, they are required to report externally at a legal entity level. For this reason, the financial reporting systems need to aggregate information to the entity and group level. While this might seem a simple process in theory, in practice, it can prove very difficult due to poor system integration and the lack of an overall view of the business (both of which are operational risks).
- A trader is focused on the future – ie, trying to predict what a market will do – while the accounting function focuses on the past, ie, ensuring that what has been traded is accurately reported. This can occasionally create a tension between the front office and the accounting function. The intention must be to develop a good relationship, to foster open communication and to avoid operational difficulties.
- Changing accounting standards in the industry can lead to confusion in the interpretation of regulations and reporting requirements.
- Mergers and acquisitions can exacerbate accounting risk by adding to the fragmentation of the business view. It takes time for a company to understand the full financial details of the merged company and to incorporate these efficiently into the financial reporting of the new firm.

## 1.5 Human Resources (HR)

### Learning Objective

#### 6.5.1 Understand the role of the HR function in the context of the operational risk environment

Operational risk exists throughout the human resources (HR) process. Among other things the HR function is responsible for:

- recruiting new employees
- company-wide employee engagement initiatives
- compensation and benefits
- employee retention programmes
- implementing and overseeing performance management systems
- instituting and monitoring policies and current HR regulations
- establishing and maintaining a formal policies and procedures manual, incorporating benefits for employees, and
- maintaining employee records.

In addition, there may be instances where the HR function supports business strategy and initiatives, such as mergers and acquisitions which may involve aspects such as employee assessments, salary reviews and benchmarking. There may also be some legal aspects such as the Transfer of Undertakings (Protection of Employment) Regulations 2006 (TUPE) or observing employee consultation requirements laid out in legislation. In recruiting new employees, HR must also consider how potential hires fit with, and affect, the culture of the firm, as this is important to how well the operational risk is managed.

## 1.6 Internal Audit

### Learning Objectives

- 6.6.1 Understand the role of the internal audit function in relation to operational risk
- 6.6.2 Know the requirements of the MiFID directive in respect of the internal audit function

Internal audit represents the third line of defence within an organisation and plays an important role in the risk control framework. It provides an independent, internal assessment of the effectiveness of the firm's controls and procedures. It also independently assesses the effectiveness of the risk management process.

Under MiFID, it is a requirement for each firm to have an 'independent internal audit function' if it is appropriate and proportionate. This internal audit function must again have sufficient authority and be structured, resourced and operated effectively. To maintain their independence the internal audit function will usually have a reporting line into the audit committee of the board of directors. The independent periodic review of all transaction lifecycle activities is an important safeguard for senior management in ensuring the integrity of the internal control structure. It also ensures that management information systems are operating effectively through independent testing and validation.

By performing reviews, internal audit assesses control effectiveness, questioning whether an institution's processes and procedures are:

- adequately controlled
- up to date, and
- practised in accordance with manuals and documentation.

Internal audit must have an unrestricted mandate to review all aspects of the transaction life cycle and be totally independent of senior managers and their departments who are subject to the review. There is a crossover with the operational risk management process in that both involve the identification of risk issues. However, auditing focuses on checking the control environment on a snapshot basis (eg, once every six months), highlighting issues (audit points) and reporting, tracking and validating remedial action taken by the business. On the other hand, operational risk management monitors risk on a continuous, day-to-day basis, as part of the process allowing more dynamic and strategic management. Audit information should, therefore, be used as an input to operational risk management. Audit points can also be used as risk indicators.

Both internal and external audits can be powerful enablers of change. As part of the cultural change to a more risk-aware outlook, the company's desire to resolve audit issues can significantly raise the profile of the need for effective risk management.

## 1.7 Information Technology (IT)

### Learning Objective

#### 6.7.1 Understand the role of the IT function in the context of the operational risk environment

---

Operational risk exists throughout the IT process, from strategic decisions about IT, through managing projects, to design, implementation and maintenance.

The IT function is typically responsible for:

- maintaining an adequate day-to-day systems environment
- delivering strategic change solutions that meet the business needs.

The IT function is typically divided into four separate departments within a financial services firm:

- **support** – provide an on-call service that provides urgent assistance in the event of IT failures or problems
- **infrastructure** – responsible for the smooth provision of computer systems which run the day-to-day business, including information security and access control
- **architects** – involved in designing, developing, testing and implementing new systems, and
- **project managers** – control specific projects within the IT function involving budgeting, timing estimation and progress monitoring. They will also liaise between IT and the users of the systems, ie, the other business functions of the firm.

The technology causes of operational risk have already been explained in chapter 4, and the risk management responsibility for these causes sits within the IT function. In summary, its broad responsibilities include:

- highlighting and managing deficiencies in the design or operation of all systems that support the firm's activities
- protecting the organisation from system security issues such as viruses and hacking
- ensuring that information held on systems is secure
- ensuring system development keeps pace with rapidly evolving user requirements, and
- ensuring that systems integrate effectively, thereby minimising manual intervention and data integrity issues.

In addition to representing an area where risk must be managed, the IT function has also provided innovations for reducing risks within the firm. For example, banks are increasingly using new technologies such as artificial intelligence (AI) and machine learning (ML) for credit scoring and improving the performance of the loan book.

## 1.8 Legal

### Learning Objectives

- 6.8.1 Understand the role of the legal function in the context of the operational risk environment
- 6.8.2 Know the common legal areas where operational risk issues arise

Legal risk is the risk of loss due to legal issues brought about by an inability to enforce legal contracts, licences, ownership rights, patents or documents. Legal risk could also arise from inadvertently agreeing to contractual conditions, such as providing an indemnity to the contracting party, therefore, transferring the risk from the party to the firm. The legal function's role is to manage risk by ensuring that:

- contracts accurately represent the firm's intentions, and that
- contracts are enforceable and unambiguous.

To do so, this function must implement effective policies and procedures, the effectiveness of which depends on how well the operational risk issues are managed.

The legal function is critical at the **set-up stage** when legal agreements are negotiated prior to trading. Such agreements (which can be at the entity, product or transaction level) are designed to cover any legal eventuality that may reasonably occur, as agreed by the business line, during the course of the contract.

### 1.8.1 Operational Risk Impact

Some common legal areas where operational risk issues exist are:

- **Contract formation** – ensuring the appropriate legal documentation is in place and is satisfactory prior to trading. Getting the contract details right at the outset is one of the main responsibilities of the legal function. The best way to avoid legal risk is to produce contracts that are clear and rely on predefined, approved wording for consistency. This should be done in conjunction with advice from the relevant business area. This could also include decisions about the exact legal structures of various investment vehicles, which if not taken carefully can lead to everything from competitive disadvantage and low uptake by clients, to incurring unforeseen losses due to contradictory requirements or opaque risk controls.
- **Legal names** – confirming the counterparty's legal name helps to establish the legal, contractual rights of each party.
- **Jurisdiction** – law in one jurisdiction may not apply, or apply differently, in another.
- **Netting arrangements** – netting is used as a means of reducing credit risk. The terms or rules for netting must be contractually agreed and care must be taken to ensure enforceability.
- **Collateral arrangements** – ensuring that all collateral arrangements are legally enforceable and cover the assets intended.
- **Power to transact** – ensuring the counterparty has the legal power to transact, ie, that it is not acting beyond its legal authority – a term legally known as **ultra vires**.

- **Employee authority** – ensuring that the counterparty’s employees have the appropriate authority to transact on behalf of the firm.
- **Fiduciary responsibilities** – ensuring the fiduciary responsibilities of a firm are understood. A fiduciary is an individual, corporation or association holding assets for another party, often with the legal authority and duty to make decisions regarding financial matters on their behalf.
- **Client relationship** – ensuring the maintenance of an arm’s length relationship with the client (via the legal agreement) and disclosure of the relevant risks. There must be clarity between an arm’s length relationship and an advisory relationship.

## 1.9 Product Development and Marketing

### Learning Objective

- 6.9.1 Understand the role of the product development and marketing function in the context of the operational risk environment

The product development function deals with the creation of new, and also the adaptation or modification of existing, products and services that will offer customers new or additional benefits. Products or services may need to be developed to help satisfy a newly defined customer need in the marketplace or to compete with rival firms.

The product development and marketing functions play a critical role in linking sales, development, customers and potential customers of a business. Their responsibilities typically include:

- identifying customer needs and wants
- planning and creating ideas, goods or services to satisfy those needs and wants
- establishing pricing that results in profitable transactions
- promoting ideas, goods or services to an identified target market
- ensuring all promotional material is appropriate and compliant
- managing distribution and logistics strategies, and
- understanding competitors and the market fully.

The product development and marketing functions will also have a responsibility to ensure that the business does not grow too rapidly, which could result in the firm not having enough resources to cope with the increase in demand for its services, for example, an insufficiency of staff, IT systems or related infrastructure. This also needs to be balanced with having an optimum level of business to ensure survival.

Linked in with the product development and marketing functions will be a communications function (covering both external and internal communications) and an investor relations function.

## 1.10 Project Management and Change Management

### Learning Objective

- 6.10.1 Understand the role of the project management and change management function in the context of the operational risk environment

The project management team aims to bring about the successful completion of specific project goals and objectives. Where multiple projects are being managed in conjunction, this is referred to as 'programme management'.

The change management team ensures that any required changes are implemented in a controlled manner by following a predefined framework or model. The various operational risks faced by both of these functions will need to be identified and managed throughout the process.

Operational risk may increase during a transitional period; for example, as a result of a change in regulation, introduction of a new system, or a change in policy or procedure, particularly during the period where the change is still relatively new and unfamiliar. This risk can be increased further where the business areas affected have high workloads and low experience.

For example, a new system has been deployed and is being run in parallel for a period of time. During this phase, transactions are being keyed manually into both systems, resulting in higher workloads for the team affected. A reconciliation of the two databases identifies that key fields are being incorrectly populated in the new system. Further investigation identifies that this is due to a lack of training on the new system and an insufficient understanding of how these key fields are being used.

## End of Chapter Questions

Think of an answer for each question and refer to the appropriate section for confirmation.

**1. What is the role of the chief risk officer?**

*Answer Reference: Section 1.1.3*

**2. What is the difference between the middle office and the back office function?**

*Answer Reference: Section 1.2*

**3. What is compliance risk?**

*Answer Reference: Section 1.3.1*

**4. Name three objectives of the compliance function.**

*Answer Reference: Section 1.3.1*

**5. What three questions does the internal audit function seek to answer when performing reviews?**

*Answer Reference: Section 1.6*

**6. What is the difference between the role of the internal audit function and the role of the risk management function?**

*Answer Reference: Section 1.6*

**7. What is legal risk?**

*Answer reference: Section 1.8*

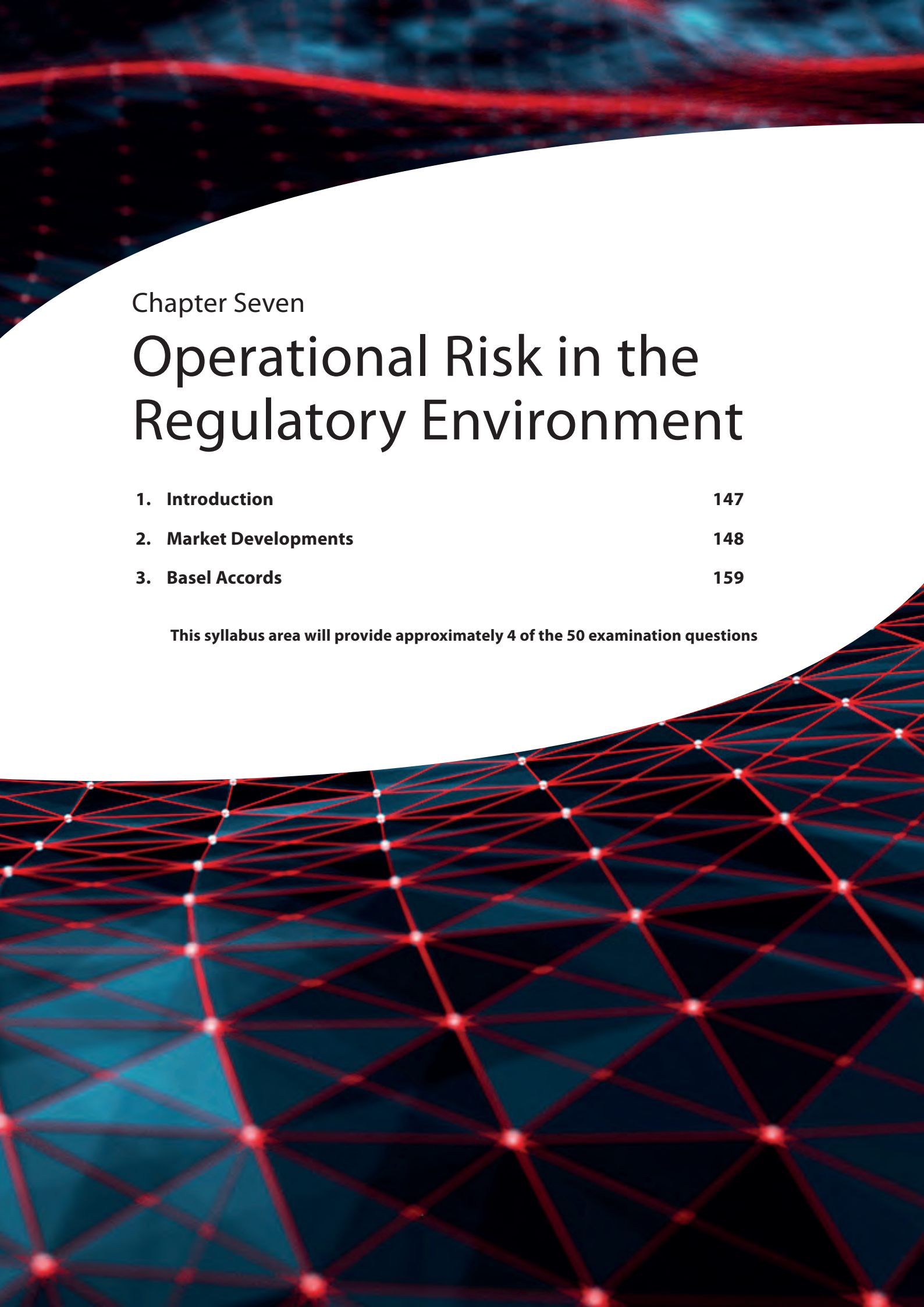
**8. What is the role of product development?**

*Answer reference: Section 1.9*

**9. What is the difference between the project management function and the change management function?**

*Answer Reference: Section 1.10*





## Chapter Seven

# Operational Risk in the Regulatory Environment

|                               |            |
|-------------------------------|------------|
| <b>1. Introduction</b>        | <b>147</b> |
| <b>2. Market Developments</b> | <b>148</b> |
| <b>3. Basel Accords</b>       | <b>159</b> |

**This syllabus area will provide approximately 4 of the 50 examination questions**







## 1. Introduction

This chapter describes the main events that have occurred in the development of standard practices and regulations with respect to operational risk management, culminating in the publication of the Basel Accords. Basel II included an explicit treatment of operational risk for the first time and represented a watershed in the drive for common standards and protection.

The operational risk area may sometimes appear relatively immature in some aspects of financial services and there remain practical difficulties in identifying and accurately assessing exposures. For this reason, standard methodologies have not yet found widespread agreement.

There are, however, guidelines for good practice which are available for firms to use.

These guidelines have evolved as a result of global research, surveys and investigation into the disparate methods of understanding, assessing and managing operational risk.

Such investigations have attempted to highlight the most promising and effective practices in the industry and have gradually developed a body of knowledge that can be called good practice.

## 2. Market Developments

### Learning Objective

- 7.1.1 Know how the following directives, regulations, codes and regimes impact operational risk: corporate governance; Sarbanes-Oxley; MiFID, MiFID II, MiFIR; Dodd-Frank; Foreign Account Tax Compliance Act (FATCA); conduct risk, General Data Protection Regulation (GDPR); Sustainable Disclosure Regulation (SDR); Digital Operational Resilience Act (DORA); Senior Managers and Certification Regime (SM&CR); Consumer Duty

As the acceptance of the importance of operational risk has grown, there has been a gathering momentum from international regulators to ensure that it is managed in an objective and consistent manner. There is now an accepted belief that it should be assessed separately from credit risk and market risk perspectives, and that regulatory capital should be provided for addressing operational risk separately.

The concepts for risk management have been developed by the industry to the point where several reasonably sophisticated techniques are now being employed. However, there is no commonly accepted approach, nor is there a convincing argument that there should be one. Unlike credit risk and market risk, operational risk involves the assessment and management of risks whose cause can lie outside a firm's control and whose effects are not capable of being limited or capped. In addition, each firm has a unique environment and a unique risk appetite, so it is becoming accepted that operational risk will be managed differently as a result. This is understood by the regulators and is being reflected in their new rules.

### 2.1 Corporate Governance

The UK Corporate Governance Code came into effect in July 2018 and was updated in January 2024; the updated code applies to companies listed on the London Stock Exchange for accounting periods from January 2025. The Code sets out high level expectations in relation to operational risk management and requires the board of directors to establish procedures to manage risks, oversee the internal control framework, and determine the nature and extent of the principal risks the company is willing to take in order to achieve its long-term strategic objectives.

The Code places high importance on the interaction between companies and their shareholders and is intended to improve corporate governance within the UK by improving standards and promoting transparency and integrity. The Code is broken down into five overarching sections:

1. Board leadership and company purpose.
2. Division of responsibilities.
3. Composition, succession and evaluation.
4. Audit, risk and internal control.
5. Remuneration.

Each of these sections is further supported by a number of related principles which can be found in table 7.1 below.

Table 7.1 – The 18 Principles of the Corporate Governance Code 2018

| The 18 Principles of the Corporate Governance Code 2018 |                                                                                                                                                                                                                                                                                                                                                                                                   |
|---------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Section                                                 | Principle                                                                                                                                                                                                                                                                                                                                                                                         |
| 1. Board leadership and company purpose                 | a. A successful company is led by an effective and entrepreneurial board whose role is to promote the long-term sustainable success of the company by generating value for shareholders and contributing to wider society. The board should ensure that the necessary resources, policies and practices are in place for the company to meet its objectives and measure performance against them. |
|                                                         | b. The board should establish the company's purpose, values and strategy and satisfy itself that these and its culture are all aligned. All directors must act with integrity, lead by example and promote the desired culture.                                                                                                                                                                   |
|                                                         | c. Governance reporting should focus on board decisions and their outcomes in the context of the company's strategy and objectives. Where the board reports on departures from the Code's provisions, it should provide a clear explanation.                                                                                                                                                      |
|                                                         | d. In order for the company to meet its responsibilities to shareholders and stakeholders, the board should ensure effective engagement with, and encourage participation from, these parties.                                                                                                                                                                                                    |
|                                                         | e. The board should ensure that workforce policies and practices are consistent with the company's values and support its long-term sustainable success. The workforce should be able to raise any matters of concern                                                                                                                                                                             |

| The 18 Principles of the Corporate Governance Code 2018 |                                                                                                                                                                                                                                                                                                                                                                                                                                    |
|---------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Section                                                 | Principle                                                                                                                                                                                                                                                                                                                                                                                                                          |
| 2. Division of responsibilities                         | f. The chair leads the board and is responsible for its overall effectiveness in directing the company. They should demonstrate objective judgement throughout their tenure and promote a culture of openness and debate. In addition, the chair facilitates constructive board relations and the effective contribution of all non-executive directors and ensures that directors receive accurate, timely and clear information. |
|                                                         | g. The board should include an appropriate combination of executive and non-executive (and, in particular, independent non-executive) directors, such that no one individual or small group of individuals dominates the board's decision making. There should be a clear division of responsibilities between the leadership of the board and the executive leadership of the company's business.                                 |
|                                                         | h. Non-executive directors should have sufficient time to meet their board responsibilities. They should provide constructive challenge, strategic guidance, offer specialist advice and hold management to account.                                                                                                                                                                                                               |
|                                                         | i. The board, supported by the company secretary, should ensure that it has the policies, processes, information, time and resources it needs in order to function effectively and efficiently.                                                                                                                                                                                                                                    |
| 3. Composition, succession and evaluation               | j. Appointments to the board should be subject to a formal, rigorous and transparent procedure, and an effective succession plan for the board and senior management should be maintained. Both appointments and succession plans should be based on merit and objective. They should promote diversity, inclusion and equal opportunity.                                                                                          |
|                                                         | k. The board and its committees should have a combination of skills, experience and knowledge. Consideration should be given to the length of service of the board as a whole and membership regularly refreshed.                                                                                                                                                                                                                  |
|                                                         | l. Annual evaluation of the board should consider its composition, diversity and how effectively members work together to achieve objectives. Individual evaluation should demonstrate whether each director continues to contribute effectively.                                                                                                                                                                                  |

| The 18 Principles of the Corporate Governance Code 2018 |                                                                                                                                                                                                                                                                                              |
|---------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Section                                                 | Principle                                                                                                                                                                                                                                                                                    |
| 4. Audit, risk and internal control                     | m. The board should establish formal and transparent policies and procedures to ensure the independence and effectiveness of internal and external audit functions and to satisfy itself on the integrity of financial and narrative statements.                                             |
|                                                         | n. The board should present a fair, balanced and understandable assessment of the company's position and prospects.                                                                                                                                                                          |
|                                                         | o. The board should establish procedures to manage risks, oversee the internal control framework, and determine the nature and extent of the principal risks the company is willing to take in order to achieve its long-term strategic objectives.                                          |
| 5. Remuneration                                         | p. Remuneration policies and practices should be designed to support strategy and promote long-term sustainable success. Executive remuneration should be aligned to the company's purpose and values, and be clearly linked to the successful delivery of the company's long-term strategy. |
|                                                         | q. A formal and transparent procedure for developing policy on executive remuneration and determining director and senior management remuneration should be established. No director should be involved in deciding their own remuneration outcome.                                          |
|                                                         | r. Directors should exercise independent judgement and discretion when authorising remuneration outcomes, taking account of company and individual performance and wider circumstances.                                                                                                      |

Source: *The UK Corporate Governance Code January 2024*

While this set of principles applies only to companies listed on the London Stock Exchange (LSE), private companies are also encouraged to conform; however, there is no requirement for disclosure of compliance with the Code in private company accounts.

## 2.2 Sarbanes-Oxley

Sarbanes-Oxley (SOX) is a very significant piece of US legislation that was enacted in 2002 following major corporate failures and accounting scandals. The principal purpose of the legislation was to protect investors by improving the accuracy and reliability of corporate financial reporting and disclosures. Firms in scope of the act are required to perform risk assessments designed to identify and mitigate risks relating to the organisations internal controls over financial reporting to ensure that financial statements are accurate.

Following sharp stock market falls in 2001, particularly the collapse of technology, media and telecom stocks that resulted in significant investor losses, the New York Attorney General conducted an investigation into the quality and impartiality of advice given by research analysts.

Serious conflicts of interest in the production of investment research were uncovered and US regulatory action therefore followed with the enactment of the Sarbanes-Oxley Act 2002. The Act brought in new rules relating to public company accounting, auditor independence, corporate responsibility and analysts' conflicts of interest. It also gave the US Securities and Exchange Commission (SEC) the power to regulate or to require securities associations and national securities exchanges to create rules to protect investors and the public interest. Subsequently, many more rules have been introduced, for example, the requirement that analysts now certify the truthfulness of their views and disclose if they have received payment for them.

The UK has its own version of SOX, known as UK SOX, which similarly focuses on robust internal controls and accurate financial reporting by requiring firms to implement robust risk assessments and internal audits, reducing the risk of financial misstatements and fraud.

## 2.3 MiFID, MiFID II and MiFIR

**The Markets in Financial Instruments Directive (MiFID I)** is a large piece of EU legislation affecting all financial firms in the EU and the UK. Coming into force in 2007, the main objectives of MiFID I were to increase competition and investor protection, in addition to levelling the playing field for market participants in financial services. This was significantly amended in 2018 by MiFID II and the **Markets in Financial Instruments Regulation (MiFIR)**, which was one of the most complex pieces of regulatory change the financial industry has ever seen.

In brief, MiFID II and MiFIR seek to enhance the protections offered by MiFID I, which has been criticised for not going far enough in order to protect investors. The key difference between them is that MiFID sets out the goals that EU member states should strive to meet, while MiFIR imposes rules that all countries must follow.

MiFID was transposed into the FCA Handbook upon its implementation. For MiFIR, this framework was transposed and implemented into UK law following the end of the UK's transition period with the EU, under the EU (Withdrawal) Act 2018 (as amended by the European (Withdrawal Agreement) Act 2020), in a process known as onshoring.

Initially, the degree of similarity between UK MiFID and EU MiFID, and between UK MiFIR and EU MiFIR, was high. However, the UK and the EU have since been making amendments to their respective MiFID and MiFIR regimes in order to address any aspects that they identified as not working effectively, such that the regimes are now diverging.

The implementation of MiFID had a significant impact on financial services regulation in the UK, how firms operate their businesses and the way they interact with their customers.

Most firms that fall within the scope of MiFID will also have to comply with the Capital Requirements Directive (CRD), which sets requirements for the regulatory capital that a firm must hold.

MiFID introduced the requirement for firms to have an independent risk management function, with sufficient authority and resources, and requires financial services firms to have an effective risk management policy in place, together with internal control mechanisms that are appropriate to each individual firm. Firms are asked to identify the risks relating to their activities, processes and systems and to set their risk tolerance level.

There were many changes for financial firms including client classification, best execution, information that is provided to clients, execution-only business, suitability and conflicts of interest.

The MiFID requirements for compliance and internal risk functions are broadly the same as the rules of the then UK financial services regulator, the **Financial Services Authority (FSA)**, that were already in place at that time, including:

- Firms must establish and maintain policies and procedures aimed at ensuring effective compliance.
- Firms must establish procedures that identify the risks associated with a failure by the firm to comply with its obligations.
- Firms must establish a monitoring programme to regularly assess and review any inadequacies or deficiencies arising in the firm's compliance and address any issues arising.
- Firms must have an independent compliance function (unless inappropriate or impractical to do so) which possesses the necessary authority and is structured, resourced and operated effectively.
- Firms must appoint a compliance officer who has the necessary authority and also the responsibility for the compliance oversight function.
- If appropriate and proportionate, firms must establish and maintain an internal audit function which is separate and independent.
- Firms must establish, implement and maintain adequate risk management policies and procedures which identify and set the tolerable level of risk relating to a firm's activities including employees' compliance with them.
- Firms must have a separate risk control function, if this is proportionate, depending on the nature, scale and complexity of its business. The risk function must document the organisation and responsibilities of the risk assessment function.

## 2.4 Dodd-Frank

The Dodd-Frank Wall Street Reform and Consumer Protection Act (more commonly known as the Dodd-Frank Act, or simply, Dodd-Frank) is a far-reaching piece of legislation in the US. It was enacted in July 2010 and was made law following the global financial crisis of 2007–08 with the aim of preventing another one by improving the level of accountability and transparency in the US financial system. It also aims to end the concept that a US firm is 'too big to fail' so as to protect the US taxpayer by ending the system of providing bailouts to struggling firms and also to protect consumers from abusive financial services practices.

One particular measure within Dodd-Frank requires that high-risk over-the-counter (OTC) derivatives, such as credit default swaps (CDSs), are regulated in the US by the SEC or the Commodity Futures Trading Commission (CFTC). The intention is that firms that take excessive risks can be identified and be brought to the attention of the US regulators before another major financial crisis occurs.



## 2.5 Foreign Account Tax Compliance Act (FATCA)

The Foreign Account Tax Compliance Act (FATCA) is US federal law that came into effect in 2010. It requires US persons, including those living outside the US, to report details of themselves and their non-US financial accounts to the US authorities on an annual basis. It also requires all non-US based financial institutions to examine their account holders in order to identify any US persons and then report details of their identities and their assets to the US Treasury.

FATCA requires firms to ensure that they have robust controls in place to report to the US tax authorities (IRS) and to ensure that the appropriate tax treatment has been applied to clients holding US assets. While FATCA reduces the risk of firms unknowingly facilitating tax evasion, the rules can be complex and rapidly evolving when dealing with clients from jurisdictions around the world, this complexity can itself lead to inaccuracies and errors in regulatory reporting which can lead to incorrect tax treatment for clients (and subsequent client dissatisfaction) as well as regulatory fines or withdrawal of qualified intermediary status for impacted firms.

## 2.6 Conduct Risk

Conduct risk can be described as a failure to successfully deliver fair outcomes to customers and is part of the overall risk, compliance and governance of financial firms. The FCA has not defined the term specifically, but has suggested that individual firms adopt their own definitions. Conduct risk failures could result in a regulatory enforcement or a fine.

Conduct risk has been closely linked to the FCA's Fair Treatment of Customers (FTOC) initiative. Initially called Treating Customers Fairly (TCF), FTOC looks at what a fair deal for retail consumers should actually mean and look like in practice. The FCA has defined six consumer outcomes to explain to firms what it believes TCF/FTOC should do for its customers:

1. Consumers can be **confident** that they are dealing with firms where the **fair treatment** of customers is central to the corporate culture.
2. Products and services marketed and sold in the retail market are designed to **meet the needs** of identified consumer groups and are targeted accordingly.
3. Consumers are provided with **clear information** and are kept appropriately informed before, during and after the point of sale.
4. When consumers receive advice, the **advice is suitable** and takes account of their circumstances.
5. Consumers are provided with **products that perform** as firms have led them to expect, and the associated service is both of an acceptable standard and as they have been led to expect.
6. Consumers do not face **unreasonable post-sale barriers** imposed by firms to change product, switch provider, submit a claim or make a complaint.

While there are similarities between conduct risk and TCF, conduct risk is considered to be wider in context. It is expected that conduct risk can broadly be managed in the same way that firms manage their operational risks. Many conduct risks may already be included as operational risks in the first place. Firms are expected to identify, measure, mitigate and monitor their conduct risks.

An example of a conduct risk might relate to the governance procedures around the products of a firm, ie, how they are created, considered, signed off, marketed and distributed, and reviewed on an ongoing basis.

## 2.7 General Data Protection Regulation (GDPR)

The **General Data Protection Regulation (GDPR)** came into force within the EU and the EEA in 2018 and was retained in domestic law within the UK as UK GDPR following the UK's departure from the EU. GDPR is designed to protect the rights of individuals (known as 'data subjects') in respect of their personal data. The regulation introduced the concept of a 'data controller' (the person or organisation responsible for the processing of personal data) who has the ultimate responsibility for the data, and a 'data processor' (the person or organisation processing the data on behalf of the data controller).

The GDPR also introduced the role of a data protection officer (DPO), an individual who has overall responsibility to ensure the organisation processes data in accordance with several principles, as highlighted below:

- Lawfulness, fairness and transparency
- Purpose limitation
- Data minimisation
- Accuracy
- Storage limitation
- Integrity and Confidentiality
- Accountability.

In the UK, the GDPR is regulated by the Information Commissioner's Office (ICO) and penalties for non-compliance can be up to £17.5 million or 4% of global turnover. FCA regulated firms can also be fined by the FCA for data protection failures where these overlap with the FCA principles of business, for example, in 2017 the FCA fined Equifax £11m for failing to secure UK consumer data on the basis that this was also a breach of the principles 3, 6 and 7 which was significantly higher than the £0.5m fine imposed by the ICO.

Globally, privacy laws have in recent years seen an increase in adoption across non-EU countries, such as Turkey, China and Canada, as well as a growing number of state-level privacy laws within the US.

## 2.8 Sustainable Disclosure Regulation (SDR)

The **Sustainable Disclosure Regulation (SDR)** framework was introduced in 2022, and is designed to enhance transparency and accountability regarding sustainability factors in financial markets. The key components introduced by SDR are as follows:

- **Sustainable investment labels** – to provide consistent labelling where assets meets specific green or ESG criteria.
- **Product-level disclosures** – including consumer disclosures to help retail investors understand the sustainability features of the product and detailed disclosures which require ongoing firm reporting against sustainability goals.
- **Detailed disclosures** – clear presale disclosures outlining sustainability features coupled with ongoing annual reporting.
- **Language restrictions** – helping to support investors in making decisions when comparing sustainable investments and preventing the use of green labelling unless specific threshold criteria has been met.
- **Nature-related disclosures** – encouraging firms to disclose nature-related risks and opportunities.

SDR provides a common taxonomy for sustainability and is expected to reduce greenwashing, (the practice where firms make false claims about the sustainability of their products) thus making it easier for consumers to compare the products and services of financial institutions on the basis of their environmental impact. The full implementation of SDR will continue until December 2026 where additional legal entity level disclosures will be introduced (for firms with assets under management of £5 billion) reporting the firms approach to managing sustainability risks and opportunities.

Within the EU, the **Sustainable Finance Disclosure Regulation (SFDR)** came into effect in 2021 and is also designed to improve transparency in financial markets for sustainable investment products (ie, financial products with an ESG focus). SFDR introduced mandatory disclosures for financial market participants in relation to the firm's consideration of its sustainability risks, and while SFDRs scope and disclosures are somewhat different to SDR it applies to non-EU firms marketing products within the EU.

## 2.9 Digital Operational Resilience Act (DORA)

The Digital Operational Resilience Act (**DORA**) was introduced by the European Commission in September 2020 and promotes a common set of standards to mitigate technology-related risks within financial institutions and improve operational resilience across the financial sector. Importantly, DORA recognises that financial institutions are often reliant on services provided by critical third parties, such as internet providers, cloud data storage providers and SAAS (software as a service) software providers. As such, the requirements of DORA extend to key non-financial third parties.

The objectives of DORA are designed to be achieved through five pillars:

- ICT risk management and governance
- ICT-related incident reporting
- Digital operational resilience testing
- ICT third-party risk
- Information sharing.

While being an EU regulation, DORA has a global reach as it also applies to all firms providing products or services to EU customers or EU firms which means that many non-EU based organisations will need to comply, including those who may not themselves be regulated such as FinTech or ICT firms.

## 2.10 Senior Managers and Certification Regime (SM&CR)

In the UK, the FCA and the PRA have introduced a range of policy changes with a view to improving individual accountability in financial services institutions. The most important of these is the Senior Managers Regime (SMR), whose main rules came into effect on 7 March 2016. The SMR's initial aim was to increase individual accountability within the banking sector; however, this has been extended to apply across all financial institutions.

The SM&CR is split into two parts:

The **Senior Managers Regime (SMR)** – the SMR focuses on the most senior individuals in firms who hold key roles or have overall responsibility for whole areas of relevant firms. It is the firm's responsibility to ensure each senior manager has a statement of responsibilities setting out the areas for which they are personally accountable, and to produce a firm responsibilities map that knits these together.

Senior managers also have a 'duty of responsibility', which means that they are required to take the steps, that are reasonable for a person in that position to take, to prevent a regulatory breach from occurring. As a result, firms need to ensure that:

- all senior managers are pre-approved by the FCA before conducting their role
- all senior managers have a statement of responsibilities detailing the areas for which they are accountable, and
- the firm has a responsibilities map that shows how accountability has been apportioned across the firm.

At the next level below the SMR is a Certification Regime, which applies to an even larger number of individuals within financial firms.

The **Certification Regime (CR)** – the CR applies to 'material risk-takers'. These are staff who pose a risk of significant harm to the firm or any of its customers (eg, staff who give investment advice or who administer benchmarks). Firms must have procedures in place to reassess the fitness and propriety of certified staff on an annual basis.

All other staff of financial institutions are expected by the regulators to comply with conduct risk. The only group to which these requirements do not apply are members of ancillary staff who are not directly employed in investment activity. There are thus three levels in the overall structure:

- Senior managers (Senior Managers Regime)
- other senior individuals (Certification Regime), and
- all other staff (the Conduct Rules).

The challenge for firms in this is that the regulators are effectively requiring the firms themselves to carry out their own fit and proper checks on individuals who work for them – particularly in regard to the Certification Regime. For senior managers above the level addressed by the SMR itself, the regulators are involving themselves in approving those individuals who are permitted to serve as board members in financial institutions.

The regulators believe that the rules will make it easier for firms and the regulators themselves to be clear about who is responsible for what. Clear individual accountability should improve standards and make firms easier to run and to supervise. Should things go wrong with firms it will allow senior managers to be held to account for any misconduct that falls within their area of responsibility. It will also hold individuals working at all levels within relevant firms to maintain appropriate standards of conduct.

Included into the formal Statements of Responsibility to be drawn up for each individual senior manager is that, even in the event that they leave a firm, they will still be held responsible after the event if things go wrong in the area of the firm for which they were responsible having left the firm.

In general, the Certification Regime applies to material risk takers – being staff who are subject to the Remuneration Code – and other staff who pose a risk of significant harm to the firm or any of its customers should they fail to carry out their duties correctly. In addition to these new regimes, new rules regarding whistle-blowing systems and controls are being adopted in order to promote a culture where people can speak out.

These rules came into effect in September 2016 and apply to deposit taking institutions, insurance firms and PRA designated investment firms or FCA regulated firms (solo regulated firms).

## 2.11 Consumer Duty

Consumer Duty came into force in the UK on the 31 July 2023 and is designed to improve client outcomes by setting high standards of consumer protection across financial services and requiring firms to put their customers' needs first. The duty consists of one overarching principle, three cross cutting rules and four outcomes:

The principle requires firms to: *'act to deliver good outcomes for retail customers'*.

The three cross cutting rules are behavioural standards that all firms must follow when dealing with customers:

- act in good faith towards retail customers
- avoid foreseeable harm, and
- enable and support retail customers to pursue their financial objectives.

The four consumer duty outcomes are designed to provide further areas of focus for firms to improve consumer outcomes:

- **Products and services** – ensuring that these are to be designed to meet the needs and objectives of a specified target consumer market.
- **Price and value** – to ensure that products and services provide fair value with a reasonable relationship between the price that consumers pay and the benefit that they receive.
- **Consumer understanding** – to ensure that firms communicate in a way that supports consumer understanding and equips customers to make effective, timely and properly informed decisions.
- **Consumer support** – to ensure that support is to be provided that meet consumers' needs throughout the lifetime of the product or service.

The Duty applies to all firms with a key role in delivering retail customer outcomes, including those with no direct customer relationship. The FCA expects firms to monitor their implementation of Consumer Duty on a ongoing basis and firms are expected to take immediate action to address any gaps identified in their implementation.

## 3. Basel Accords

### 3.1 Introduction

#### Learning Objectives

- 7.2.1 Know the basic requirements of the operational risk aspects of: Basel Accords; the Capital Requirements Directive
- 7.2.2 Understand the main operational risk features of the Basel Accords

#### The Basel Committee

Formed under the auspices of the Bank for International Settlements (BIS), the Basel Committee on Banking Supervision (BCBS) comprises representatives from central banks and regulatory authorities. Over time, the focus of the **Basel Committee** has evolved, embracing initiatives designed to address the regulatory supervision of banks and to promote uniform capital requirements so that banks from different countries may compete openly with one another.

Having set capital adequacy standards for banks in respect of credit risk since 1988, the Basel Committee began addressing the need for setting aside additional capital for both market risk and operational risk during the 1990s in response to market events including the Barings crisis and other high-profile cases. The original requirement for banks to hold capital of at least 8% of their risk-weighted assets has gradually been extended over the years. Market risk as a result of a value-at-risk (VaR) measurement was added to the capital requirement formula in 1996.

#### Basel II and the Capital Requirements Directive (CRD)

Published in 2004, the second Basel Accord (Basel II) updated the existing Basel I framework. A significant innovation of the revised framework was the greater use of assessments of risk provided by banks' internal systems as inputs to capital calculations. Basel II uses a 'three pillars' concept, which is covered in more detail in section 3.2 of this chapter.

In Europe, Basel II was adopted under the Capital Adequacy Directive (CAD). First issued in 1993, the CAD was a European directive that, as its name suggests, established uniform capital requirements applicable to both universal banks' securities operations and non-bank securities firms. Essentially, Europe was pursuing locally what Basel was pursuing globally.

#### Example

A universal bank would identify a portion of its statement of financial position (balance sheet) as comprising a 'trading book'.

Capital for the trading book would be held in accordance with the CAD, while capital for the remainder of the bank's statement of financial position would be held in accordance with the Basel Accord.

Europe developed the CAD at the same time that the Basel Committee was developing an amendment covering market risk for the Accords. While the two initiatives influenced each other, they were not completed simultaneously.

The Basel Committee's Risk Management Group set out some principles that provided a framework for the effective management and supervision of operational risk for use by banks and supervisory authorities when evaluating operational risk management policies and practices. The Committee realised that the exact approach for operational risk management chosen by an individual bank will depend on a range of factors – for example, its size, sophistication, and the nature and complexity of its business activities.

In 2006, the CAD was superseded by the Capital Requirements Directive (CRD). The CRD represents the EU's interpretation of Basel II, and the EU capital requirements for implementation by national regulators across member states are based upon the Basel II approach. Applying to all financial institutions (not just banks), the CRD aims to:

- have in place a comprehensive and risk-sensitive framework
- encourage and enhance risk management among financial institutions, and
- maximise the effectiveness of the capital rules in ensuring continuing financial stability, thus maintaining confidence in financial institutions and protecting consumers.

Note that the EU CRD is less prescriptive than Basel II.

With Basel II having formed the basis for the EU CRD, this provided the basis for new national rulebooks for all firms in the EU. Hence, in the UK (which was, at that time, still a member of the EU), the then regulator implemented the Basel II Accord via the CRD. Finalised Handbook changes appeared towards the end of 2006, with implementation from 2007.

Global implementation of Basel II began at the end of 2006 (individual country timetables varied), with full international implementation continuing well beyond that. Again, the new capital rules apply to all financial institutions, not just banks.

The process to reach this agreed framework took many turns among the world's leading banks and their regulators, with its form being amended since its early stages. The revised Basel capital framework aims to make the requirements which apply to internationally active banks (both wholesale and retail) more risk sensitive and representative of modern risk management practices.

### Basel III

The third Basel Accord (Basel III) was developed by the Basel Committee in response to the global financial crisis. Building on the previous Basel I and II Accords, Basel III introduced a set of reforms designed to mitigate risk within the international financial services sector by requiring banks, credit institutions and investment firms to maintain minimum leverage ratios and levels of reserve capital in order to limit the likelihood and impact of future financial crises. This capital must be of a higher quality against more conservatively calculated risk-weighted assets (RWAs).



Basel III also aims to ensure that there is sufficient liquidity during times of economic stress, improve risk management, strengthen the transparency and reduce bank leverage by setting voluntary regulatory standards on the level of bank capital adequacy, stress testing and **market liquidity risk**.

In summary, here are the main additions introduced under Basel III:

- **Capital requirements** – additional capital buffers relating to the amount and quality of mandatory and discretionary capital held, which would allow national regulators to insist that an additional 2.5% of capital needs to be held by banks during periods of high credit growth.
- **Leverage ratio** – a minimum leverage ratio that requires banks to hold in excess of 3% of their average total consolidated assets to provide more protection.
- **Liquidity requirements** – two new required liquidity ratios have been introduced:
  - **Liquidity coverage ratio** – this requires a bank to hold sufficient liquid assets that are of a higher quality and are in excess of its total net outflows over a 30-day period.
  - **Net stable funding ratio** – this requires a bank to hold an amount of stable funding that is in excess of the required amount of stable funding over a one-year period of extended stress.
- **Standardised approach** – this replaces the **advanced measurement approach (AMA)** with a single approach for all firms focusing on a bank's income and historical internal losses over a ten year period.

## 3.2 The Three Pillars

### Learning Objective

- 7.2.3 Understand the differences between Pillars 1, 2 and 3 of the Basel Accords relating to operational risk

The Basel II directive was structured on three pillars:

- **Pillar 1** – minimum capital requirements.
- **Pillar 2** – regulatory supervision.
- **Pillar 3** – market discipline.

#### Pillar 1

**Pillar 1** is the calculation of the minimum capital requirement.

Capital adequacy is measured as:

$$\text{Capital ratio} = \frac{\text{Capital requirement}}{\text{Credit risk exposure} + \text{market risk exposure} + \text{operational risk exposure}}$$

The minimum overall capital ratio remains at 8% of its risk-weighted assets (RWA) but the methods of measuring market, credit and operational risk exposure are now more elaborate.



## Pillar 2

**Pillar 2** relates to the supervisory review process. This pillar requires supervisors to ensure that the bank has sound internal processes in place in order to assess capital adequacy based on a thorough evaluation of its risks.

The importance of institutions developing their own processes is stressed, together with the need for appropriate targets for capital that are in line with the firm's risk profile and control environment.

It is worth noting that an unsatisfactory review can result in an immediate additional capital charge, and/or force changes in senior management responsibilities. For the first time, the Accord provided guidance for the independent review of a firm's operational risk and its management. Recommendations included reviewing:

- the firm's framework and processes for determining its operational risk capital charge
- the effectiveness of the firm's risk management process
- the effectiveness of the firm's monitoring and reporting systems
- the firm's procedures to ensure the timely resolution of risk events, and
- the effectiveness of the firm's 'action' strategies for managing risk.

## Pillar 3

**Pillar 3** is concerned with market disclosure. It aims to enhance market visibility by requiring greater public disclosure to allow more transparency of banks' risk profiles and the capital adequacy of their positions.

### 3.2.1 Pillar 1 Explained

#### Learning Objective

- 7.2.4 Understand the three measurement approaches for operational risk capital requirements under Basel: basic indicator approach; standardised approach; advanced measurement approach (AMA)

Pillar 1 of Basel II breaks up regulatory capital into three parts to match credit risk, market risk and operational risk. The market risk element, dealing with trading losses, was unchanged from Basel 1, which was amended for this purpose in 1997.

The 'operational risk capital requirements' part of Pillar 1 was new for the time. This requirement was that banks' capital should reflect the risk of mistakes and wrongdoing. An example might be a fine levied on a bank for overcharging its credit card customers.

From the operational risk capital requirements perspective, Pillar 1 requires a more detailed explanation. It lays down a new means of measurement acceptable to international regulators. In seeking to provide common standards, it outlines three different measurement approaches for calculating risk exposure:

1. The basic indicator approach.
2. The standardised approach.
3. The advanced measurement approach (AMA).

Each approach is discussed in more detail below, along with the criteria that firms must satisfy in order for those approaches to apply. Note that the complexity increases for each one.

### The Basic Indicator Approach

As the name implies, this is the most basic approach. This approach requires a bank to hold a fixed percentage (denoted 'alpha') of its gross income as operational risk capital. This fixed percentage is set by the Basel Committee, and is currently at a level of 15%.

The Basel Committee anticipated that smaller, domestic institutions that do not possess sophisticated risk management tools and techniques would use the basic indicator approach.

### The Standardised Approach

This approach is more refined than the basic indicator approach because it allows different risk profiles to be allocated to different activities within a firm. This is intended to provide a more representative reflection of an organisation's overall operational risk profile.

Like the basic indicator approach, the standardised approach uses gross income as a broad indicator that reflects the scale of business operations within each business line and, therefore, the likely scale of operational risk.

Gross income is split between eight defined business lines and then each is multiplied by a factor (denoted 'beta') specific to that business line in order to produce the amount required to be held as operational risk capital for that particular part of the business. The overall amount of operational risk capital is then the sum of all these calculations. The relationship between business unit and indicator is shown in the table below.

So, for example, for a firm's corporate finance (CF) business line, the regulator has set a beta factor of 18%. This means that the CF business is required to maintain capital of:

$$\text{Required capital for CF} = \text{Gross income for CF} \times \text{beta factor of 18\%}$$

The relationship between each business unit, indicator and factor for this firm is shown in table 7.2 below.

The standardised approach relies on indicators and factors set by the regulators and recognises that many institutions may not have had sufficient loss data and analytical risk processes to calculate their own capital charge. It provides a basis for moving towards a more sophisticated methodology and encourages better operational risk management.

In order to qualify to use the standardised approach, a firm must meet the following criteria:

- Its board of directors and senior management must be actively involved in the oversight of the operational risk management framework.
- It must have an operational risk management system that is conceptually sound and implemented with integrity.
- It must have sufficient resources to staff its approach within its business lines, and control and audit areas.
- Internationally active banks must have clear responsibilities assigned to an operational risk management (ORM) function. This function should be responsible for managing the process.
- It must perform systematic tracking of operational risk data, including losses by business line.
- It must use an effective risk-reporting system.
- It must have an independent, well-documented risk management and control process.
- It must conduct regular internal audits of the operational risk process.
- It must develop criteria for mapping current business lines to the standardised framework.

Note that the EU CRD is less prescriptive than Basel II.

Table 7.2 – The Standardised Approach

| Business Unit      | Business Line        | Indicator    | Factor       |
|--------------------|----------------------|--------------|--------------|
| Investment Banking | Corporate Finance    | Gross Income | beta 1 = 18% |
|                    | Trading and Sales    | Gross Income | beta 2 = 18% |
| Banking            | Retail Banking       | Gross Income | beta 3 = 12% |
|                    | Commercial Banking   | Gross Income | beta 4 = 15% |
|                    | Payment & Settlement | Gross Income | beta 5 = 18% |
|                    | Agency Services      | Gross Income | beta 6 = 15% |
| Others             | Retail Brokerage     | Gross Income | beta 7 = 12% |
|                    | Asset Management     | Gross Income | beta 8 = 12% |

### The Advanced Measurement Approach (AMA)

The advanced measurement approach (AMA) is the most risk sensitive of the three approaches. It allows banks to use their own internal measurement system and loss data as a basis for calculating the capital charge. The primary motive for a firm to move from the standardised approach to the AMA is to reduce its capital allocation requirement as the AMA rewards more sophisticated risk management.

The AMA can cover a range of measurement techniques (both qualitative and quantitative, and usually VaR-based), providing that these measurement techniques have been approved by the regulators.

In order to qualify to use the AMA, banks must comply with the qualifying criteria required under the standardised approach. Additionally, they must comply with even more stringent requirements – these requirements aim to ensure that banks have satisfactory risk management processes, risk measurement systems and risk infrastructure in place. Some key quantitative requirements specific to the AMA are as follows:

- The bank must establish rigorous procedures for the development and validation of risk models.
- The risk measure must incorporate the impact of infrequent, high-impact losses.
- The bank must be able to demonstrate that the risk measure reflects the equivalent of a holding period of one year and a confidence level of 99.9%. Note that while this confidence limit is stipulated by the Basel Committee, there are exceptions to its application.
- The bank must develop specific criteria for assigning loss data to specific risk types within business lines. The seven defined risk types (as discussed in chapter 3) are:
  - internal fraud
  - external fraud
  - employment practices and workplace safety
  - clients, products and business practice
  - damage to physical assets
  - business disruption and systems failures, and
  - execution, delivery and process management.
- The risk process must include external, as well as internal, loss data.
- Measures must be based on a minimum five-year observation period of loss data (with a minimum three years required when a bank first moves to the AMA).
- The risk mitigation impact of insurance can be recognised up to a limit of 20% of the total operational risk capital.

If qualitative measures are used, they must have an ability to be validated objectively.

### 3.2.2 Changes to the Three Pillars

The Basel III directive introduced changes to the three pillars in 2018 as follows:

- **Pillar 1** includes rules relating to ‘enhanced minimum capital and liquidity requirements’ (Basel II related to ‘minimum capital requirements’ only).
- **Pillar 2** includes rules relating to an ‘enhanced supervisory review process for firm-wide risk management and capital planning’ (Basel II related to the ‘supervisory review process’ only).
- **Pillar 3** includes rules relating to ‘enhanced risk disclosure and market discipline’ (Basel II only related to ‘disclosure and market discipline’).

Going forward, it is expected that the capital requirements that banks must meet will continue to increase, and the cost of capital will need to be closely monitored by banks.

There is ongoing research and debate over the impact and implementation of Basel III. A few recent topics discussed have included:

- Whether capital requirements for loans to small- and medium-sized businesses (SMEs) should be lower than present rules require, given that they tend to be widely diversified, and in order to encourage credit to these smaller firms.
- Whether capital adequacy rules are successful in lowering systemic risk among the largest of firms.
- What is the appropriate amount of customisation which should be allowed in how firms implement the range of directives included in Basel I, II and III?

Source: [www.centralbanking.com](http://www.centralbanking.com)

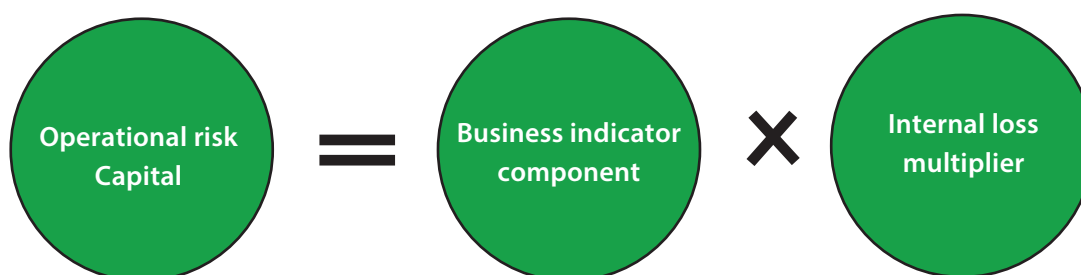
### The Standardised Approach (Basel III)

The AMA along with the existing standardised approaches listed in table 7.2 above are being replaced by the new standardised approach (SA) as a result of the introduction of Basel III. The overall impact of this change is increasing risk capital requirements in line with increasing historical losses across a range of financial institutions internationally.

There are two broad assumptions underpinning the revised standardised approach:

1. Operational risk increases within firms with higher income (ie, larger firms pose more potential risk to consumers and/or markets).
2. Firms that have a higher rate of historical operational risk losses are more likely to incur greater operational risk losses in the future (ie, riskier firms, or those with weaker internal controls environments, will continue to see higher loss rates).

These assumptions are seen in the operational risk capital (ORC) calculation as:



Source: [www.bis.org](http://www.bis.org)

### The Business Indicator Component (BIC)

The **business indicator component (BIC)** is a measure of operational risk based on the institution's last three years financial statements and consists of three elements:

1. The interest, leases and dividend component.
2. The services component.
3. The financial component.

### The Internal Loss Multiplier (ILM)

The **internal loss multiplier (ILM)** is a measure of the firm's average historical operational risk losses during the previous 10 years, it is calculated at 15 times the average annual operational risk losses. For firms to produce an accurate ILM there is a clear requirement to have appropriate controls around loss data identification, collection and aggregation; firms must also disclose their annual loss data for each of the 10 years used within in the ILM.

The new standardised approach for operational risk measurement must have been implemented by 1 January 2027.

## End of Chapter Questions

Think of an answer for each question and refer to the appropriate section for confirmation.

**1. Name two of the overarching sections of the UK Corporate Governance Code**

*Answer Reference: Section 2.1*

**2. What must firms ensure when creating a compliance function under the MiFID rules?**

*Answer Reference: Section 2.3*

**3. What is the aim of Dodd-Frank?**

*Answer Reference: Section 2.4*

**4. Define Conduct risk?**

*Answer reference: Section 2.6*

**5. Name for of the consumer outcomes under the FCA's Fair Treatment of Customers (FTOC) initiative**

*Answer reference: Section 2.6*

**6. What is the role of the data protection officer (DPO)?**

*Answer reference: Section 2.8*

**7. What issues does the Sustainable Disclosure Regulation (SDR) attempt to address?**

*Answer Reference: Section 2.8*

**8. List three of the Consumer Duty outcomes?**

*Answer Reference: Section 2.11*

**9. List three additions that were introduced under Basel III.**

*Answer Reference: Section 3.1*

**10. What is the Operational Risk Capital (ORC) calculation under the new standardised approach under BASEL III?**

*Answer Reference: Section 3.2.2*



The background features a complex, abstract network of red lines and glowing nodes on a dark blue, textured surface. A large, smooth white curve sweeps across the upper portion of the image, framing the title.

# Glossary





**Accounting Risk**

The risk of inaccurate financial reporting.

**Advanced Measurement Approach (AMA)**

A group of risk-sensitive methods used to calculate the capital charge for operational risk under the Basel rules.

**Asset Liquidity Risk**

See **Liquidity Risk**.

**Asset Securitisation**

The practice of pooling bonds or loans with credit risk and selling them as a package to outside investors.

**Back Testing**

The practice of comparing actual data with predicted data in order to ensure the veracity of a predictive model.

**Basel Committee**

A committee of central bankers which publishes a set of minimal capital requirements for banks known as the Basel Accord.

**Basis Risk**

The risk that offsetting investments in a hedging strategy will not be a perfect hedge.

**Bell Curve**

See **Normal Distribution Curve**.

**Benchmarking**

In the context of operational risk, this means comparison of a firm's loss data and measures of operational risk with competitors and other firms in the industry.

**Bilateral Arrangement (of Collateral)**

An agreement in which both parties post collateral for the value of their total obligation to the other.

**Business Indicator Component (BIC)**

Part of the Operational Risk Capital calculation under the standardised approach introduced by BASEL III. It is a measure of operational risk based on the previous 3 years' financial statements.

**Business Risk**

The risk of loss due to an adverse external environment, such as high inflation affecting labour costs, an over-competitive market reducing margins, or legal, tax or regulatory changes in the markets. See also **Risk Profile**.

**Cash Netting**

The practice whereby two parties who exchange multiple cash flows during a given day agree bilaterally to net those cash flows to one payment per currency, thereby reducing settlement risk. Multilateral netting between a group of counterparties is performed by a clearing house.

**Central Counterparty (CCP)**

The guarantor of contracts normally, but not necessarily, for exchange-traded products (ETPs), usually the clearing house of an exchange.

**Collateral**

An asset held by a lender on behalf of an obligor, under certain agreed conditions, as security for a loan or borrowed assets, or to cover a margin requirement. See also **Margin**.

**Commodity Price Risk**

This is the risk of an adverse movement in the price of a commodity.

### **Compliance Risk**

The risk to reputation, earnings or capital arising from violations or non-conformance with laws, rules, regulations, prescribed practices or ethical standards.

### **Confidence Level**

An assessment of the probability that an event will occur, usually expressed as a percentage.

### **Confirmation Process**

The process of agreeing the details of a transaction with a counterparty.

### **Corrective Control**

One of four control types designed to correct errors or losses as a result of risk events or control weaknesses.

### **Correlation Simulation**

A value at risk (VaR) measure that calculates the volatility of each risk factor from historical data and estimates its effect on the portfolio so as to give an overall composite VaR that includes all risk factors.

### **Coupon**

The income element of a bond, usually expressed as a percentage of the face value of the bond.

### **Credit Default Swap (CDS)**

A bilateral financial contract in which one counterparty (the buyer) pays a periodic, or one-off, fee (typically expressed in basis points on the notional amount), in return for a contingent payment by the other counterparty (the seller) following a credit event of a reference entity.

### **Credit Derivatives**

Specialised over-the-counter (OTC) products that allow the transfer of credit exposure between parties.

### **Credit Event**

An adverse change such as bankruptcy, insolvency, receivership, material adverse restructuring of debt, or failure to meet payment obligations when due.

### **Credit Exposure**

The amount that can potentially be lost if a debtor defaults on their obligations.

### **Credit Limits**

The maximum limits for lending set by financial institutions to prevent excessive exposure to a particular firm or counterparty.

### **Credit Rating**

An assessment of the creditworthiness of a firm that is used by lenders to manage their credit exposure.

### **Credit Rating Agency**

Organisations that rank the creditworthiness of a firm, usually by assigning the firm a credit rating. Fitch, Moody's and S&P are considered the 'big three' ratings agencies.

### **Credit Risk**

The potential loss of earnings or capital due to an obligor's failure to meet the terms of a contract or otherwise failing to perform as agreed.

### **Credit Risk Premium**

The difference between the interest rate that a firm pays when it borrows and the interest rate on a default-free security, such as a high quality, short-dated government bond.

**Current Exposure**

The current obligation outstanding.

**Detective Controls**

One of four control types designed to detect errors once they have occurred and prevent further losses.

**Digital Operational Resilience Act (DORA)**

An EU regulation designed to enhance digital operational resilience across ICT providers who support the financial sector.

**Direct Credit Risk**

The simple risk of loan default where money is lent to a customer.

**Direct Loss**

The direct financial penalty that a firm incurs as a result of a risk being realised.

**Direct Market Risk Factors**

The factors that have a direct bearing on an instrument's price, such as the financial performance of a company and the health of its statement of financial position.

**Directive Controls**

One of four control types designed to direct individuals in order to avoid or mitigate a risk event. This is usually accomplished in practice through policies or process documentation.

**Distribution Analysis**

A statistical means of using historical data to predict future events.

**Diversification**

A means of reducing the concentration of credit risk by spreading it across borrowers, sometimes in different, negatively correlating industry sectors.

**Downside**

The potential negative aspects of incurring risk.

**Enterprise Risk Management (ERM)**

A firm-wide, holistic approach to managing the range of risks across an organisation.

**Equity Price Risk**

The risk of adverse movements in share prices affecting a portfolio.

**External Detective Controls**

Controls that detect errors and losses once they have been realised (ie, they detect the consequences).

**Financial Conduct Authority (FCA)**

The UK regulator responsible for regulating conduct in retail and wholesale markets, for supervising the trading infrastructure that supports those markets, and for the prudential regulation of firms not regulated by the Prudential Regulation Authority (PRA).

**Financial Risk**

The quantifiable likelihood of loss or less-than-expected returns.

**Financial Services Authority (FSA)**

The agency created by the Financial Services and Markets Act 2000 (FSMA) to be the single financial regulator in the UK. In April 2013, it was split into two – the Financial Conduct Authority (FCA), looking after conduct issues, and the Prudential Regulation Authority (PRA), looking after prudential issues.

### **Fitch Ratings**

A credit rating agency.

### **General Data Protection Regulation (GDPR)**

An EU law related to the protection of personal data and privacy. The EU GDPR's requirements have been enacted into UK law.

### **Hedging**

A means of reducing the risk of adverse price movements by taking an offsetting position in a negatively correlated product.

### **Historical Loss Analysis**

The process of identifying previous loss events and attributing them to operational risk event types or causes.

### **Historical Simulation**

The simplest method of value at risk (VaR) calculation that uses actual historic data to estimate risk exposure in the future.

### **Indirect Loss**

The loss associated with the subsequent or downstream opportunity costs or losses of a risk being realised. This could include opportunity loss or the cost of remediation.

### **Indirect Market Risk Factors**

The factors that have an indirect bearing on an instrument's price, such as interest rate levels, economic events, or political and environmental effects.

### **Initial Margin**

The amount that a market participant must deposit with a broker or central counterparty clearing house (CCP) at the time they take a position in a contract.

### **Interest Rate Risk**

The risk of adverse movements in interest rates.

### **Internal Detective Controls**

Controls that detect errors after they have occurred but before a potential loss is realised in the outside world (ie, they detect the internal effect in order to prevent the consequences).

### **Internal Loss Multiplier (ILM)**

Part of the operational risk capital calculation under the standardised approach introduced by BASEL III. It is a multiplier of 15 times the average annual operational risk losses incurred over the previous 10 years.

### **Issuer Risk**

The risk of default, with respect to redemption or interest servicing, when one institution holds debt securities issued by another institution.

### **Key Risk Indicators (KRIs)**

Objective measurement criteria that measure a firm's ongoing risk status.

### **Know Your Customer (KYC)**

The Money Laundering Regulations 2007 and the Financial Conduct Authority (FCA) rules requiring firms to take sufficient steps, before taking on a customer, to satisfy themselves of the identity of that customer.

### **LCH (London Clearing House)**

A multi-asset clearing house which acts as the central counterparty for trades executed on various over-the-counter (OTC) and exchange venues. It is a recognised central counterparty.

### **Legal Risk**

The risk of loss due to the unenforceability of contracts or documents.

**Liquidity Coverage Ratio (LCR)**

The proportion of highly liquid assets held by a financial institution to meet its short-term obligations.

**Liquidity Risk**

The risk that an organisation will not be able to meet its liabilities as they fall due. This may be because it is unable to liquidate assets or obtain enough funding, or it cannot easily unwind or offset specific exposures without significantly lowering market prices (eg, because of inadequate market depth or market disruptions).

**Loan Sales**

The practice of a firm making a loan to a company and then selling the loan to other institutions or investors.

**Loss Given Default (LGD)**

The estimated loss that a firm would incur at a specific time if a counterparty defaulted.

**Margin**

Money or collateral deposited that serves as a performance guarantee. See also **Collateral**.

**Market Liquidity Risk**

The risk of loss through not being able to trade in a market or obtain a price on a desired product when required.

**Market Risk**

The potential loss of earnings or capital arising from changes in the value of portfolios of financial instruments.

**Market Risk Limit**

See Stop-Loss Limit.

**Markets in Financial Instruments Directive (MiFID)**

An EU directive that allows firms authorised in one member state to provide/offer financial services to customers in another member state, subject to certain restrictions. There is also MiFID II and MiFIR.

**Markets in Financial Instruments Regulation (MiFIR)**

An EU regulation designed to ensure that markets are transparent, operate efficiently and it provides investor protection.

**Mark-to-Market**

Valuing assets against the present value of an instrument.

**Money Laundering**

The process whereby criminals attempt to conceal the true origins of the proceeds of their criminal activities and to give them the appearance of legitimacy by introducing them into the mainstream financial system.

**Near Miss**

An unplanned event where loss or damage was avoided due to preventative, detective or corrective controls working effectively, or by an act of nature.

**Negative Correlation**

An inverse or opposite relationship between two factors.

**Net Stable Funding Ratio**

The proportion of stable funding relative to the required levels of stable funding.

### **Normal Distribution Curve**

A common form of probability distribution which is continuous, symmetrical about its mean and is defined by its mean and standard deviation.

### **Nostro Account**

The record of money on deposit at another bank or institution (our account).

### **Obligor**

A party that has a financial obligation to another party.

### **Off-Balance Sheet Transaction**

A transaction that is not required to be reported in a firm's financial accounts.

### **On-Balance Sheet Transaction**

A transaction that is required to be reported in a firm's financial accounts.

### **Operational Risk**

The risk of loss resulting from inadequate or failed internal processes, people and systems, or from external events.

### **Operational Risk Controls**

Activities that are inserted into a process to protect it against specific operational risks.

### **Operational Risk Policy**

A framework for operational risk management.

### **Outsourcing**

The transfer of an aspect of a firm's business operations to a third party.

### **Pillar 1**

The rules in the Basel Capital Accord that define the minimum ratio of capital to risk-weighted assets (RWAs).

### **Pillar 2**

The supervisory review pillar of the Basel Capital Accord which requires supervisors to undertake a qualitative review of a bank's capital allocation techniques and compliance with relevant standards.

### **Pillar 3**

The disclosure requirements of the Basel Capital Accord, which facilitate market discipline.

### **Portfolio**

A collection of investments owned by the same individual or organisation.

### **Positioning Process**

The process of ensuring that there is sufficient stock or cash available to fulfil the settlement of a contract.

### **Post-Settlement Stage**

The third stage of a transaction's life cycle involving the movement of, and control over, cash and physical assets.

### **Potential Future Exposure**

The likely maximum loss (for a specified confidence level) in the event of default at a particular point in time.

### **Pre-Settlement Risk**

The risk that an institution defaults prior to settlement when the instrument has a positive economic value to the other party.

**Preventative Controls**

One of four control types designed to prevent errors from occurring in the first place.

**Price Level Risk**

The risk of potential adverse changes in the price of a financial instrument.

**Price Uncertainty**

The uncertainty of knowing whether market prices will move in a favourable or adverse direction.

**Probability Distributions**

Mathematical functions that describe the probabilities of possible outcomes occurring. They are depicted as graphs with the 'probability of occurrence' on the vertical axis (y-axis) and the 'possible outcome' on the horizontal axis (x-axis).

**Probability of Default**

The estimated likelihood that a counterparty will default on an obligation.

**Project Risk**

The risk that the failure or partial failure of a project to meet its objectives leads to financial loss.

**Ranking**

A method of assessing risk by estimating the likelihood of its being realised and the magnitude of its impact. This information is usually depicted graphically.

**Reconciliation**

A control function that ensures the firm's record of stock and cash movements, among other things, agrees with its statement of balance and holdings.

**Regulatory Risk**

See **Compliance Risk**.

**Risk**

The possibility of negative consequences or loss occurring.

**Risk Management**

The implementation of a strategic process that reduces the likelihood or the impact of risks being realised.

**Risk Measurement**

A process that is concerned with understanding the size of a risk and, therefore, the impact on a firm by trying to predict a future event using past knowledge.

**Risk Profile**

The types of risks that are faced by a firm and its exposure to those risks at any given time. See also **Business Risk**.

**Risk Register**

A log or database recording all risks identified, including details such as the nature of the risk, reference and owner, mitigation measures, likelihood of risk occurring, and potential impact.

**Scenario Analysis**

A method of analysing multiple risk events occurring concurrently, highlighting potential risk issues in order to allow preventative action to be taken.

**Securitisation**

See **Asset Securitisation**.



### **Senior Managers and Certification Regime (SM&CR)**

An FCA framework designed to reduce consumer harm and increase accountability and improve conduct.

### **Sensitivity Analysis**

A means of understanding how the price of a financial instrument or value of a portfolio changes in response to influencing effects.

### **Settlement**

The fulfilment of contractual commitments such as payment of cash for securities. The conclusion of a securities transaction by delivery against payment (DvP).

### **Settlement Risk**

The risk that there is a non-simultaneous exchange of value and one or more parties will fail to deliver on the terms of the contract.

### **Set-Up Stage**

The first stage of a transaction's life cycle involving all pre-transaction activities.

### **Society for the Worldwide Interbank Financial Telecommunication (SWIFT)**

The global standard for financial transactions and operates a messaging service between its members.

### **Spread**

The difference between similar financial measures, for example, the difference between the bid and offer prices of an instrument, or between market interest rates and a central bank rate.

### **Standard Deviation (SD)**

A means of measuring variability, uncertainty or volatility of return. It measures how far a variable moves over time away from its average (or mean).

### **Standing Settlement Instructions (SSIs)**

Pre-recorded details of how frequent customers will pay for their investment purchases and how they wish to receive their settlement monies when selling investments.

### **Stop-Loss Limit**

The specified maximum loss that a firm is prepared to make.

### **Strategic Risk**

The risk of loss due to a sub-optimal strategy being employed and associated with the way the institution is managed. For example, a competitor or product strategy may be employed that fails to maximise the return on the investment made.

### **Stress Testing**

A means of testing the accuracy of Value-at-Risk (VaR) or other models against extreme market event scenarios.

### **Suitability**

An assessment to ensure that products being sold to, or investments being traded on behalf of, a customer, are appropriate for their needs.

### **Sustainable Disclosure Regulation (SDR)**

The Sustainability Disclosure Regulation, designed to enhance transparency and accountability regarding sustainability factors in financial markets.

**Sustainable Finance Disclosure Regulation (SFDR)**

The Sustainable Finance Disclosure Regulation is an EU regulation designed to improve transparency in financial markets for sustainable investment products, introducing mandatory disclosures for financial market participants in relation to the firm's consideration of its sustainability risks.

**Top-Down Risk Assessment**

This involves the senior management reviewing the key risks that their business may be exposed to and then implementing a process to combat these risks.

**Transaction Capture**

The activity of capturing details of trades in systems.

***Ultra Vires***

Translates as 'beyond the powers'. The term describes actions taken by government bodies or corporations that exceed the scope of their authority, which leads to legal risk.

**Underwriting Standards**

The standards that financial institutions apply to borrowers in order to evaluate their creditworthiness and, therefore, limit the risk of default.

**Unilateral Arrangement (of Collateral)**

An agreement in which one party gives collateral to the other.

**Upside**

The positive aspects of incurring risk.

**Value at Risk (VaR)**

The maximum expected loss that can occur with a specified confidence over a specified period of days.

**Variance/Covariance Simulation**

See **Correlation Simulation**.

**Variation Margin**

A demand for extra cash cover for margins made by brokers and clearing houses on a daily basis to reflect changes in the market value of positions.

**Volatility**

The relative rate by which a financial instrument's price moves up and down.

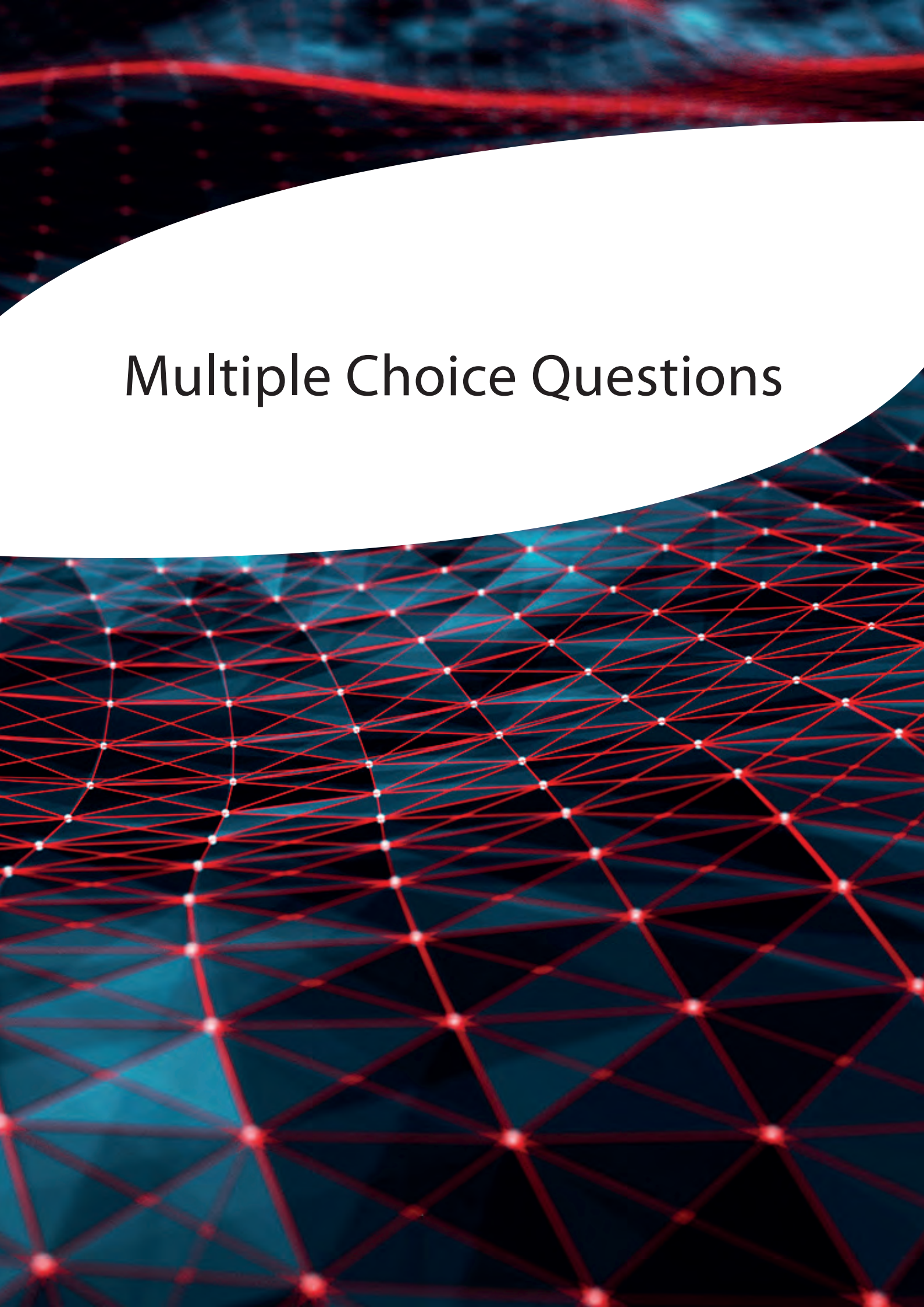
**Volatility Risk**

The risk of price movements that are more uncertain than usual affecting the pricing of products.

**Volume Sensitivity**

A process cause of operational risk where the workload increases in proportion to increasing volumes.



The background features a white, curved, wave-like shape on the left side. The rest of the image is filled with a complex, abstract pattern of red and blue lines and dots, resembling a network or a digital landscape. The red lines are prominent, forming a dense web of connections, while the blue lines are more subtle, creating a layered effect. The overall aesthetic is high-tech and futuristic.

# Multiple Choice Questions



## Multiple Choice Questions

The following additional questions have been compiled to reflect as closely as possible the standard that you will experience in your examination. Please note, however, they are not the actual CISI examination questions.

- 1. A company which introduces straight-through processing (STP) systems reduces its process risk. However, this may increase:**
    - A. People risk
    - B. Systems risk
    - C. Event risk
    - D. Reputational risk
  
  - 2. Which of the following is an advantage of credit derivatives?**
    - A. They help to reduce concentrations of credit risk
    - B. They reduce market volatility
    - C. They replace the need for diversification
    - D. They allow credit risk to be monitored
  
  - 3. Which of the following is an attribute of a normal distribution curve?**
    - A. It is symmetrical about its standard deviation
    - B. It is plotted about its median
    - C. Its average value is always greater than its standard deviation
    - D. It is defined by its standard deviation and its mean
  
  - 4. A lack of capacity is an example of which cause of risk?**
    - A. People
    - B. Processes
    - C. Systems
    - D. Events
  
  - 5. The key role of the compliance function is to ensure that the firm:**
    - A. defines programmes to enhance individual accountability
    - B. issues guidelines on collateral and margin usage
    - C. operates according to corporate governance parameters
    - D. accurately compiles reports of its assets and liabilities
  
  - 6. A clash of cultures is a likely effect of which of the following?**
    - A. Poor leadership
    - B. Interdepartmental conflict
    - C. Mergers
    - D. The introduction of a new risk policy
-

- 7. The risk of a difference in the impact of market factors on the price of two similar investments is known as:**
- A. volatility risk
  - B. basis risk
  - C. settlement risk
  - D. liquidity risk
- 8. Which of the following is not a type of market risk?**
- A. Volatility risk
  - B. Basis risk
  - C. Company-specific risk
  - D. Liquidity risk
- 9. Where value-at-risk (VaR) back testing shows unsatisfactory differences between the estimates and reality, what action is normally taken?**
- A. Additional capital is sought
  - B. The methodology model is reviewed
  - C. A report is immediately issued to the regulator
  - D. Extra hedging is arranged
- 10. Which of the following statements describes scenario analysis?**
- A. It is a key risk indicator
  - B. It assesses multiple risks in combination
  - C. It examines the key risks only
  - D. It must be documented
- 11. The primary purpose of positioning is to ensure that:**
- A. delivery occurs on time
  - B. funding deadlines are met
  - C. there are sufficient assets available to fulfil a contract
  - D. the bank's stock and cash holdings are liquid
- 12. Pillar 3 of Basel II is primarily concerned with:**
- A. the regulatory review process
  - B. calculating capital adequacy
  - C. operational risk measurement
  - D. public disclosure



- 13. Which of the following is not a technique of measuring credit risk?**
- A. Credit ratings
  - B. Credit exposure
  - C. Credit limits
  - D. Credit risk premium
- 14. The operational risk policy of a firm should normally be:**
- A. provided in writing to all customers
  - B. sponsored at board level
  - C. registered with the central bank
  - D. compiled by the compliance officer
- 15. What stage normally immediately follows the risk measurement and assessment stage in a typical risk management process?**
- A. Risk identification
  - B. Risk reporting
  - C. Risk treatment
  - D. Risk monitoring
- 16. Most firms that fall within the scope of MiFID will also have to comply with which one of the following?**
- A. The Retail Distribution Review (RDR)
  - B. The Capital Requirements Directive (CRD)
  - C. UCITS V
  - D. Solvency II
- 17. Where a firm's various risks are plotted on a standard risk-ranking chart, the highest risks will normally appear in the:**
- A. top right-hand quadrant
  - B. top left-hand quadrant
  - C. bottom right-hand quadrant
  - D. bottom left-hand quadrant
- 18. Which type of measure of operational risk is a means of peer-group comparison within the industry?**
- A. Scenario analysis
  - B. Cost-based provisioning
  - C. Benchmarking
  - D. Ranking
-



- 19. The self-assessment approach to risk identification normally utilises which other method of assessing operational risk?**
- A. Ranking
  - B. Scenario analysis
  - C. Key risk indicators
  - D. Benchmarking
- 20. When establishing key risk indicators (KRIs), which of the following is an example of a non-process-related indicator?**
- A. Volume of transactions per head
  - B. Number of times a trader exceeds agreed credit limits
  - C. Annual level of staff turnover
  - D. Average duration of unsigned confirmations
- 21. Which of the following is an example of the risk transfer method of treating risk?**
- A. Introducing internal detection controls
  - B. Designing a contingency planning policy
  - C. Taking out a fire and theft insurance policy
  - D. Setting market and credit risk limits
- 22. One of the primary changes brought about by the Basel II Accord was to:**
- A. impose quarterly internal reviews of the risk measurement process
  - B. introduce incentives for better risk management
  - C. exempt MiFID-compliant firms from extra risk requirements
  - D. incorporate the requirements of the Sarbanes-Oxley regulations
- 23. Focus workshops are used to identify risks and their causes because they have the ability to:**
- A. ensure risk reporting is being performed
  - B. show clearly the adequacy of controls
  - C. satisfy regulators that an adequate control environment exists
  - D. investigate cross-functional dependencies
- 24. Which of the following statements is not true in relation to risk appetite?**
- A. It must be documented
  - B. It should be sponsored by the board
  - C. It provides an objective benchmark for assessing risk
  - D. It must be used in combination with value-at-risk (VaR)

- 25. Under the standardised approach adopted for Pillar 1 of Basel II, the beta factor used to calculate the required capital varies according to:**
- A. the relative risk level as measured by ranking
  - B. the relative risk level as measured by benchmarking
  - C. the firm's business lines
  - D. the firm's age
- 26. Which of the following methods of measurement has the disadvantage that it depends upon the expertise of the professional involved?**
- A. External loss data analysis
  - B. Scenario analysis
  - C. Internal risk event data analysis
  - D. Benchmarking
- 27. Which of the following methods of credit risk treatment best reduces settlement risk?**
- A. Diversification
  - B. Delivery versus payment
  - C. Credit derivatives
  - D. Credit limits
- 28. Which Basel II operational risk category does money laundering fall into?**
- A. Internal fraud
  - B. External fraud
  - C. Employment practices and workplace safety
  - D. Clients, products and business practice
- 29. Which of the following is NOT one of the seven key principles that govern the processing of personal data**
- A. Accountability
  - B. Integrity and Confidentiality
  - C. Reconciliations
  - D. Lawfulness, fairness and transparency
- 30. Which of the following is the best reason for using external detective controls?**
- A. To reduce the likelihood of risk occurring
  - B. To prevent a risk occurring
  - C. To reduce the impact of a risk occurring
  - D. To provide feedback in the risk-reporting process

- 31. How can risks be calculated when using the ranking method of prioritisation?**
- A. Impact x likelihood
  - B. Impact ÷ likelihood
  - C. Impact + likelihood
  - D. Impact only
- 32. A key characteristic of technology failure is that:**
- A. it is impossible to reduce the likelihood of occurrence
  - B. it is sometimes outside the control of the firm
  - C. it only impacts on short-term issues
  - D. it only impacts on long-term issues
- 33. A key reason why firms have controls in place to ensure segregation of duties between front-office and back office functions is to:**
- A. reduce settlement risk
  - B. speed up the processing time
  - C. achieve best execution
  - D. minimise fraudulent opportunities
- 34. A series of documentary omissions occurring in a firm is often an early indication of:**
- A. data capture errors
  - B. cultural difficulties
  - C. process weaknesses
  - D. capital adequacy problems
- 35. A life office breached compliance rules by missing a reporting deadline and exceeding an investment limit. In which of these two breaches (if either) could the cause result from technology issues?**
- A. In neither case
  - B. Only in the case of the missed deadline
  - C. Only in the case of the exceeded limit
  - D. In both cases
- 36. The primary difference between enterprise risk management (ERM) and market risk management, is that ERM:**
- A. focuses primarily on long-term issues
  - B. aims to integrate the management of all risks
  - C. covers non-financial risks only
  - D. operates on a bottom-up approach basis

- 37. A key impact of the Sarbanes-Oxley Act 2002 was to increase the level of corporate responsibility in the specific area of:**
- A. company accounting
  - B. competitor activities
  - C. product range
  - D. remuneration terms
- 38. Where a firm's compliance risk is realised, which of the following results is most likely to consequently occur?**
- A. A cross-compensating reduction in the firm's market risk level
  - B. Damage to the firm's credit risk
  - C. A fall in the firm's costs
  - D. Damage to the firm's reputation
- 39. Where data has been wrongly captured by a firm, which of the four main root causes will be to blame?**
- A. Technology, external events and processes
  - B. Environment, people and processes
  - C. Processes, people and technology
  - D. People, processes, technology and external events
- 40. The primary role of the front office of a financial institution is to:**
- A. oversee strategy
  - B. earn revenue
  - C. settle transactions
  - D. monitor risk
- 41. Which specific requirement is normally addressed by the employee of a financial institution by completing a fact-find?**
- A. Status disclosure
  - B. Money laundering
  - C. Best execution
  - D. Know Your Customer
- 42. Which of the following is a characteristic of trade confirmations?**
- A. They are all performed electronically
  - B. They must be made in writing
  - C. They are usually based on pre-established legal agreements
  - D. They usually take place two days after the trade day

- 43. Which of the following is most likely to be a key risk indicator (KRI) for the positioning stage of the settlement process?**
- A. Time taken to formulate a legal agreement
  - B. Time taken for counterparties to return confirmations
  - C. Number of late-settled transactions due to lack of funds
  - D. Number of transactions not captured within a specified time frame
- 44. The number of breaks is often used as a risk indicator in connection with which stage of the front-office support function activities?**
- A. Transaction instruction
  - B. Positioning
  - C. Settlement
  - D. Reconciliation
- 45. If standard settlement instruction data is not used for a particular transaction instruction, this will often result in:**
- A. faster processing
  - B. additional risk
  - C. the involvement of an extra third party
  - D. problems occurring at the positioning stage
- 46. If an independent internal audit section is required under MiFID, this team must:**
- A. have sufficient authority
  - B. report directly to the compliance officer
  - C. include a qualified accountant or solicitor
  - D. be separately funded from the firm's reserves
- 47. The main difference between direct and indirect financial loss, which can result from a risk being realised, mainly relates to whether the loss:**
- A. is borne by a third party
  - B. is long lasting
  - C. can be quantified
  - D. can seriously impact profitability
- 48. Where a firm carries out an ultra vires check, this is done in an attempt to mitigate which particular risk?**
- A. Volatility risk
  - B. Liquidity risk
  - C. Basis risk
  - D. Legal risk

**49. Contractual ambiguity is a common aspect of which one of the following types of risk?**

- A. Regulatory risk
- B. Basis risk
- C. Legal risk
- D. Pre-settlement risk

**50. Which of the four main root causes of operational risk is most likely to have a recognised separate internal and external dimension?**

- A. People
- B. Systems
- C. Processes
- D. Events

## Answers to Multiple Choice Questions

1.            **B**            **Chapter 4, Section 1.1**

Where a firm places greater reliance on systems, the impact of a system failure is increased.

2.            **A**            **Chapter 2, Section 2.2.2**

Credit derivatives enable credit exposure to be transferred between parties.

3.            **D**            **Chapter 2, Section 3.2**

It is a bell curve with the mean at the centre, and the slopes are dependent on the standard deviation.

4.            **B**            **Chapter 4, Section 1**

A lack of capacity can lead to firms being unable to process business demand.

5.            **A**            **Chapter 6, Section 1.3.1**

The compliance function defines the programmes and processes and their related accountability.

6.            **C**            **Chapter 3, Section 2**

Culture is strongly influenced by leadership and if two sets of leaders combine, it can create conflict.

7.            **B**            **Chapter 2, Section 3.1.2**

Basis risk occurs when one kind of risk exposure is designed to offset another.

8.            **C**            **Chapter 2, Section 3.1.2**

Company-specific risk is not a type of market risk and relates to the performance of individual companies.

9.            **B**            **Chapter 2, Section 3.3.4**

The model should be revised in order to improve the accuracy of future estimates.

10.           **B**            **Chapter 3, Section 6.2.3**

Scenario analysis is a risk assessment tool that allows multiple risk events to be assessed in combination.

11.           **C**            **Chapter 5, Section 3.1.3**

The process of positioning ensures that sufficient cash or stock is available to fulfil a contract.

12.           **D**            **Chapter 7, Section 3.2**

Pillar 3 requires greater public disclosure to allow improved transparency of banks' risk profiles and capital adequacy.

**13. C Chapter 2, Section 1.2**

Credit limits are not a method of measuring risk and merely limit the amount of exposure one counterparty may have against another.

**14. B Chapter 3, Section 3.1**

In order to be effective, the policy should be agreed and explained at board level.

**15. C Chapter 3, Section 4**

After a risk has been identified and quantified, steps should be taken to try and treat it.

**16. B Chapter 7, Section 2.3**

The Capital Requirements Directive (CRD) sets requirements for the regulatory capital that a firm must hold.

**17. A Chapter 3, Section 6.2.1**

Those with the relatively largest magnitude and likelihood ratings will appear in the top right section.

**18. C Chapter 3, Section 6.2.4**

Benchmarking compares loss data and measures of operational risk with competitors and other firms in the industry.

**19. A Chapter 3, Section 6.2.1**

This method often involves compiling a list of risks which managers then assess and measure.

**20. C Chapter 3, Section 7.1**

Non-process-related indicators primarily cover measures relating to people.

**21. C Chapter 3, Section 8.4**

Insurance effectively transfers risk from the policyholder to the insurance company.

**22. B Chapter 7, Section 3.1**

Basel II introduced a menu of approaches which effectively reward those that operate better risk management.

**23. D Chapter 3, Section 5.3.3**

By involving all of the functional activities in a process, interrelated dependencies can be identified.

**24. D Chapter 3, Section 3.11**

Value-at-risk (VaR) calculations are used to calculate likely future losses and form part of the credit risk management process.



**25. C Chapter 7, Section 3.2.1**

The beta factor used is specific to each business line.

**26. B Chapter 3, Section 6.2.3**

Scenario analysis is a subjective method of highlighting potential risk issues.

**27. B Chapter 5, Section 3.2.2**

DVP is the simultaneous exchange of cash and assets, and reduces the risk of settlement failure.

**28. D Chapter 3, Section 5.2**

Clients, products and business practice include misused confidential information and money laundering.

**29. C Chapter 7, Section 2.8**

GDPR defines seven key principles that govern the processing of personal data: lawfulness, fairness, and transparency; purpose limitation; data minimization; accuracy; storage limitation; integrity and confidentiality; and accountability.

**30. C Chapter 3, Section 8.1**

External detection controls operate after an error or loss has been realised, in order to limit the effect of the loss.

**31. A Chapter 3, Section 6.2.1**

Multiplying together the likelihood and magnitude of impact will provide a crude score which can be used to prioritise risks that a company may face.

**32. B Chapter 4, Section 1.3.7**

Power failure, for example, is often outside the firm's control.

**33. D Chapter 4, Section 1.3.5**

If a single individual has end-to-end authority, the opportunity for fraud is greatly increased.

**34. C Chapter 4, Section 1.3.2**

The incidence of documentary omissions is likely to be an early warning sign of process weaknesses.

**35. D Chapter 4, Section 1.3.3**

The transgressions could be inadvertently caused by people, processes or technology problems.

**36. B Chapter 1, Section 3**

ERM attempts to manage a firm's interrelated risks in the most effective way.

**37. A Chapter 7, Section 2.2**

Sarbanes-Oxley introduced new rules relating to the sign-off of company accounts.

**38. D Chapter 6, Section 1.3**

A compliance breach could result in a fine and/or censure, which could affect reputation.

**39. D Chapter 4, Section 1.3.1**

The problem could originate from any or all of the four main root causes.

**40. B Chapter 5, Section 2**

The front office is where trading takes place.

**41. D Chapter 5, Section 2.2**

The fact-find is used to gather the required information about the customer.

**42. C Chapter 5, Section 3.1.2**

All confirmations are based on a legal agreement set up at the outset.

**43. C Chapter 5, Section 3.1.3**

Settlement may be delayed if there is insufficient cash or assets to fulfil a trade. Positioning is the process of ensuring that the contract can be fulfilled.

**44. D Chapter 5, Section 3.2.4**

Breaks measure the volume of unreconciled events.

**45. B Chapter 5, Section 3.2.1**

The absence of an automated instruction process means that a separate transaction-specific instruction must be used, which increases the risk.

**46. A Chapter 6, Section 1.6**

MiFID requires this independent section to have sufficient authority.

**47. C Chapter 4, Section 2.1**

Direct financial loss is quantifiable but indirect financial loss is non-quantifiable.

**48. D Chapter 6, Section 1.8.1**

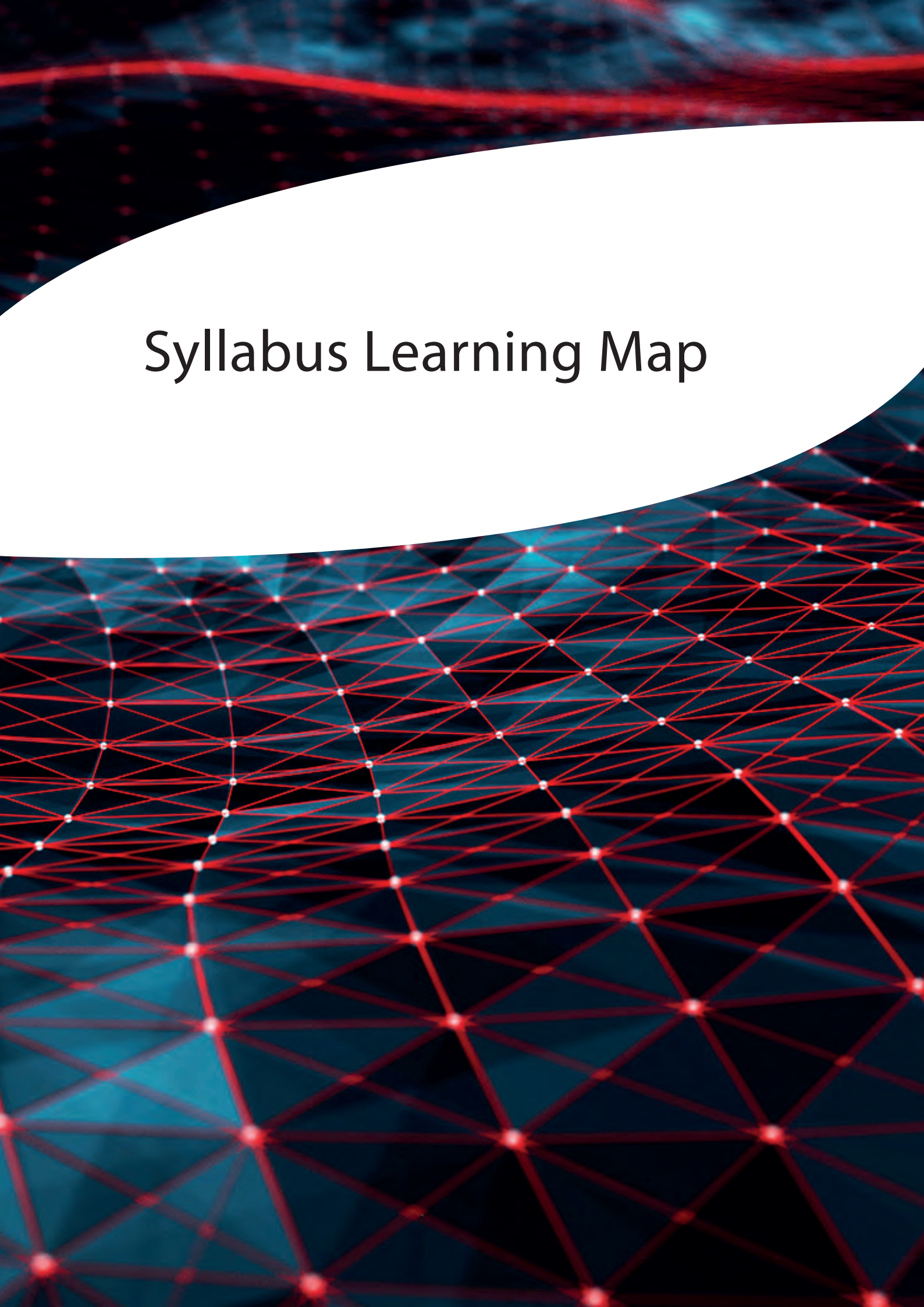
*Ultra vires* means acting beyond one's authority which could give rise to legal implications.

**49. C Chapter 4, Section 1.3.6**

Contractual ambiguities can lead to unforeseen litigation.

**50. D Chapter 4, Section 1.1**

Events have internal and external influences which separately affect operational risk.



# Syllabus Learning Map



| Syllabus Unit/<br>Element |  | Chapter/<br>Section |
|---------------------------|--|---------------------|
|---------------------------|--|---------------------|

| Element 1  | Risk Basics                                                                                                                                                                                                                                                                                                                                                                                                      | Chapter 1 |
|------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------|
| <b>1.1</b> | <b>Risk in the Financial Services Sector</b><br>On completion, the candidate should:                                                                                                                                                                                                                                                                                                                             |           |
| 1.1.1      | Know the following major risk categories: <ul style="list-style-type: none"> <li>• credit risk</li> <li>• market risk</li> <li>• operational risk</li> <li>• liquidity risk</li> </ul>                                                                                                                                                                                                                           | 2.2       |
| 1.1.2      | Understand simple examples of risk in the financial services sector                                                                                                                                                                                                                                                                                                                                              | 2.3       |
| 1.1.3      | Understand the operational risk issues linked with recent major risk-related events in the financial services sector, such as: <ul style="list-style-type: none"> <li>• Invesco (2014)</li> <li>• PPI</li> <li>• LIBOR</li> <li>• HSBC (2016)</li> <li>• Central Bank of Bangladesh (2016)</li> <li>• Wells Fargo (2016)</li> <li>• TSB (2018)</li> <li>• GAM (2018)</li> <li>• Raphael's Bank (2018)</li> </ul> | 2.4       |
| <b>1.2</b> | <b>Enterprise Risk Management</b><br>On completion, the candidate should:                                                                                                                                                                                                                                                                                                                                        |           |
| 1.2.1      | Understand Enterprise Risk Management (ERM) <ul style="list-style-type: none"> <li>• objectives</li> <li>• challenges</li> </ul>                                                                                                                                                                                                                                                                                 | 3         |

| Element 2  | Other Major Risks                                                                                                                                     | Chapter 2 |
|------------|-------------------------------------------------------------------------------------------------------------------------------------------------------|-----------|
| <b>2.1</b> | <b>The Nature of Credit Risk</b><br>On completion, the candidate should:                                                                              |           |
| 2.1.1      | Know the basic terms used in the subject of credit risk: <ul style="list-style-type: none"> <li>• counterparty risk</li> <li>• issuer risk</li> </ul> | 1.1       |
| 2.1.2      | Be able to apply the concept of credit risk to simple, practical situations                                                                           | 1.1       |

| Syllabus Unit/ Element |                                                                                                                                                                                                                                                                                                                                                                                                  | Chapter/ Section |
|------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------|
| <b>2.2</b>             | <b>Measuring Credit Risk</b><br>On completion, the candidate should:                                                                                                                                                                                                                                                                                                                             |                  |
| 2.2.1                  | Know the basic techniques for measuring credit risk: <ul style="list-style-type: none"> <li>• credit exposure management</li> <li>• credit risk premium</li> <li>• credit ratings</li> <li>• modern measurement techniques</li> </ul>                                                                                                                                                            | 1.2              |
| <b>2.3</b>             | <b>Credit Risk Management and Reporting</b><br>On completion, the candidate should:                                                                                                                                                                                                                                                                                                              |                  |
| 2.3.1                  | Understand the role of the credit risk management function                                                                                                                                                                                                                                                                                                                                       | 2.1              |
| 2.3.2                  | Understand the following examples of credit risk mitigation: <ul style="list-style-type: none"> <li>• asset securitisation</li> <li>• central counterparties</li> <li>• clearing houses</li> <li>• collateral and margin</li> <li>• credit derivatives</li> <li>• credit limits</li> <li>• diversification</li> <li>• loan sales</li> <li>• netting</li> <li>• underwriting standards</li> </ul> | 2.2              |
| <b>2.4</b>             | <b>The Nature of Market Risk</b><br>On completion, the candidate should:                                                                                                                                                                                                                                                                                                                         |                  |
| 2.4.1                  | Know the basic features of market risk: <ul style="list-style-type: none"> <li>• price level risk</li> <li>• volatility risk</li> <li>• liquidity risk</li> <li>• basis risk</li> </ul>                                                                                                                                                                                                          | 3.1              |
| 2.4.2                  | Be able to apply the basic features of market risk to simple, practical situations                                                                                                                                                                                                                                                                                                               | 3.1              |
| <b>2.5</b>             | <b>Measuring Market Risk</b><br>On completion, the candidate should:                                                                                                                                                                                                                                                                                                                             |                  |
| 2.5.1                  | Understand the measures of central tendency and dispersion: <ul style="list-style-type: none"> <li>• mean</li> <li>• median</li> <li>• mode</li> <li>• standard deviation</li> <li>• distribution analysis</li> </ul>                                                                                                                                                                            | 3.2              |

| Syllabus Unit/<br>Element |                                                                                                                                                                                                                                                                                                                                                                      | Chapter/<br>Section |
|---------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------|
| <b>2.6</b>                | <b>Value-at-Risk (VaR)</b><br>On completion, the candidate should:                                                                                                                                                                                                                                                                                                   |                     |
| 2.6.1                     | Understand the meaning of VaR and its constituents                                                                                                                                                                                                                                                                                                                   | 3.3                 |
| 2.6.2                     | Understand the meaning of back testing                                                                                                                                                                                                                                                                                                                               | 3.3                 |
| 2.6.3                     | Understand the meaning of stress testing                                                                                                                                                                                                                                                                                                                             | 3.3                 |
| 2.6.4                     | Know the limitations of using VaR for market risk management                                                                                                                                                                                                                                                                                                         | 3.3                 |
| <b>2.7</b>                | <b>Market Risk Management and Reporting</b><br>On completion, the candidate should:                                                                                                                                                                                                                                                                                  |                     |
| 2.7.1                     | Understand the following techniques for mitigating market risk: <ul style="list-style-type: none"> <li>• hedging</li> <li>• market risk limits</li> <li>• diversification</li> </ul>                                                                                                                                                                                 | 4.1                 |
| 2.7.2                     | Understand the role of the market risk management framework                                                                                                                                                                                                                                                                                                          | 4.2                 |
| <b>2.8</b>                | <b>The Nature of Liquidity Risk</b><br>On completion, the candidate should:                                                                                                                                                                                                                                                                                          |                     |
| 2.8.1                     | Know the basic terms used in the subject of liquidity risk: <ul style="list-style-type: none"> <li>• asset and liability management</li> <li>• maturity ladders</li> <li>• actual and contractual cash receipts</li> <li>• asset liquidity risk</li> <li>• funding liquidity risk</li> <li>• liquidity coverage ratio</li> <li>• net stable funding ratio</li> </ul> | 5.1                 |
| 2.8.2                     | Be able to apply the concept of liquidity risk to simple, practical situations                                                                                                                                                                                                                                                                                       | 5.1                 |
| <b>2.9</b>                | <b>Measuring Asset Liquidity Risk</b><br>On completion, the candidate should:                                                                                                                                                                                                                                                                                        |                     |
| 2.9.1                     | Know the key measures of asset liquidity risk: <ul style="list-style-type: none"> <li>• bid-offer spread</li> <li>• market depth</li> <li>• immediacy</li> <li>• resilience</li> </ul>                                                                                                                                                                               | 5.2.1               |
| <b>2.10</b>               | <b>Liquidity Risk Management Function</b><br>On completion, the candidate should:                                                                                                                                                                                                                                                                                    |                     |
| 2.10.1                    | Understand the role of the liquidity risk management function from the perspective of the firm                                                                                                                                                                                                                                                                       | 6.1                 |



| Syllabus<br>Unit/<br>Element |  | Chapter/<br>Section |
|------------------------------|--|---------------------|
|------------------------------|--|---------------------|

| Element 3  | The Nature of Operational Risk                                                                                                                                                                                                                                                                                                                                         | Chapter 3 |
|------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------|
| <b>3.1</b> | <b>Definition of Operational Risk and Operational Risk Categories</b><br>On completion, the candidate should:                                                                                                                                                                                                                                                          |           |
| 3.1.1      | Know the basic Bank for International Settlements' definition of operational risk                                                                                                                                                                                                                                                                                      | 1.1       |
| 3.1.2      | Understand that operational risk is present across the organisation in all departments and activities                                                                                                                                                                                                                                                                  | 1.2       |
| <b>3.2</b> | <b>Culture</b><br>On completion, the candidate should:                                                                                                                                                                                                                                                                                                                 |           |
| 3.2.1      | Understand the importance of effective leadership and the role of senior management in sustaining a robust risk and control culture                                                                                                                                                                                                                                    | 2.3       |
| 3.2.2      | Know the main factors determining a firm's risk and control culture: <ul style="list-style-type: none"> <li>• strategy/objectives</li> <li>• clear roles and responsibilities</li> <li>• risk appetite</li> <li>• selection, training and development</li> <li>• values and behaviours</li> <li>• communication</li> <li>• incentivisation and remuneration</li> </ul> | 2.4       |
| 3.2.3      | Know the organisational areas where positive behaviours are necessary to ensure a continuing robust risk and control culture                                                                                                                                                                                                                                           | 2.4       |
| 3.2.4      | Understand the contribution of the risk officers in maintaining a robust risk and control culture                                                                                                                                                                                                                                                                      | 2.4       |
| 3.2.5      | Understand the UK regulators' expectations of risk control and culture                                                                                                                                                                                                                                                                                                 | 2.4       |
| <b>3.3</b> | <b>The Operational Risk Management Process</b><br>On completion, the candidate should:                                                                                                                                                                                                                                                                                 |           |
| 3.3.1      | Know the following terms used in relation to operational risk management: <ul style="list-style-type: none"> <li>• inherent (gross) risk</li> <li>• residual (net) risk</li> </ul>                                                                                                                                                                                     | 4         |
| 3.3.2      | Understand the role of the operational risk management                                                                                                                                                                                                                                                                                                                 | 4         |
| 3.3.3      | Understand the key aims of operational risk management: <ul style="list-style-type: none"> <li>• identification and assessment of risks</li> <li>• management of operational risk exposure within appetite</li> </ul>                                                                                                                                                  | 4         |

| Syllabus Unit/<br>Element |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                       | Chapter/<br>Section |
|---------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------|
| 3.3.4                     | Know the stages of the operational risk management process: <ul style="list-style-type: none"> <li>• policy</li> <li>• setting operational risk appetite and/or tolerance</li> <li>• identification/classification</li> <li>• risk and control measurement and assessment</li> <li>• risk response</li> <li>• monitoring</li> <li>• reporting and escalation</li> <li>• planning and change</li> </ul>                                                                                                                                                                                                                | 4                   |
| 3.3.5                     | Understand the practical constraints of implementing an operational risk management framework                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                         | 9                   |
| <b>3.4</b>                | <b>The Policy for Managing Operational Risk</b><br>On completion, the candidate should:                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                               |                     |
| 3.4.1                     | Understand the following areas required by an operational risk policy: <ul style="list-style-type: none"> <li>• board-level sponsorship</li> <li>• identification of key officers</li> <li>• cross divisional involvement and agreement</li> <li>• clearly defined roles and responsibilities</li> <li>• definition and communication of the risk management framework</li> <li>• segregation of duties</li> <li>• consistency of approach firm wide</li> <li>• coordination</li> <li>• documentation of acceptable risk levels</li> <li>• definition and communication of the control standards framework</li> </ul> | 3                   |
| 3.4.2                     | Understand the three lines of defence model                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                           | 3.10                |
| <b>3.5</b>                | <b>Risk Identification/Classification</b><br>On completion, the candidate should:                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |                     |
| 3.5.1                     | Understand the purpose of identifying risks                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                           | 5.1                 |
| 3.5.2                     | Know the Basel operational risk event types                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                           | 5.2                 |
| 3.5.3                     | Be able to apply risk classification in accordance with Basel II categories                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                           | 5.2                 |
| 3.5.4                     | Understand the following methods for identifying operational risk: <ul style="list-style-type: none"> <li>• risk and control self-assessment</li> <li>• reviews and audits</li> <li>• focus workshops</li> <li>• risk event analysis</li> <li>• management information</li> </ul>                                                                                                                                                                                                                                                                                                                                     | 5.3                 |

| Syllabus Unit/ Element |                                                                                                                                                                                                                                                                                                                      | Chapter/ Section |
|------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------|
| 3.5.5                  | Understand the practical problems of risk identification: <ul style="list-style-type: none"> <li>• changes to business operating models</li> <li>• changes to business environment</li> <li>• firm-wide engagement</li> <li>• differing individual perceptions of risk</li> </ul>                                    | 5.4              |
| <b>3.6</b>             | <b>Setting Risk Appetite</b><br>On completion, the candidate should:                                                                                                                                                                                                                                                 |                  |
| 3.6.1                  | Understand the following: <ul style="list-style-type: none"> <li>• the meaning of the term 'risk appetite'</li> <li>• the meaning of the term 'risk capacity'</li> <li>• the importance of documenting a firm's risk appetite</li> <li>• the content and target audience for a risk appetite statement</li> </ul>    | 3.11             |
| <b>3.7</b>             | <b>Risk and Control Measurement and Assessment</b><br>On completion, the candidate should:                                                                                                                                                                                                                           |                  |
| 3.7.1                  | Know the basic terms used in the assessment and measurement of operational risk                                                                                                                                                                                                                                      | 6                |
| 3.7.2                  | Understand the main reasons for assessing and measuring operational risk                                                                                                                                                                                                                                             | 6                |
| 3.7.3                  | Understand the ranking method of assessing operational risk                                                                                                                                                                                                                                                          | 6.2.1            |
| 3.7.4                  | Understand the risk and control self-assessment (self-certification) method of assessing operational risk                                                                                                                                                                                                            | 6.2.2            |
| 3.7.5                  | Understand the scenario analysis method of assessing operational risk                                                                                                                                                                                                                                                | 6.2.3            |
| 3.7.6                  | Understand the top-down risk assessment process                                                                                                                                                                                                                                                                      | 6.2.5            |
| 3.7.7                  | Understand the uses and limitations of internal risk event data in assessing operational risk                                                                                                                                                                                                                        | 6.2.6            |
| 3.7.8                  | Understand the difficulties involved in measuring operational risk                                                                                                                                                                                                                                                   | 6.2              |
| 3.7.9                  | Understand the benchmarking method of measuring operational risk                                                                                                                                                                                                                                                     | 6.2.4            |
| 3.7.10                 | Know the sources and uses of external loss data                                                                                                                                                                                                                                                                      | 6.2.7            |
| 3.7.11                 | Understand the limitations of using external loss data                                                                                                                                                                                                                                                               | 6.2.7            |
| 3.7.12                 | Be able to apply the following methods of risk assessment and risk measurement to simple, practical examples: <ul style="list-style-type: none"> <li>• rating and ranking</li> <li>• risk and control self-assessment</li> <li>• scenario analysis</li> <li>• benchmarking</li> <li>• risk event analysis</li> </ul> | 6.2              |

| Syllabus Unit/<br>Element |                                                                                                                                                                                                                                                                                                                                                                  | Chapter/<br>Section |
|---------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------|
| <b>3.8</b>                | <b>Risk Response</b><br>On completion, the candidate should:                                                                                                                                                                                                                                                                                                     |                     |
| 3.8.1                     | Understand the type of risk response: <ul style="list-style-type: none"> <li>• risk acceptance</li> <li>• reducing the likelihood and the impact</li> <li>• risk avoidance</li> <li>• risk transfer</li> </ul>                                                                                                                                                   | 8                   |
| 3.8.2                     | Understand the use of the following examples of operational controls in reducing the impact or likelihood of operational risk: <ul style="list-style-type: none"> <li>• supervision and segregation of duties</li> <li>• business continuity and contingency planning</li> <li>• information and physical security</li> <li>• risk awareness training</li> </ul> | 8                   |
| 3.8.3                     | Understand how the following examples can be used to transfer operational risk: <ul style="list-style-type: none"> <li>• insurance</li> <li>• outsourcing</li> </ul>                                                                                                                                                                                             | 8                   |
| <b>3.9</b>                | <b>Risk Monitoring and Reporting</b><br>On completion, the candidate should:                                                                                                                                                                                                                                                                                     |                     |
| 3.9.1                     | Understand the main activities that comprise the risk monitoring of the risk management process: <ul style="list-style-type: none"> <li>• measurement</li> <li>• assessment</li> </ul>                                                                                                                                                                           | 7.1                 |
| 3.9.2                     | Understand the importance of risk monitoring in the risk management process                                                                                                                                                                                                                                                                                      | 7.1                 |
| 3.9.3                     | Understand how indicators can be used as a method of monitoring operational risk                                                                                                                                                                                                                                                                                 | 5.3 and 7.1         |
| 3.9.4                     | Understand the main functions of operational risk reporting to internal and external stakeholders                                                                                                                                                                                                                                                                | 7.2                 |
| <b>3.10</b>               | <b>Operational Resilience</b><br>On completion, the candidate should:                                                                                                                                                                                                                                                                                            |                     |
| 3.10.1                    | Understand the difference between operational risk and operational resilience and the significance placed upon operational resilience by the regulators                                                                                                                                                                                                          | 10                  |

| Syllabus<br>Unit/<br>Element |  | Chapter/<br>Section |
|------------------------------|--|---------------------|
|------------------------------|--|---------------------|

| Element 4  | The Causes and Impacts of Operational Risk                                                                                                                                                                                                                                                                                                                                    | Chapter 4   |
|------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------|
| <b>4.1</b> | <b>Operational Risk: Causes and Events</b><br>On completion, the candidate should:                                                                                                                                                                                                                                                                                            |             |
| 4.1.1      | Know the four causes of operational risk events                                                                                                                                                                                                                                                                                                                               | 1           |
| 4.1.2      | Understand why knowledge of causes is important in operational risk management                                                                                                                                                                                                                                                                                                | 1           |
| 4.1.3      | Understand the operational risk events in simple, practical examples: <ul style="list-style-type: none"> <li>• incorrect data</li> <li>• delayed processing and documentary omissions</li> <li>• regulatory non-compliance</li> <li>• project mismanagement</li> <li>• fraud and theft</li> <li>• unforeseen litigation</li> <li>• information technology failures</li> </ul> | 1.3 and 2.2 |
| <b>4.2</b> | <b>Operational Risk: Impacts</b><br>On completion, the candidate should:                                                                                                                                                                                                                                                                                                      |             |
| 4.2.1      | Understand direct and indirect financial loss                                                                                                                                                                                                                                                                                                                                 | 2.1         |
| 4.2.2      | Understand the following examples of financial and non-financial impacts of an operational risk event: <ul style="list-style-type: none"> <li>• potential loss of earnings</li> <li>• regulatory censure/closure and reputational damage</li> <li>• staff demotivation</li> <li>• poor conduct risk outcomes</li> <li>• remedial and litigation costs</li> </ul>              | 2.1         |
| <b>4.3</b> | <b>The Links Between Causes, Events and Impacts of Operational Risk</b><br>On completion, the candidate should:                                                                                                                                                                                                                                                               |             |
| 4.3.1      | Understand the links between, causes, events and impacts of operational risk                                                                                                                                                                                                                                                                                                  | 1.3 and 2.3 |
| <b>4.4</b> | <b>Near-Miss Identification and Reporting</b><br>On completion, the candidate should:                                                                                                                                                                                                                                                                                         |             |
| 4.4.1      | Understand the concept and importance of near miss identification and reporting as a result of an operational risk event                                                                                                                                                                                                                                                      | 3           |

| Syllabus Unit/<br>Element |                                                                                                                                                                                                                                                                                                                                                                                                                                         | Chapter/<br>Section |
|---------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------|
| <b>Element 5</b>          | <b>Operational Risk Arising in the Trade Cycle</b>                                                                                                                                                                                                                                                                                                                                                                                      | <b>Chapter 5</b>    |
| <b>5.1</b>                | <b>Set-Up</b><br>On completion, the candidate should:                                                                                                                                                                                                                                                                                                                                                                                   |                     |
| 5.1.1                     | Understand what tasks must be completed during set-up: <ul style="list-style-type: none"> <li>• marketing and sales</li> <li>• Know Your Customer</li> <li>• international sanctions</li> <li>• suitability</li> <li>• account set-up</li> <li>• reference data</li> <li>• credit assessment</li> <li>• standard settlement instructions</li> <li>• legal contract negotiation</li> <li>• client and counterparty agreements</li> </ul> | 2.2                 |
| 5.1.2                     | Understand the key risks, controls and indicators associated with the set-up phase                                                                                                                                                                                                                                                                                                                                                      | 2.2                 |
| <b>5.2</b>                | <b>Execution</b><br>On completion, the candidate should:                                                                                                                                                                                                                                                                                                                                                                                |                     |
| 5.2.1                     | Understand the role and responsibilities of the front office                                                                                                                                                                                                                                                                                                                                                                            | 2                   |
| 5.2.2                     | Understand the nature of the key risks, controls and indicators in the front office: <ul style="list-style-type: none"> <li>• transaction capture</li> <li>• exchange of transaction instructions</li> <li>• monitoring position and credit limits</li> </ul>                                                                                                                                                                           | 2                   |
| <b>5.3</b>                | <b>Pre-Settlement Phase</b><br>On completion, the candidate should:                                                                                                                                                                                                                                                                                                                                                                     |                     |
| 5.3.1                     | Understand the components of the pre-settlement phase: <ul style="list-style-type: none"> <li>• transaction capture</li> <li>• trade confirmation</li> <li>• asset and cash positioning</li> <li>• centralised clearing</li> <li>• calculation of collateral</li> </ul>                                                                                                                                                                 | 3.1                 |
| 5.3.2                     | Understand the key risks, controls and indicators associated with the pre-settlement phase                                                                                                                                                                                                                                                                                                                                              | 3.1                 |

| Syllabus Unit/ Element |                                                                                                                                                                                                                                                                                                                                    | Chapter/ Section |
|------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------|
| <b>5.4</b>             | <b>Settlement Phase</b><br>On completion, the candidate should:                                                                                                                                                                                                                                                                    |                  |
| 5.4.1                  | Understand the components of the settlement phase: <ul style="list-style-type: none"> <li>• payment instructions</li> <li>• payment receipts</li> <li>• securities transfers and custody</li> </ul>                                                                                                                                | 3.2              |
| 5.4.2                  | Understand the key risks, controls and indicators associated with the settlement phase                                                                                                                                                                                                                                             | 3.2              |
| <b>5.5</b>             | <b>Post-Settlement Phase</b><br>On completion, the candidate should:                                                                                                                                                                                                                                                               |                  |
| 5.5.1                  | Understand the components of the post-settlement phase: <ul style="list-style-type: none"> <li>• reconciliation</li> <li>• inventory management</li> <li>• margin/collateral monitoring</li> </ul>                                                                                                                                 | 3.2              |
| 5.5.2                  | Understand the key risks, controls and indicators associated with the post-settlement phase                                                                                                                                                                                                                                        | 3.2              |
| <b>5.6</b>             | <b>Asset Servicing</b><br>On completion, the candidate should:                                                                                                                                                                                                                                                                     |                  |
| 5.6.1                  | Know the main types of corporate action: <ul style="list-style-type: none"> <li>• dividend and coupon payments</li> <li>• redemption of fixed-income securities</li> <li>• rights issues</li> <li>• stock buy-backs</li> <li>• takeovers and mergers</li> <li>• conversion of convertible bonds</li> <li>• proxy voting</li> </ul> | 3.2              |
| 5.6.2                  | Understand the main risks associated with corporate action processing: <ul style="list-style-type: none"> <li>• missed announcements</li> <li>• complex structure of information and instruction flows between participants</li> <li>• late election</li> <li>• incomplete or incorrect information or instructions</li> </ul>     | 3.2              |

| Syllabus Unit/Element |                                                                                                                                                                                                                                                         | Chapter/Section  |
|-----------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------|
| <b>Element 6</b>      | <b>The Support and Control Functions</b>                                                                                                                                                                                                                | <b>Chapter 6</b> |
| <b>6.1</b>            | <b>Risk Governance</b><br>On completion, the candidate should:                                                                                                                                                                                          |                  |
| 6.1.1                 | Understand how risk governance is established in financial institutions: <ul style="list-style-type: none"> <li>the role of the Board of Directors</li> <li>the role of the Board Risk Committee</li> <li>the role of the Chief Risk Officer</li> </ul> | 1.1              |
| <b>6.2</b>            | <b>Middle/Back Office</b><br>On completion, the candidate should:                                                                                                                                                                                       |                  |
| 6.2.1                 | Understand the role and responsibilities of the middle and back office functions in managing operational risk                                                                                                                                           | 1.2              |
| <b>6.3</b>            | <b>Compliance</b><br>On completion, the candidate should:                                                                                                                                                                                               |                  |
| 6.3.1                 | Understand the role and responsibilities of the compliance function in relation to operational risk                                                                                                                                                     | 1.3              |
| 6.3.2                 | Understand the impacts of compliance risk                                                                                                                                                                                                               | 1.3              |
| <b>6.4</b>            | <b>Financial Reporting and Regulation</b><br>On completion, the candidate should:                                                                                                                                                                       |                  |
| 6.4.1                 | Understand the role of the financial reporting and regulatory function in the context of the operational risk environment                                                                                                                               | 1.4              |
| <b>6.5</b>            | <b>HR</b><br>On completion, the candidate should:                                                                                                                                                                                                       |                  |
| 6.5.1                 | Understand the role of the HR function in the context of the operational risk environment                                                                                                                                                               | 1.5              |
| <b>6.6</b>            | <b>Internal Audit</b><br>On completion, the candidate should:                                                                                                                                                                                           |                  |
| 6.6.1                 | Understand the role of the internal audit function in relation to operational risk                                                                                                                                                                      | 1.6              |
| 6.6.2                 | Know the requirements of MiFID directive in respect of the internal audit function                                                                                                                                                                      | 1.6              |
| <b>6.7</b>            | <b>IT</b><br>On completion, the candidate should:                                                                                                                                                                                                       |                  |
| 6.7.1                 | Understand the role of the IT function in the context of the operational risk environment                                                                                                                                                               | 1.7              |



| Syllabus Unit/ Element |                                                                                                                                 | Chapter/ Section |
|------------------------|---------------------------------------------------------------------------------------------------------------------------------|------------------|
| <b>6.8</b>             | <b>Legal</b><br>On completion, the candidate should:                                                                            |                  |
| 6.8.1                  | Understand the role of the legal function in the context of the operational risk environment                                    | 1.8              |
| 6.8.2                  | Know the common legal areas where operational risk issues arise                                                                 | 1.8              |
| <b>6.9</b>             | <b>The Product Development and Marketing</b><br>On completion, the candidate should:                                            |                  |
| 6.9.1                  | Understand the role of the product development and marketing function in the context of the operational risk environment        | 1.9              |
| <b>6.10</b>            | <b>The Project Management and Change Management</b><br>On completion, the candidate should:                                     |                  |
| 6.10.1                 | Understand the role of the project management and change management function in the context of the operational risk environment | 1.10             |

| Element 7  | Operational Risk in the Regulatory Environment                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                    | Chapter 7 |
|------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------|
| <b>7.1</b> | <b>Achieving Common Standards and Protection</b><br>On completion, the candidate should:                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                          |           |
| 7.1.1      | Know how the following directives regulations, codes and regimes impact operational risk: <ul style="list-style-type: none"> <li>• corporate governance</li> <li>• Sarbanes-Oxley</li> <li>• MiFID, MiFID II, MiFIR</li> <li>• Dodd-Frank</li> <li>• Foreign Account Tax Compliance Act (FATCA)</li> <li>• conduct risk</li> <li>• General Data Protection Regulation (GDPR)</li> <li>• Sustainable Finance Disclosure Regulation (SFDR)</li> <li>• Digital Operational Resilience Act (DORA)</li> <li>• Senior Managers and Certification Regime (SM&amp;CR)</li> <li>• Consumer Duty</li> </ul> | 2         |

| Syllabus Unit/<br>Element |                                                                                                                                                                                                                                                                 | Chapter/<br>Section |
|---------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------|
| <b>7.2</b>                | <b>Basel Accords</b><br>On completion, the candidate should:                                                                                                                                                                                                    |                     |
| 7.2.1                     | Know the basic requirements of the operational risk aspects of: <ul style="list-style-type: none"> <li>• Basel Accords</li> <li>• The Capital Requirements Directive</li> </ul>                                                                                 | 3.1                 |
| 7.2.2                     | Understand the main operational risk features of the Basel Accords                                                                                                                                                                                              | 3.1                 |
| 7.2.3                     | Understand the differences between Pillars 1, 2 and 3 of the Basel Accords relating to operational risk                                                                                                                                                         | 3.2                 |
| 7.2.4                     | Understand the three measurement approaches for operational risk capital requirements under Basel: <ul style="list-style-type: none"> <li>• basic indicator approach</li> <li>• standardised approach</li> <li>• advanced measurement approach (AMA)</li> </ul> | 3.2.1               |

## Examination Specification

Each examination paper is constructed from a specification that determines the weightings that will be given to each element. The specification is given below.

It is important to note that the numbers quoted may vary slightly from examination to examination as there is some flexibility to ensure that each examination has a consistent level of difficulty. However, the number of questions tested in each element should not change by more than plus or minus 2.

| Element Number | Element                                           | Questions |
|----------------|---------------------------------------------------|-----------|
| 1              | Risk Basics                                       | 3         |
| 2              | Other Major Risks                                 | 7         |
| 3              | The Nature of Operational Risk                    | 20        |
| 4              | The Causes and Impacts of Operational Risk Events | 4         |
| 5              | Operational Risks Arising in the Trade Cycle      | 5         |
| 6              | The Support and Control Functions                 | 7         |
| 7              | Operational Risk in the Regulatory Environment    | 4         |
| <b>Total</b>   |                                                   | <b>50</b> |



Well done for finishing your studies...

# But what's next?

Book your CISI exam!

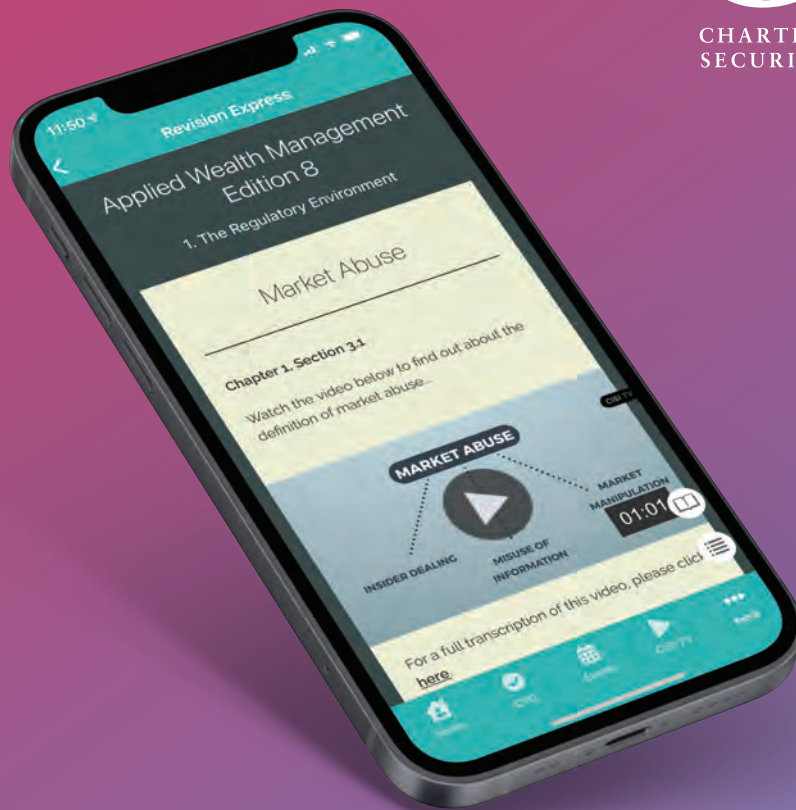
Our exams can be sat at a test centre near you  
or via remote invigilation from your home or a meeting room.

To find your nearest test centre venue,  
visit [cisi.org/cbt](https://www.cisi.org/cbt)

To learn more about remote invigilation,  
visit [cisi.org/ri](https://www.cisi.org/ri)

To book your exam, visit [cisi.org/exam-booker](https://www.cisi.org/exam-booker) or contact our Customer Support Centre on +44 20 7645 0777

**CISI**  
CHARTERED INSTITUTE FOR  
SECURITIES & INVESTMENT



# Enhance your studies with the MyCISI App

As a student member, you can also access all the first-class CPD resources we offer such as Professional Refresher online learning modules, CISI TV videos and more – all in one easy to use app.

Search for MyCISI on the Play Store or App Store.



# How CISI membership will benefit you after your studies



Gain a competitive edge with first-class CISI membership benefits. These benefits are enjoyed by over 43,000 professionals across the world and help keep our members on top of their game.

Below are some of the key resources that you can access as part of your student membership. To retain these benefits after your studies, join the CISI as a member.

## CISI TV

A selection of our most popular CPD events, interviews, and features, available to watch online, anytime, anywhere.

**500+**  
videos on demand

**120,000+**  
on-demand videos  
watched last year



## CPD, Networking & Social Events

Our in-person and virtual programme offers the hottest topics, expert insight and networking opportunities.

**500+**  
events every year

**24**  
UK Branches and  
9 National Advisory  
Councils who represent  
local members and guide our offering



## Online Learning with Professional Refresher

Our Professional Refresher series offers cutting edge analysis and insight for financial services professionals in bite-sized elearning modules.

**200+** unique modules

**25,000+** users last year

**10** modules updated every month



## The Review

Our award-winning members magazine incorporates the latest news, insight and thought leadership affecting your profession, available both online and in print.

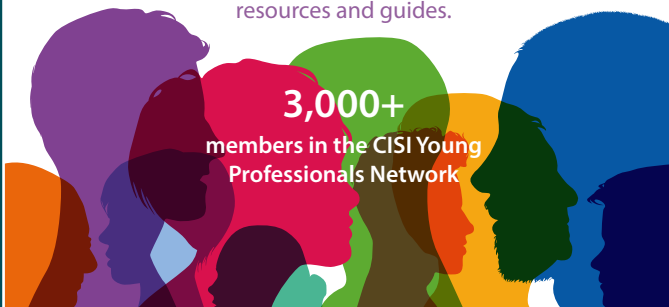
**100,000+**  
views online last year



## Young Professionals' Network (YPN)

Our YPN was created to help young professionals aged 18-35 harness their competitive edge and professional development skills with a dedicated range of tailored events, resources and guides.

**3,000+**  
members in the CISI Young  
Professionals Network



## Designatory Letters and Badges

Differentiate yourself from your peers with exclusive member badges and designatory letters to showcase your achievements.



## Interested in joining our community?

Our membership levels start from Affiliate level, which is available to anyone. Depending on the qualifications you achieve, you may be eligible for our higher-level membership, such as Associate or Full Member. Find out more at [cisi.org/membership](https://www.cisi.org/membership)



# Online Learning

**Cutting edge analysis and insight for financial services professionals, available anytime, anywhere**

We offer **over 200** elearning modules to help you meet your CPD requirements. Here are some of the modules available. These CISI Professional Refreshers are free to CISI members and accessible to CISI student members.

To find out more about Professional Refresher elearning modules, visit [cisi.org/pr](https://www.cisi.org/pr)

## Anti-Money Laundering

Understand AML legislation and regulation, the role of the MLRO, and the sanctions and penalties.



## Client Assets and Client Money Essentials

Gain an overview of the principles and high-level rules associated with holding and protecting client assets.



## Conflicts of Interest

Consider examples of conflicts of interest, tools, policies and procedures, enforcement action, and good practice.



## Data Science

Digitisation of business operations has accelerated the speed of data capture. Harness the value of your data.



## Diversity and Inclusion

Targeted at those responsible for diversity, equality and anti-discrimination, and those recruiting and managing.



## Financial Crime

Gain an overview of insider dealing, market abuse, money laundering, terrorist finance and financial sanctions.



## Financial Planning

Gain an overview of the financial planning process, key terms and the regulatory framework that governs it.



## Greenwashing

This module explores the key concepts surrounding greenwashing, the wider implications, and the measures being taken to fight it.



## Impact Investing

Aim to take ethical and sustainable investment principles a step further through intentional investment.



## Integrity and Ethics

Understand ethics in finance, the importance of trust and trustworthiness, and compliance versus ethics.



## Market Abuse

Examine offences, penalties, safe harbours, reporting obligations and the relationship with other offences.



## Neuroscience at Work

Learn how to work optimally without harming your health when faced with increased workloads and deadlines.



# Revision Express

## Test your knowledge before your exam

Revision Express is an online study tool designed to be used alongside CISI workbooks to prepare you for your exam. It contains a range of questions that aid learning by reaffirming understanding of the subject, and the Sample Exam Standard Test contains questions that have been compiled to reflect as closely as possible the standard that you will experience in your exam.



## Key Features

- ✓ Special end-of-module practice exam to reflect as closely as possible the standard you will experience in your exam (please note, however, they are not the CISI exam questions themselves)
- ✓ Questions throughout to reaffirm understanding of the subject
- ✓ Extensive glossary of terms
- ✓ Allows you to study whenever you like, and on any device

## To purchase Revision Express

Visit the CISI's online bookshop at [cisi.org/bookshop](https://cisi.org/bookshop) or call our Customer Support Centre on +44 20 7645 0777  
If you have already purchased Revision Express, you can access it via the MyCISI app or MyStudy at [cisi.org/mystudy](https://cisi.org/mystudy)

Please note: The questions in Revision Express should not be viewed as sample exam questions as sample papers are available for this purpose.



## The possibilities are endless with CISI qualifications

Globally recognised qualifications that will  
allow you to spread your wings in the world  
of finance.

Enhance your skills, career and personal  
brand at [cisi.org/qualifications](https://cisi.org/qualifications)





